TESPİTİ KOD GİBİ DÜŞÜNMEK · SAHA REFERANSI

DWELL

VOL. 02

DETECTION ENGINEERING

Tespit mühendisliği

Fikirden üretime: kural yazmak, doğrulamak ve bir tespit kütüphanesini yaşatmak üzerine bir saha referansı.

ÖMER ŞAYAK

Kural değil, kanıt.

KÜNYE

DWELL · Cilt 2

Detection Engineering — Tespit Mühendisliği

Fikirden üretime: Kural yazma, doğrulama ve tespit kütüphanesi yönetimi üzerine bir saha referansı.

Yazar: Ömer Şayak
Yayın yılı: 2026

LİSANS VE KULLANIM

© 2026 Ömer Şayak. Tüm hakları, aşağıda belirtilen lisans koşulları saklı kalmak üzere korunmaktadır.

Bu kitabın yazara ait metinleri, tabloları ve özgün görselleri Creative Commons Atıf-GayriTicari-AynıLisanslaPaylaş 4.0 Uluslararası (CC BY-NC-SA 4.0) lisansı kapsamında yayımlanmıştır. İçerik, kaynak gösterilmesi ve aynı lisans koşullarının korunması şartıyla ticari olmayan amaçlarla paylaşılabilir ve uyarlanabilir. Ticari kullanım için ayrıca izin alınması gerekir.

Kitapta yer alan, yazar tarafından oluşturulmuş Sigma kuralları, sorgular, betikler ve yapılandırma örnekleri MIT No Attribution (MIT-0) lisansı kapsamında sunulmuştur. Bu örnekler atıf zorunluluğu olmaksızın kullanılabilir, değiştirilebilir ve ticari projelere uyarlanabilir.

Üçüncü taraf içeriklerin hakları ilgili sahiplerine aittir. Konuk katkıları kitabın genel lisansına dâhil değildir; bu metinlerin kitap dışındaki kullanımı için katkı sahiplerinden ayrıca izin alınmalıdır.

Lisans koşulları:

CC BY-NC-SA 4.0

MIT-0

SORUMLULUK REDDİ

Bu kitap, tespit mühendisliği alanında eğitim ve teknik başvuru amacıyla hazırlanmıştır. İçerikteki kurallar, sorgular, yapılandırmalar ve diğer teknik örnekler, kullanılacak ürünün sürümüne ve sistem ortamına göre farklı sonuçlar verebilir. Örneklerin herhangi bir ortamda doğrudan çalışacağı veya belirli bir güvenlik sonucunu sağlayacağı garanti edilmez.

Saldırı simülasyonu ve adversary emulation kapsamında açıklanan teknikler yalnızca açıkça yetkilendirilmiş, yazılı izin alınmış ve kontrollü sistemlerde uygulanmalıdır. Okuyucu, örnekleri kullanmadan önce kendi ortamındaki teknik gereksinimleri, güvenlik etkilerini ve geçerli yasal yükümlülükleri değerlendirmelidir.

Ürün ve marka adları yalnızca tanımlama amacıyla kullanılmıştır; ilgili haklar sahiplerine aittir. Aksi belirtilmedikçe örneklerdeki kurum, kullanıcı ve sistem bilgileri kurgusaldır.

ÖNSÖZ

Neden bu cilt

Serinin ilk cildinde SOC'un rollerini, teknolojisini, log kaynaklarını, triyajını, müdahalesini ve av işini anlattım. Tespit mühendisliğine ise daha az yer ayırabilmiştim. Bu işi kendi ayrıntılarıyla ele alan bir cilde ihtiyaç duydum.

Burada veriyi tanımaktan kuralı sınamaya, alarmı ayarlamaktan bakıma kadar tespit mühendisliğini ayrıntılarıyla ele alıyorum. Okurken kendi ortamınızdaki tespitleri de bu sorularla değerlendirebilmenizi istiyorum.

Bu cildi o çalışma için yazdım.

Bu kitabı yazarken temel aldığım düşünce şu: bir tespitin neyi gördüğünü kanıtıyla gösterebilmeliyiz. Kural, hedeflediğimiz davranışı tarif eder. Veri kontrolü, test, emülasyon ve bakım ise bu tarifin ortamda nasıl çalıştığını anlamamızı sağlar. Kütüphanenin büyüklüğü, tek başına tespitlerin sağlıklı olduğunu göstermez.

Bu kitabı kural yazan ve yazmaya başlayanlar için yazdım. SOC analisti olarak tespitin nasıl üretildiğini merak ediyorsanız, SIEM yöneticisi olarak kural setinizin neden köreldiğini anlamak istiyorsanız ya da yeni bir tespit ekibinin ilk üyesiyseniz, burada kendi işinizden bir şey bulacaksınız. Bir SOC'un nasıl çalıştığını bilmeniz yeterli. Serinin ilk cildi bu zemini anlatıyor; bu cilt kendi başına da okunabilir.

Bölümleri dört kısma ayırdım. Zemin (1–2) veriyi; Yazmak (3–6) kuralın yapısını, Sigma'yı, mantık kalıplarını ve ATT&CK eşlemesini; Doğrulamak (7–9) test, emülasyon ve yanlış alarm yönetimini; İşletmek (10–14) depoyu, bakımı, platformları, ekip işini ve birleşik vakaları ele alıyor. Sıra, bir tespiti üretirken izlediğimiz yolu takip ediyor.

Baştan sona okuyabilir ya da ilgili bölüme doğrudan gidebilirsiniz. Sondaki dört ek, çalışma sırasında başvurmak için hazırlandı.

Buradaki örnekleri kullanırken kendi verinizi esas alın. Bir kuralın mantığı doğru olsa da alan eşlemesi, kaynak kapsamı ve meşru iş akışları sizin ortamınızda farklı olabilir. Benim amacım, kuralı yazarken ve üretime alırken hangi soruları soracağınızı göstermektir.

Birlikte çalıştığım ekiplere, alarmları inceleyip geri bildirim veren analistlere ve kurallarımı sınayan kırmızı takım arkadaşlarıma teşekkür ederim. Bu kitapta, birlikte öğrendiklerimizin payı var.

Serinin bir sonraki cildi threat hunting'e ayrılacak: tespitin bittiği yerde, hipotezle aramanın başladığı yer.

İyi okumalar.

Ömer Şayak

KATKIDA BULUNANLAR

Konuk katkılar

Bu kitaptaki bazı bölümlerde, kendi alanlarında çalışan pratisyenlerin imzalı katkıları yer alıyor. Metin boyunca "Konuk Katkı" başlıklı kutularda görürsünüz; her biri kendi sesiyle, kendi deneyimini anlatır.

Farklı masalarda çalışan insanların aynı soruna nasıl baktığını okumak, kendi yaklaşımımızın sınırlarını görmemizi sağlıyor.

Muhammed Faruk Koyuncu Tespit ve Müdahale Mühendisi
Bölüm 6.1 · 8.2 · 8.6 — ATT&CK, varyant tasarımı ve emülasyon sonucu

Sarp Gezer Tehdit Tespit Mühendisi
Bölüm 9.3 · 9.5 · 10.11 — gürültü, dışlama ve ortam farkı

Konuk katkılar, ilk dosyada yer alan yazar izin beyanı esas alınarak korunmuştur. Her metnin telifi katkı sahibine aittir; kitabın genel lisansı bu kutulara uygulanmaz. Bu baskıda katkı sahipleri adına yeni bir onay veya yeniden paylaşım izni verilmiş sayılmaz. Kitabın ana metnindeki görüş ve hatalar bana aittir.

Bu metinlerde anlatılan olaylar, katkı sahiplerinin kendi deneyimlerinden genelleştirilmiştir; kurum, müşteri ve sistem adları geçmez.

BU KİTAP HAKKINDA

Kapsam ve konvansiyonlar

Bu cilt, bir tespitin fikirden üretime ve oradan emekliliğe kadar geçtiği yolu ele alır. Amaç belirli bir SIEM'i öğretmek değil; hangi platformda çalışırsanız çalışın taşınabilir olan tespit düşüncesini ve mühendislik disiplinini kurmaktır.

Örneklerin ve kanıtın sınırı

Birincil kaynak, ürünün alan veya API tanımını doğrular; kurumunuzun ayarını doğrulamaz. Birim testi, seçilmiş olaylarda mantığı sınar; canlı platform testi yerine geçmez. Derleme ve yerel test iddiaları, yalnızca ilgili sürümdeki eşlikçi paket raporu ve test çıktıları mevcutsa doğrulanabilir. Windows, Caldera, QRadar, Splunk, Elastic ve Sentinel üzerinde canlı çalıştırılmamış örnekler böyle bir başarı iddiası taşımaz.

Şekillerin ve birleşik vakaların sayıları, ayrıca ölçüm kaynağı belirtilmedikçe öğretim amaçlıdır. Başarı, alarm sayısı veya performans sonucu olarak alıntılanmamalıdır. Konuk kutuları katkı sahibinin anlatımı olarak korunur.

KAPSAM DIŞI

Bir referans kitabının neyi kapsamadığını da söylemesi gerekir. Bu cilt **tespit mühendisliğinin yöntemini** anlatır; belirli tehdit alanlarının kataloğunu değil.

Örnekler ağırlıklı olarak Windows, Linux ve bulut ortamlarından seçilmiştir; macOS, OT/ICS ve mobil platformlar kapsam dışıdır. Bu ortamların telemetrisi farklıdır, ama kitaptaki yöntem — veri kontrolü, kalıp seçimi, test, doğrulama, bakım — oralarda da aynı biçimde uygulanır.

Şunlar da bilinçli olarak dışarıda bırakıldı: **SOAR ve otomatik yanıt** (serinin ilk cildinde ele alındı), **threat hunting** (bir sonraki cildin konusu), **olay müdahalesi ve adli bilişim** (ayrı bir disiplin), ve **makine öğrenmesi modellerinin matematiği** — bu sonuncusuna Bölüm 5.7'de kural yazarının bilmesi gereken kadarıyla değinilir.

KUTULAR

Metin boyunca beş tür kutu kullanılır. Kutular gövde metnini tekrarlamaz; yalnızca ona bir şey ekler.

> **TANIM**
> Bir terimin kısa ve kesin karşılığı. Hızlı başvuru içindir.

> **SAHADAN NOT**
> Kitaptan değil sahadan gelen gözlem. Pratikte işe yarayan kısayollar ve bir kez yaşanmış uyarılar.

> **DİKKAT**
> Sık yapılan hatalar ve tehlikeli varsayımlar.

> **ÖRNEK**
> Somut bir kural, komut ya da senaryo.

> **KONUK KATKI**
> Sahada çalışan bir pratisyenin imzalı metni. Kendi sesiyle, kendi deneyimi; telifi yazarına aittir.

İÇİNDEKİLER

İçerik

DWELL · Cilt 2 1
Neden bu cilt 2
Konuk katkılar 3
Kapsam ve konvansiyonlar 4
Örneklerin ve kanıtın sınırı 4
Tespit Mühendisliği Nedir 9
1.1 Kural yazmak ile tespit üretmek 9
1.2 Disiplinin üç çıktısı 10
1.3 Neden ayrı bir uzmanlık hâline geldi 11
1.4 Dört basamak 12
1.5 Kitabın haritası 13
Veri ve Alan Eşleme 14
2.1 Tespit yazılabilir veri 14
2.2 Aynı kavramın farklı adları 14
2.3 Ortak şemalar: ECS, OCSF, CIM 16
2.4 Eşlemeyi kodla yönetmek 17
2.5 Windows: denetim politikası ve kanallar 18
2.6 Sysmon yapılandırmasını tasarlamak 19
2.7 Linux ve konteyner 21
2.8 Ağ ve bulut 22
2.9 Veri sözleşmesi 22
2.10 Sessiz bozulmayı yakalamak 23
2.11 Kapsama envanteri 25
İyi Bir Tespitin Anatomisi 27
3.1 Bir tespitin dört parçası 27
3.2 İsabet ve kapsama 28
3.3 Tespit türleri ve dayanıklılık 29
3.4 Eyleme dönüklük: alarm ne söylemeli 30
3.5 Şiddet, güven ve risk 31
3.6 Metadata: kuralı devredilebilir kılmak 31
3.7 Kural mı, av mı, zenginleştirme mi 33
Sigma: Kural Dili 34
4.1 Neden ortak bir kural dili 34
4.2 Kural yapısı 34
4.3 logsource: kuralın nereye bakacağı 35
4.4 detection: selection, filter, condition 36
4.5 Modifier'lar 38

4.6 condition ifadeleri ... 38
4.7 Korelasyon kuralları ... 39
4.8 Kuralı hedefe indirmek ... 41
4.9 Kural yazım disiplini ... 43
Kural Mantığı Kalıpları ... 44
5.1 Kalıp düşünmek ... 44
5.2 Eşleşme: bilinen kötüyü aramak ... 44
5.3 İlişki: alanlar arası bağ ... 45
5.4 Eşik: kaç kere, ne kadar sürede ... 46
5.5 Nadirlik: ilk kez görülen ... 47
5.6 Sıra: zinciri yakalamak ... 48
5.7 Sapma: normalden uzaklaşma ... 49
5.8 Kalıp seçmek ve birleştirmek ... 50
ATT&CK Eşleme ve Kapsama ... 51
6.1 ATT&CK'i doğru okumak ... 51
6.2 Eşleme disiplini ... 52
6.3 Kapsama haritasının üç katmanı ... 53
6.4 Kapsama yüzdesi neden yanıltıcı ... 54
6.5 Hangi tekniğe önce ... 55
6.6 Kapsamayı yaşayan bir şey olarak tutmak ... 56
Testi Kurmak ... 57
7.1 Varsayımı kaldırmak ... 57
7.2 Test piramidi ... 58
7.3 Birim testi: iki tür örnek ... 59
7.4 Testi çalıştırmak ... 60
7.5 Regresyon: değişikliğin görünmeyen etkisi ... 61
7.6 Üretime çıkan yol ... 62
7.7 Testin sınırları ... 63
Adversary Emulation ... 64
8.1 Emülasyon ne sorar ... 64
8.2 Atomik testler: en küçük birim ... 64
8.3 Caldera: kavramlar ... 66
8.4 Kendi ability'nizi yazmak ... 66
8.5 Bir koşuyu yürütmek ... 67
8.6 Sonucu ölçmek ... 68
8.7 Bulguyu kurala çevirmek ... 70
8.8 Güvenli emülasyon ... 70
8.9 Doğrulamayı sürekli hâle getirmek ... 71
False Positive Mühendisliği ... 72
9.1 Gürültünün gerçek maliyeti ... 72
9.2 Gürültüyü ölçmek ... 73

9.3 Kaynağı bulmak 74
9.4 Baselining: normali öğrenmek 75
9.5 Dışlama tasarımı 76
9.6 Dışlamanın alternatifleri 78
9.7 Tuning döngüsü 79
9.8 Kabul edilen gürültü 79
Detection-as-Code 81
10.1 Kuralı yazılım gibi ele almak 81
10.2 Depo yapısı 82
10.3 Şemayı zorunlu kılmak 83
10.4 İş akışı 83
10.5 Kural incelemesi 84
10.6 Dağıtım hattı 84
10.7 Kural durumu ve ortamlar 85
10.8 Geri alma ve sürüm 86
10.9 Erişim ve izlenebilirlik 86
10.10 Topluluk kurallarını içeri almak 87
10.11 Çok müşterili kütüphane 88
10.12 Depodan türeyen metrikler 90
10.13 Mevcut kütüphaneyi taşımak 91
10.14 Küçük ekipte detection-as-code 92
Tespit Borcu ve Kütüphane Bakımı 93
11.1 Kütüphane neden çürür 93
11.2 Bir kural nasıl körelir 94
11.3 Sessizliği okumak 95
11.4 Gözden geçirme takvimi 96
11.5 Dışlama borcu 97
11.6 Emekliye ayırmak 97
11.7 Kütüphane sağlık göstergeleri 98
11.8 Bakımı işin içine yerleştirmek 99
11.9 Bir bakım turu, baştan sona 100
Platforma İndirmek 101
12.1 Çeviri neden yeterli değil 101
12.2 Korelasyon mimarisi farkı 102
12.3 QRadar 103
12.4 Splunk 104
12.5 Elastic 105
12.6 Microsoft Sentinel 105
12.7 Alarm nesnesi ve gruplama 106
12.8 Aynı tespit, dört platform 107
12.9 Platform değiştirmek 108

Rol ve Ekip 109
13.1 Rolün doğuşu 109
13.2 Zaman gerçekte nereye gidiyor 109
13.3 Beceriler 110
13.4 Ekip içindeki arayüzler 111
13.5 Rolü kurmak ve büyütmek 112
13.6 Başarıyı ölçmek 112
13.7 Bu işte gelişmek 113
Uçtan Uca Üç Vaka 114
14.1 Vakaları nasıl okumalı 114
14.2 Vaka 1 — Servis hesabıyla interaktif oturum 114
14.3 Vaka 2 — Zamanlanmış görevle kalıcılık 116
14.4 Vaka 3 — Yanal hareket, iki kez baştan 118
14.5 Üç vakadan çıkan dersler 120
14.6 Kapanış 121
Sigma Hızlı Referans 122
Alan Eşleme Tablosu 124
Kontrol Listeleri 125
C.1 Yeni bir kural yazmadan önce 125
C.2 Kural incelemesi 125
C.3 Yeni bir log kaynağı bağlarken 125
C.4 Emülasyon koşusu 126
C.5 Üç aylık bakım turu 126
Başlangıç Kural Seti 127
Terimler 128
Kaynaklar ve ileri okuma 130

BÖLÜM 01

Tespit Mühendisliği Nedir

Bu bölüm, kural yazmak ile bir tespiti işletmek arasındaki farkı ele alıyor. Tespitin çıktısını, sorumluluklarını ve kitabın izlediği sırayı buradan kuracağız.

1.1 Kural yazmak ile tespit üretmek

Bir mühendis aşağıdaki Sigma kuralını yazıp depoya gönderiyor. Kural okunaklı; WMI sağlayıcısından başlatılan kabukları seçiyor. İnceleme onaylanıyor, kural üretime çıkıyor ve bilet kapanıyor.

SIGMA — WMI SAĞLAYICISINDAN KABUK

```
title: WMI sağlayıcısından komut yorumlayıcısı başlatılması
id: 9d2f1c4a-3b77-4a51-9f0c-2e8b6d5a1c33
status: experimental
description: WmiPrvSE ebeveynli kabuk sürecini seçer; uzak bağlantıyı tek başına kanıtlamaz.
logsource: {category: process_creation, product: windows}
detection:
  selection:
    ParentImage|endswith: '\WmiPrvSE.exe'
    Image|endswith: ['\cmd.exe', '\powershell.exe']
  condition: selection
falsepositives: [Meşru yerel veya uzak WMI yönetimi]
level: high
tags: [attack.execution, attack.t1047]
x_rule_revision: dwell-1.1-wmi-r1
```

Kural dosyasının tamamlanması, tespitin teslim edildiği anlamına gelmiyor. Verinin geldiğini, mantığın hedef davranışı gördüğünü ve alarmın araştırılabildiğini de göstermemiz gerekiyor. Bu kitap, o işi başından bakımına kadar ele alıyor.

Kuralın iddiası sınırlı: bu ortamda WmiPrvSE.exe ebeveynli cmd.exe veya powershell.exe sürecini görürüz. Bu olay yerel WMI kullanımıyla da oluşabilir; tek başına uzak çalıştırma kanıtı değildir. ParentImage gerçekten doluyor mu, yerel ve uzak örnekler ayrı ayrı denendi mi, meşru yönetim işleri ne kadar eşleşiyor ve altı ay sonra kim yeniden kontrol edecek? Tespiti teslim etmek, bu soruları da yanıtlamaktır.

Kuralı yazmak bu işin bir adımıdır. Veriyi tanımak, test etmek, gereksiz alarmları azaltmak ve bakım yapmak da emek ister. Yazma işinin payını sabit bir yüzdeyle vermek yerine, ekibin kendi çalışma kaydından ölçmesini öneriyorum.



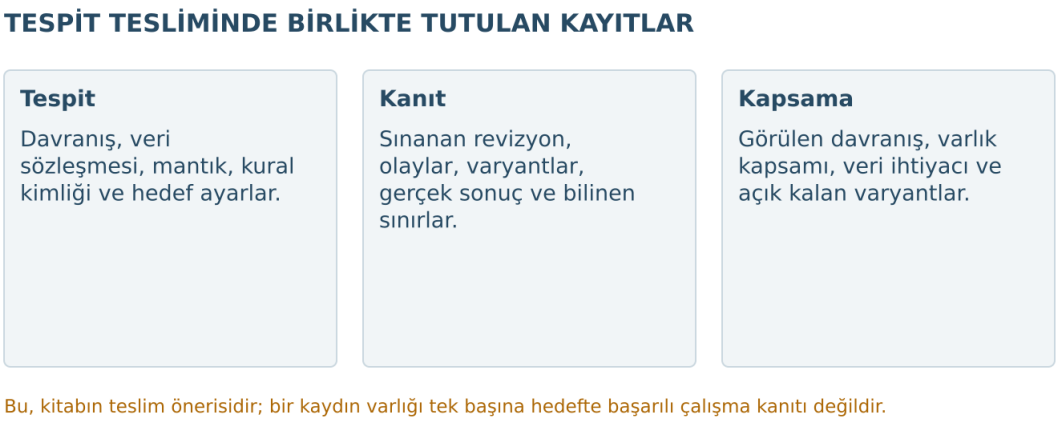
Şekil 1.1 Kural yazmak tek bir adımdır; tespit mühendisliği o adımın öncesini ve sonrasını da kapsar.

Şekil 1.1 iki yaklaşımı karşılaştırıyor. Üstte yalnız kural yazımı var; altta veriyi, testi ve bakımı da kapsayan yaşam döngüsü. Asıl ayrım, teslimatın nerede bittiğine dair sorumluluk tanımıdır.

1.2 Disiplinin üç çıktısı

> **TANIM — DETECTION ENGINEERING**
>
> Tehdit davranışlarını güvenilir biçimde yakalayan tespitleri tasarlama, yazma, test etme, ayarlama ve bakımını yapma disiplini. Kuralları yazılım gibi ele alır: sürümlenir, gözden geçirilir, test edilir, ölçülür ve gerektiğinde emekliye ayrılır.

Bu kitapta tespit mühendisliğinin teslimatını üç parçayla ele alıyorum: çalışan tespit, bakım bilgisi ve kapsama kaydı. Kuralın yanında bu bilgileri de bırakmak, sonraki kişinin neyi devraldığını anlamasını sağlar.



Şekil 1.2 Tespit teslimatının üç bileşeni: çalışan mantık, doğrulama kanıtı ve kapsam bilgisi.

Birincisi çalışan tespittir: belirli bir davranışı, tanımlanmış veri üzerinde, kabul koşulları sınanmış bir mantıkla yakalamak. Gürültü seviyesi ve araştırma yükü de bu kabulün parçasıdır.

İkincisi kanıt. Kontrollü testin veya doğrulanmış üretim olayının kaydıdır: hangi davranış, hangi veri ve kural revizyonuyla eşleşti; alarm ne zaman oluştu; ne eksik kaldı? Üretimde bir kez tetiklenme

değerli bir gözlemdir. Ham olay ve araştırma sonucu davranışı doğruluyorsa kanıt da olabilir. Yine de tek olay, bütün varyantların kapsandığını göstermez. Bölüm 7 ve 8 bu ayrımı işler.

Üçüncüsü kapsama bilgisidir: gördüğümüz varyantları ve bildiğimiz boşlukları birlikte yazmak. Örneğin T1055 için gereken telemetri yoksa bunu haritada açıkça göstermek gerekir. Böyle bir kayıt, veri toplama ve doğrulama için hangi işin yapılacağını anlatır.

> **SAHADAN NOT — KANIT NEYİ GÖSTERİYOR?**
>
> "En son kuralınızın çalıştığını nereden biliyorsunuz?" sorusunu sorun. Üretimde tetiklenme bir başlangıçtır; ham olay ve araştırma sonucu davranışı doğruluyorsa kanıt olabilir. Kontrollü test ise belirli varyantın belirli revizyonda görüldüğünü gösterir. İkisinde de tarih, kapsam ve kaydın bağlantısı gerekir. Bir başarılı olay, bütün tekniği doğrulamaz.

1.3 Neden ayrı bir uzmanlık hâline geldi

Kural yazma işi bazı ekiplerde SIEM yöneticisinin veya kıdemli analistin ek göreviydi. Bugün ayrı sorumluluk olarak ele alınmasını anlamak için dört gelişmeye bakabiliriz: telemetri çeşitliliği, ortak davranış sözlüğü, yazılım mühendisliği uygulamaları ve hazır içeriğin ortama uyarlanma ihtiyacı. Bu, mesleğin bütün kurumlarda aynı tarihte doğduğu iddiası değildir.

Telemetri çeşitlendikçe veri kaynaklarını, alanları ve toplama koşullarını ayrı ayrı bilmek gerekiyor. MITRE ATT&CK davranışları ortak adlarla tartışmayı kolaylaştırıyor. Git, kod incelemesi ve otomatik test ise değişiklikleri izlememizi sağlıyor. Hazır içerik de bu işin başlangıcı olabilir; ortamda nasıl davrandığı ayrıca ölçülmelidir.

Hazır içerik yararlı bir başlangıçtır; ancak kurumunuzdaki veri ayarını, eski uygulamayı veya servis hesabının işini kendiliğinden doğrulamaz. Kuralın hangi varsayımlarla yazıldığını okuyup yerel veriyle sınayın. Hazır ve kendi yazdığınız içerik için aynı kabul ölçütlerini kullanın.

Karşılaştırma	İncelemeden etkinleştirmek	Yerel kabulden geçirmek
Girdi	Hazır veya kendi yazılmış kural	Aynı içerik + veri ve test sözleşmesi
Ortama uyum	Varsayım olarak kalır	Alan, kapsam ve iş bağlamı sınanır
Doğrulama	Kuruma ait kanıt yoktur	Belirli revizyon/varyant için kanıt tutulur
Değişim	Etkisi bilinmeyebilir	Kaynak değişimi ve regresyon izlenir
Sahiplik	Belirtilmemiş olabilir	Bakım sorumlusu ve kabul kararı kaydedilir

> **HAZIR İÇERİĞİ KABUL ETMEK**
>
> Topluluk ve satıcı içeriğini başlangıç olarak kullanabilirsiniz. Veri gereksinimini ve mantığı okuyun; yerel pozitif, negatif ve atlatma örnekleriyle sınayın. Uygun hazır içerik bulunması, yeni kural yazmaktan önce değerlendirilecek bir seçenektir. Hazır içerik olması, yerel kabulün tamamlandığını göstermez.

1.4 Dört basamak

Kurumların bu işte nerede durduğunu anlatmak için uzun olgunluk modelleri var; pratikte dört basamak yeterli oluyor. Basamakları ayıran ölçüt, sorumluluğun nerede bittiğidir.



Şekil 1.3 Tespit olgunluğu için dört basamak; sorumluluk ve kanıt üzerinden kurulmuş çalışma modeli.

Birinci basamakta kural dosyası vardır; kendi yazdığımız veya hazır aldığımız içerik olabilir. Hedefte hangi davranışı gördüğü henüz kanıtlanmamıştır. İkinci basamakta kaynak, alan sözleşmesi ve hedeflenen varyantlar yazılır. Verinin gerçekten geldiği ve gerekli alanların doğru anlamı taşıdığı örnek kayıtlarla incelenir. Bu kayıt, uçtan uca doğrulamanın yerine geçmez.

Üçüncü basamakta aynı kural revizyonu için yürütme, ham olay ve alarm ilişkilendirilir. Hangi varyantın hangi koşullarda görüldüğü ve nelerin kapsam dışında kaldığı kaydedilir. Dördüncü basamakta bu kayıtlar düzenli bakımın parçasıdır: veri ve kural değişiklikleri izlenir, dışlamalar gözden geçirilir ve kanıt yenilenir. Sorumlu kişi ve yeniden test koşulları bellidir.

Bu dört basamağı bir çalışma modeli olarak kullanıyorum; bir sektör araştırmasının sonuçları olarak sunmuyorum. Hangi basamakta olduğunuzu unvanlar veya ürünler değil, tuttuğunuz kanıtlar ve üstlendiğiniz bakım sorumluluğu gösterir.

> **ÜÇ SORUYLA BAŞLAYIN**
>
> Son tespitin veri gereksinimi belgeli mi, çalıştığına dair kapsamı belli kanıt var mı, bakım sorumlusu belirli mi? Bu sorular konuşmayı somutlaştırır. Yanıtlar tek başına bir olgunluk puanı veya sabit sürede yapılmış tam değerlendirme değildir.

1.5 Kitabın haritası

Bu cilt dört kısım ve on dört bölümden oluşuyor. Sıra, veriden başlayıp yazmaya, doğrulamaya ve işletmeye ilerliyor.

Zemin (1–2) veriyi ve alan eşlemelerini; Yazmak (3–6) tespitin yapısını, kitapta kullanılan Sigma özelliklerini, mantık kalıplarını ve ATT&CK eşlemesini ele alıyor. Doğrulamak (7–9) test, emülasyon ve yanlış alarm yönetimine ayrıldı. İşletmek (10–14) ise depoyu, bakım işini, platformları, ekibi ve üç birleşik vakayı kapsıyor.

Ön koşul olarak bir SOC'un nasıl işlediğini bilmeniz yeterli. Bilmiyorsanız serinin ilk cildi (*DWELL Vol.01 · SOC*) o zemini kuruyor; ama bu cilt kendi başına da okunabilir. Beklediğim tek şey, elinizin altında bir yerde denemeye açık bir ortam olması. Bu kitaptaki hiçbir fikir, siz kendi ortamınızda bir kural yazıp onu çaldırana kadar gerçek anlamda öğrenilmiş sayılmaz.

Bir sonraki bölümde işin temeline iniyoruz: alanlar. Hangi veri kaynağı hangi alanı hangi adla veriyor, ortak şemalar bu kakofoniyi nasıl çözüyor ve bir alan eşlemesi sessizce bozulduğunda bunu nasıl fark ediyorsunuz.

BÖLÜM 02

Veri ve Alan Eşleme

> *Bir tespit, dayandığı alanlar kadar iyidir. Bu bölüm aynı kavramın kaynaktan kaynağa nasıl farklı adlar aldığını, ortak şemaların bunu nasıl çözdüğünü, Windows telemetrisinin hangi katmanlardan geldiğini, Sysmon yapılandırmasının nasıl tasarlandığını ve bir alan eşlemesi sessizce bozulduğunda bunu nasıl fark edeceğinizi ele alır.*

2.1 Tespit yazılabilir veri

Önce veriye bakıyoruz. Bir kuralın neden çalışmadığını anlamak için alanın adını bilmek yetmez; nasıl üretildiğini, hangi kayıtlarda dolduğunu ve ne anlama geldiğini de bilmek gerekir. Bu bölümün ayrıntılı olmasının nedeni bu.

Her log tespit yazılabilir sayılmaz. Bir olay kaydının kural yazımına elverişli olması için üç şart aranır.

Ayrıştırılmış olmalı. Kuralın kullandığı alanlar ayrı ayrı erişilebilir olmalı. Ham metin üzerinde tespit kurulabilir, fakat kaynak biçimine bağımlılığı ve arama maliyeti ayrıca değerlendirilir. Metin değiştiğinde arızanın görünür olması için örnek kayıtlarla regresyon testi gerekir.

Tutarlı olmalı. Aynı alan her kayıtta aynı adı, aynı biçimi ve aynı anlamı taşımalı. Aynı kaynaktan gelen kayıtların bir kısmında `user` alanı `DOMAIN\ali`, bir kısmında `ali@corp.local` biçimindeyse, o alana koşan her kural kayıtların yalnızca bir kısmıyla eşleşir ve bunu size kimse söylemez.

Yeterli ayrıntıyı taşımalı. Windows 4688 komut satırı olmadan da süreç adı, kimlik ve olay sürümüne bağlı ebeveyn bilgisi sağlar. Ancak -EncodedCommand arayan bir kural, komut satırı kaydı yoksa bu kaynaktan çalışamaz. Yeterlilik veri kaynağının genel özelliği değil, belirli tespitin ihtiyacıdır.

> **DİKKAT — "LOG VAR" İLE "VERİ VAR" AYNI ŞEY DEĞİLDİR**
>
> Bir kaynağın SIEM'e aktığını görmek, o kaynaktan tespit üretilebileceği anlamına gelmez. Kaynak listesinde yeşil görünen pek çok log, kural yazımı için gereken alanı hiç taşımaz ya da tek bir metin alanına sıkışmış hâlde gelir. Bir veri kaynağını "var" saymadan önce şunu sorun: son yazdığım kuralın koştuğu alanlar bu kayıtta ayrı ayrı erişilebilir mi, ve kayıtların yüzde kaçında dolu?

2.2 Aynı kavramın farklı adları

Kaynak adresinin alan adı, veri kaynağına göre değişir: Sysmon ağ bağlantısı olayında SourceIp, Zeek conn.log içinde id.orig_h, Splunk CIM Network Traffic veri modelinde src_ip, ECS'te source.ip, OCSF ağ olaylarında src_endpoint.ip kullanılır. AWS CloudTrail'de sourceIPAddress alanı ise bir ağ akışının kaynak adresi değil, API isteğinin gözlenen kaynağıdır; değeri her zaman bir IP adresi olmayabilir. Şekil 2.1 bu alan adlarını yan yana gösterir; aynı olay türünü veya aynı anlamı garanti etmez.



Şekil 2.1 Benzer kaynak adresi alanları. CloudTrail API isteği bağlamı, ağ bağlantısı bağlamıyla otomatik olarak eşdeğer değildir.

Bu yalnızca bir isimlendirme sıkıntısı olsaydı katlanılırdı. Sorun şu ki fark isimde bitmiyor. Bir alanı eşlerken beş boyutun hepsi eşlenmelidir: **ad**, **tip**, **biçim**, **anlam ve zaman**. Sahada gördüğüm sessiz hataların çoğu, ad eşleşmesinin doğru ama anlam eşleşmesinin yanlış olduğu yerlerden çıktı.

Tip. Kaynak IP bir şemada metin, başka bir indekste özel IP türüyle tutulabilir; CloudTrail sourceIPAddress gibi bazı alanlar IP olmayan değerler de içerebilir. Bunun sorguya etkisi hedefe bağlıdır: Splunk cidrmatch metin IP kabul eder; Elasticsearch'te IP alan türü CIDR sorgusu için önemlidir. Sayı gibi görünen metinlerde de açık dönüştürme veya doğru indeks türü gerekir. Veri sözleşmesine türü ve kullanılacak işleci birlikte yazın.

Biçim. Kullanıcı DOMAIN\kullanıcı veya kullanıcı@domain.tld; dosya yolu C:\Windows\... veya \Device\HarddiskVolume2\Windows\... biçiminde gelebilir. Ortak bir sonek iki biçimde de eşleşebilir, fakat tam yol veya önek koşulları aynı sonucu vermez. IPv6 köşeli parantezleri, harf biçimi ve yol ayracı da normalleştirme sözleşmesinde ele alınmalıdır.

Anlam. NAT öncesi ve sonrası adresler aynı alan adına eşlenebilir; fakat aynı ağ konumunu anlatmaz. Korelasyon bu farkı kaybederse farklı varlıkları birleştirebilir. Alan adının yanında adresin nerede gözlendiğini de sözleşmeye yazın.

Zaman. Olayın gerçekleşmesi, ajanın kaydı okuması, ara sistemde işlenmesi ve merkezî depoya ulaşması farklı anlardır. ECS'te @timestamp, event.created ve event.ingested bu ayrımı taşır. OCSF'de time olay zamanıdır; metadata.processed_time ara işlemeyi, sürümde mevcutsa metadata.logged_time son varışı gösterir. Gecikmeyi hesaplarken hangi iki zamanı çıkardığınızı açıkça belirtin.

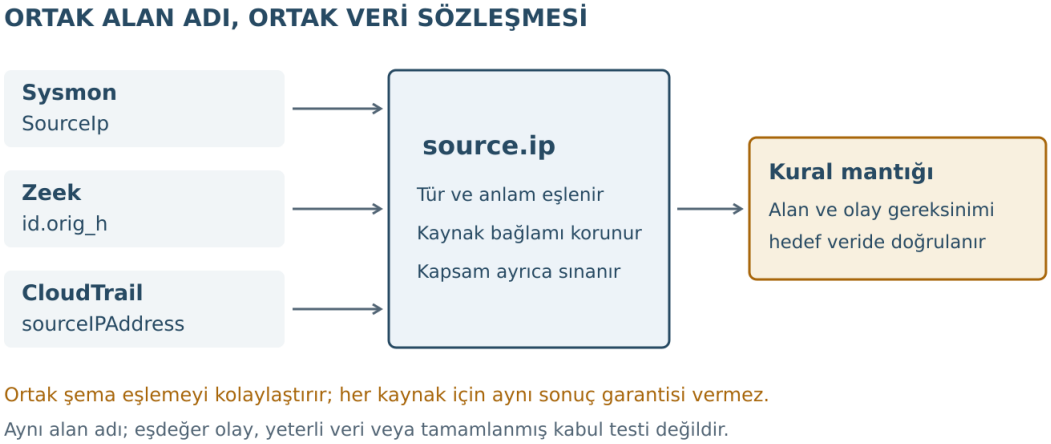
Saat ofseti ve saat senkronizasyonunu da sözleşmeye ekleyin. Bir zaman alanının var olması doğru saati taşıdığını garanti etmez. Olay zamanı ile merkezî varış arasındaki fark, aynı olay kimliği üzerinden ölçülmelidir.

ALAN SÖZLÜĞÜ İLE HAM KAYDI BİRLİKTE OKUYUN

Doküman alanın beklenen anlamını, ham kayıt kurulu kaynakta gelen değeri gösterir. İkisini aynı kaynak sürümü ve ayarla karşılaştırın. Normal olay kadar eksik alan, null, boş değer ve farklı olay sürümünü de örnekleyin. Birkaç kayıt bütün olasılıkları kapsamaz; anlam ve tür farkını veri sözleşmesine işleyin.

2.3 Ortak şemalar: ECS, OCSF, CIM

Ortak şema, farklı kaynakları aynı sözlükle ele almamızı sağlar. Kaynak değiştiğinde eşleme güncellenir. Alanın türü ve anlamı korunuyorsa kural mantığı değişmeden kalabilir; olay kapsamı veya anlam değişmişse kuralı da yeniden incelemek gerekir.



Şekil 2.2 Kaynak alanları ortak şemaya eşlenir; kuralın ihtiyaç duyduğu anlam ve olay kapsamı her kaynakta ayrıca doğrulanır.

Bu kitapta üç ortak şemayı karşılaştırıyorum: ECS, OCSF ve Splunk CIM. ECS alan adlarını, OCSF olay sınıflarını ve nesnelerini, CIM ise Splunk veri modellerini tanımlar. Bir şemadaki adın diğerinde benzemesi, alanların aynı anlamı taşıdığını garanti etmez.

Kavram	ECS	OCSF şema kaydı	Splunk CIM 6.4
Kaynak IP	source.ip	src_endpoint.ip	src_ip
Hedef port	destination.port	dst_endpoint.port	dest_port
Süreç yolu	process.executable	process.file.path	process_path
Komut satırı	process.command_line	process.cmd_line	process
Gerçek ebeveyn yolu	process.parent.executable	process.parent_process.file.path	parent_process_path
Oluşturan aktör	Kaynağa bağlı	actor.process; ebeveynle aynı varsayılmaz	Kaynağa bağlı
Kullanıcı	user.name	actor.user.name	user
Süreç dosyası SHA256	process.hash.sha256	process.file.hashes; SHA-256 seçilir	process_hash; doğrudan süreç SHA-256 eşdeğeri değildir (bağlam ve algoritma doğrulanmalı)
Olay zamanı	@timestamp	time; UTC epoch ms	_time

Alan adının bir şema dokümanında tanımlı olması, ham olayda kendiliğinden o adla bulunduğu anlamına gelmez. Splunk CIM veri modelleri için veri normalizasyonu/alan çıkarımı, Elastic ECS için ingest eşlemesi, OCSF için olay sınıfı ve sürüm uyumu gerekir. Her eşlemeyi gerçek bir örnek olay üzerinden kontrol edin.
Şema seçerken ürününüzün desteğine, kullandığınız içeriklerin varsayımlarına ve taşıma ihtiyacınıza bakın. Bazı ortamlar birden fazla şemaya dönüşüm gerektirir. Esas olan, kaynak alan ile hedef anlam arasındaki sözleşmenin yazılı ve test edilmiş olmasıdır.

Kurumun kendi şeması da bir seçenek olabilir; ancak sözlüğü, sahibi ve dönüşüm kuralları belli olmalıdır. Mevcut şemaya kuruma özgü alan ekliyorsanız adlandırmayı ve anlamı açıkça belgeleyin. Kişilerin hafızasında duran eşleme, ekip değişince sürdürülemez.

ŞEMA GEÇİŞİNDE ESKİ KAYITLARI DA TEST EDİN

Kaynak veya pipeline değişikliği geçmiş kayıtlara kendiliğinden uygulanmıyorsa eski ve yeni alanlar farklı kalır. Geçişte geçmiş verinin nasıl aranacağını ve saklama süresini planlayın. İki dönemi kapsayan eşlemeyi seçilmiş eski ve yeni olaylarla sınayın. Yeniden işleme veya dönüşüm kararı ürüne ve yerel veri sözleşmesine bağlıdır.

2.4 Eşlemeyi kodla yönetmek

Eşlemeyi belgelemek yetmez; çalıştırılabilir hâle getirmek gerekir. Sigma tarafında bu iş bir *pipeline* ile yapılır. Kural jenerik alan adlarıyla yazılır, pipeline onu hedef ortamın alan adlarına çevirir. Böylece kural ile ortam arasındaki bağ tek bir dosyada toplanır.

PIPELINE — SYSMON SÜREÇ OLAYINDAN ECS'E

```
name: dwell-sysmon-to-ecs
priority: 10
transformations:
  - id: field-map
    type: field_name_mapping
    mapping:
      Image: process.executable
      CommandLine: process.command_line
      ParentImage: process.parent.executable
      ParentCommandLine: process.parent.command_line
      User: user.name
      Computer: host.name
      EventID: event.code
  - id: process-event
    type: add_condition
    conditions:
      event.dataset: windows.sysmon_operational
      event.code: '1'
    rule_conditions:
      - type: logsource
        category: process_creation
  - id: unknown-field
    type: detection_item_failure
    message: Bu alan DWELL süreç oluşturma sözleşmesinde eşlenmemiş
    rule_conditions:
      - type: logsource
        category: process_creation
    field_name_conditions:
      - type: exclude_fields
```

PIPELINE — SYSMON SÜREÇ OLAYINDAN ECS'E

```
fields: [process.executable, process.command_line, process.parent.executable,
        process.parent.command_line, user.name, host.name, event.dataset, event.code]
```

Son dönüşüm, bu pipeline'ın desteklemediği alanı gördüğünde derlemeyi durdurur. İzin listesinde pipeline'ın eklediği event.dataset ve event.code da yer alır. Bu kontrol alan adının sözleşmeye uyduğunu gösterir; gerçek kayıtta dolduğunu kanıtlamaz. Dataset ve olay kodu, kurulu entegrasyondan alınmış örnekle doğrulanmalıdır.

Alan eşlemesini pipeline'da tutmak, ad değişikliklerini merkezi olarak yönetmeyi kolaylaştırır. Değişikliğin türü veya anlamı da etkilediği durumlarda kurallar yeniden incelenir. Pipeline, kurallarla birlikte sürümlenir ve hedefte örnek kayıtlarla sınanır.

2.5 Windows: denetim politikası ve kanallar

Bu bölümde Windows telemetrisinin üç önemli kaynağını ele alıyorum: Security günlüğü, Sysmon ve PowerShell günlükleri. Kapsamları ve etkinleştirme ayarları farklıdır. Bunlar Windows'un bütün telemetri kaynakları değildir; hangi davranış için hangisine ihtiyaç duyduğumuzu veri sözleşmesi belirler.



Şekil 2.3 Seçilmiş Windows telemetri kaynakları; PowerShell kanalı sürüme göre değişir.

Denetim politikası ve Security kanalı. Oturum (4624/4625), süreç oluşturma (4688) ve görev oluşturma (4698) gibi olaylar buradan gelir. 4688 için Audit Process Creation; komut satırı için ayrıca Include command line in process creation events gerekir. İkisini ayrı kontrol edin. Komut satırı boşsa bu alana dayanan kural çalışmaz; olayın diğer alanları yine kullanılabilir.

4698 için Audit Other Object Access Events alt kategorisinin Success kaydı gerekir. Olaydaki TaskContent XML, süreç oluşturma alanlarıyla aynı şema değildir; Bölüm 14.3'te ayrı kural olarak ele alınır.

PowerShell günlüğü ayrı yapılandırılır. Script block logging etkinse 4104, işlenen betik bloğunun içeriğini kaydeder; bu kayıt bütün komutların başarıyla yürütüldüğünü kanıtlamaz. Windows PowerShell 5.1'in kanalı Microsoft-Windows-PowerShell/Operational, PowerShell 7'nin kanalı PowerShellCore/Operational'dır. PowerShell 7 olay sağlayıcısının kaydı da kontrol edilir. Modül günlüğünün kapsamı, seçilen modüllere ve ayara bağlıdır.

Sysmon. Microsoft'un Sysinternals ailesinden gelen ek bir ajandır; işletim sistemiyle birlikte gelmez, ayrıca kurulur ve mutlaka yapılandırılır. Bir sonraki alt bölümün tamamı buna ayrıldı.

4688 ve Sysmon EID 1 süreç oluşturmayı farklı alanlarla gösterebilir. Sysmon yapılandırmaya bağlı dosya hash'leri, ebeveyn komut satırı ve bütünlük düzeyi ekler. İmza durumu EID 1'in alanı değildir. İki kaynak da toplanıyorsa öncelik ve yedek kaynak davranışı kuralın veri sözleşmesinde yazılmalıdır.

> **ÖRNEK — AYNI DAVRANIŞ, ÜÇ FARKLI KAYIT**
>
> Office uygulaması doğrudan kodlanmış PowerShell başlatıyor. Security 4688, yapılandırma ve olay sürümüne göre süreç, kimlik, ebeveyn ve komut satırı bilgisi verir. Sysmon EID 1 ebeveyn komut satırı, bütünlük düzeyi ve yapılandırılan hash'leri ekleyebilir; imza durumunu taşımaz. İmza için EID 6/7 veya doğrulanmış dosya zenginleştirmesi gerekir. PowerShell 4104 ise etkinse işlenen betik bloğunu gösterir. Bunların hiçbiri tek başına kötü niyeti kanıtlamaz.

2.6 Sysmon yapılandırmasını tasarlamak

Sysmon'da hacim, etkin olay türlerine, filtrelere ve iş yüküne bağlıdır. Yapılandırmayı pilot bir grupta ölçerek tasarlayın. Bir olay türünün tespit değeri yüksek olabilir; bunun düşük hacim üreteceğini ayrıca varsaymayın.



Şekil 2.4 Sysmon olay türlerini seçerken sorulacak sorular. Hacim sıralaması veya saha ölçümü değildir.

EID 8 ve EID 10 değerli bağlam sağlayabilir; özellikle EID 10 bazı iş yüklerinde çok sayıda olay üretir. Hedef süreçleri, erişim maskelerini ve meşru uygulamaları pilotta ölçün. DNS (22), registry (13) ve image load (7) için de aynı yöntem geçerlidir: ihtiyaç, gerçek hacim ve filtrelemenin kaybettireceği görünürlük birlikte değerlendirilir.

Sysmon olay filtresinde onmatch, ilgili olay türünde koşula uyan kaydın dahil mi yoksa hariç mi tutulacağını belirler. RuleGroup'un groupRelation ayarı ise koşulların nasıl birleştirileceğini anlatır. Bu iki ayarı birbirine karıştırmayın.



Şekil 2.5 Seçilmiş olay türü için Sysmon include ve exclude koşulları.

Sysmon dışlaması kaynağın ürettiği olayları azaltır; dışlanan kayıt bu kaynaktan SIEM'e gitmez. Başka telemetri aynı davranışı gösterebilir, ancak hiç tutulmamış kaydı sonradan geri getiremeyiz. Dışlamanın kaybettirdiği olayları bu yüzden kaynakta da test edin.

SYSMON — EVENTFILTERING İÇİNE EKLENEN PARÇA

```
<!-- Yol ve alan adı AYNI olayda birlikte eşleşmeli. -->
<!-- Dosya imzası bu koşullarla doğrulanmaz. -->
<RuleGroup name="dwell-dns" groupRelation="and">
  <DnsQuery onmatch="exclude">
    <Rule name="approved-agent-corp-dns" groupRelation="and">
      <QueryName condition="end with">.corp.local</QueryName>
      <Image condition="is">C:\Program Files\Guncelleyici\agent.exe</Image>
    </Rule>
  </DnsQuery>
</RuleGroup>
<!-- Agent/dış alan ve başka süreç/iç alan dışlanmamalı. -->
<!-- HashAlgorithms, EventFiltering dışında yapılandırılır. -->
<!-- SearchIndexer ebeveynini topluca dışlamak burada önerilmez. -->
```

Tam yol koşulu, yalnız dosya adını eşleştirmekten daha dardır. Bununla birlikte yol, dosya imzasını veya dizinin yazma izinlerini doğrulamaz. "İmzalı dizin" diye bir güven özelliği yoktur. Ajanın dosyası, dizin ACL'si ve süreç kökeni ayrı incelenmelidir; doğru yol metni saldırgan komutuna da eklenebilir.

SwiftOnSecurity sysmon-config ve Olaf Hartong sysmon-modular başlangıç için incelenebilir. Hazır yapılandırmanın olay kapsamını ve dışlamalarını okuyun; kendi tespit gereksinimlerinizle karşılaştırın. Modül veya ATT&CK etiketi, davranışın ortamınızda doğrulandığını tek başına göstermez.

SAHADAN NOT — YAPILANDIRMAYI DA SÜRÜMLEYİN

Sysmon yapılandırması bir kural kadar canlı bir varlıktır ve tam olarak kurallar gibi yönetilmelidir: depoda tutulur, değişiklikleri gözden geçirilir, dağıtımı kayıt altına alınır. Bir tespitin neden çalmadığını araştırırken karşılaştığım en can sıkıcı cevaplardan biri, birinin aylar önce hacmi düşürmek için yapılandırmaya bir dışlama eklemiş ve kimseye söylememiş olmasıydı.

Pratik bir önlem: yapılandırmanın sürüm numarasını ajanın raporladığı bir alana yazın. Böylece hangi makinenin hangi sürümle çalıştığını sorguyla görebilirsiniz — "dağıttık" ile "dağıtıldı" arasındaki farkı ancak böyle kapatırsınız.

2.7 Linux ve konteyner

Linux'ta auditd, sistem çağrılarını ve ilgili kayıtları toplar. execve/execveat üzerinden süreç başlatma izlenebilir; SYSCALL, EXECVE ve PATH gibi parçalar aynı audit olay kimliğiyle birleştirilmelidir. Hacmi ve kayıp olay göstergelerini kendi iş yükünüzde ölçün.

AUDITD — İKİ ALTERNATİF; BİRLİKTE EKLEMEYİN

```
# A: bütün 64-bit exec olayları (iş yükünde ölçün)
-a always,exit -F arch=b64 -S execve,execveat -k proc_exec

# B: A YERİNE yalnız normal kullanıcı oturumları
# UID_MIN=1000 varsayımı; ayrıcalık filtresi değildir.
# -a always,exit -F arch=b64 -S execve,execveat -F auid>=1000 -F auid!=unset -k user_exec

# Gerekirse desteklenen b32 çağrıları için ayrı kural eklenir.
# A ve B birlikte kullanılırsa B, A'nın hacmini daraltmaz.
-w /etc/passwd  -p wa -k identity
-w /etc/shadow  -p wa -k identity
-w /etc/sudoers -p wa -k priv_change
# Mevcut olmayan path'e watch eklemeyin.
# Kalıcı dosyayı yükleyin; auditctl -l ve örnek olayla doğrulayın.
```

Örnekte geniş execve kuralına sonradan dar bir kural eklenmiyor. İki alternatiften biri seçiliyor. auid>=1000 örneği normal kullanıcı oturumlarına odaklanır; ayrıcalık filtresi değildir. UID_MIN sisteminize göre değişebilir. sudo sonrası auid ilk oturumu, euid etkin yetkiyi anlatır. Servis ve root faaliyetini dışarıda bırakmanın kapsam kaybını ayrıca kaydedin.

eBPF tabanlı toplama da bir seçenektir. Ajan, çekirdek ve yapılandırma birlikte değerlendirilir; auditd'den her koşulda daha hızlı veya daha zengin olduğu söylenemez. Konteyner tespitinde host olayıyla container.id gibi bağlamın ilişkilendirilmesi gerekir.

Kubernetes audit kaydı, API sunucusunda uygun denetim politikası etkinse üretilir. None düzeyi kayıt üretmez; politika verilmemesi de görünürlüğü etkiler. Hangi verb, resource ve stage'in tutulduğunu kontrol edin. Pod exec ve konteyner runtime olayları ayrı kapsamları gösterir; süreç kaydındaki konteyner kimliği de eşlenmelidir.

Minimum Kubernetes audit örneğinde audit-policy-file etkin olmalı; Metadata düzeyinde pods/exec gibi hedef resource/verb kapsamı seçilmelidir. Audit kaydının oluşmamasını da test edin. Hassas request/response gövdelerini ihtiyaç olmadan geniş kapsamda tutmayın.

2.8 Ağ ve bulut

Zeek conn.log, dns.log, ssl.log ve http.log gibi yapılandırılmış ağ kayıtları üretebilir. Görünürlük sensörün konumuna ve çözümlenen protokole bağlıdır. Alanları, zamanları ve eksik kayıt davranışını bu kaynaklar için de sözleşmeye bağlayın.

TLS kaydında SNI ve sertifika bilgisi gibi bağlam bulunabilir. JA3 ve JA4, temel ssl.log'da kendiliğinden var sayılmamalıdır; ilgili paketin kurulumu, sürümü ve ürettiği alan doğrulanır. Parmak izi bir davranış göstergesidir, tek başına kötü niyet kanıtı değildir.

JA3/JA4 kullanılacaksa packages.zeek.org üzerindeki ilgili paket adı ve sürümü sözleşmeye yazılır; kurulumdan sonra gerçek ssl.log örneğiyle alanın oluştuğu sınanır. Bu kitap kurulu bir parmak izi paketini varsaymıyor.

CloudTrail, Entra ID ve Kubernetes audit kayıtlarında yapılandırılmış alanlar bulunur. Kurulu hizmetin olay kapsamı ve toplama ayarları yine kontrol edilir. Biçimin yanında üç konuya bakıyoruz.

Bulut olaylarında gerçekleşme zamanı ile toplayıcıya ulaşma zamanını ayırın. Geç gelen olaylar için hedef motorun arama geçmişini ve geç veri kabulünü düzenleyin; davranışın zaman koşulunu sırf gecikmeyi karşılamak için değiştirmeyin. Kimlik eşlemesinde kullanıcı, rol ve servis kimliğini ayırın. Bölge kapsamı hizmete özgüdür: CloudTrail'in tek bölgeli izi o bölgeyi, çok bölgeli izi etkinleştirilmiş bölgeleri kapsar. Diğer kaynakların toplama modelini kendi belgesinden ve ayarından kontrol edin.

> **BULUTTA KİMLİK KAPSAMINI AÇIK YAZIN**
>
> Önceliklendirmeye ayrıcalıklı kimliklerin eylemlerinden başlamak yararlı olabilir. Kullanıcı, uygulama ve üstlenilmiş rolün kayıtta nasıl temsil edildiğini inceleyin. Bu öneri, bulut saldırılarının çoğunluğu hakkında ölçülmüş bir oran değildir; kaynak kapsamını ve kurumun tehdit profilini birlikte değerlendirin.

2.9 Veri sözleşmesi

Buraya kadarki her şey kafada tutulabilir; sorun şu ki kafada tutulan bilgi devredilemez ve denetlenemez. Olgun ekipler bu yüzden eşlemeyi yazılı hâle getirir.

> **TANIM — VERİ SÖZLEŞMESİ**
>
> Bir log kaynağı ile o kaynağa dayanan tespitler arasındaki yazılı mutabakat: hangi alanların, hangi tür ve anlamla sağlandığı; beklenen hacim; değişiklik bildirimi ve sorumlular. Sözleşme kuralların yanında durur; kaynak değiştiğinde bağımlı kurallarla birlikte gözden geçirilir.

Veri sözleşmesi, kaynak değiştiğinde hangi kuralların gözden geçirileceğini bulmayı kolaylaştırır. Bunun için alan bağımlılıkları, sürüm ve sorumlular güncel olmalıdır. Etkilenen kuralları kayıttan çıkarın ve örnek olaylarla sınayın. Kazanılan süreyi kendi değişiklik kayıtlarınızdan ölçün.

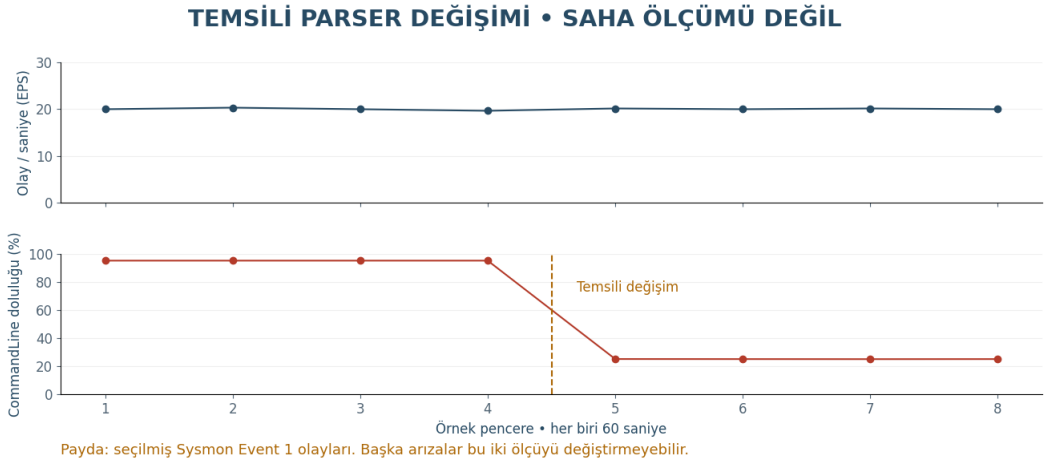
> **ÖRNEK — VERİ SÖZLEŞMESİ**
>
> Kaynak sürümü, olay türü, taşıyıcı ve alan şeması birlikte kaydedilir. process.command_line ham komut; process.parent.executable gerçek ebeveynin tam yolu; @timestamp olay, event.created ajan okuması, event.ingested merkezî varış zamanıdır. Beklenen EPS aralığı ve doluluk eşiği pilot ölçümünden çıkarılır; bu kitap evrensel değer vermez. Bağlı tespit kimlikleri, sahip ve değişiklik bildirim süreci sözleşmede yer alır.

Sözleşmeyi kural deposunda sürümleyin. YAML veya JSON, sorguların alan ve kaynak gereksinimlerini aynı kayıttan kontrol etmeye yardımcı olabilir. Sonraki örnek sorguları bu sözleşmeye göre uyarlayın; sözleşmeden otomatik sorgu üretimi için ayrı bir araç gerekir.

2.10 Sessiz bozulmayı yakalamak

Bir tespit gürültülü veya sessiz biçimde bozulabilir. Yanlış alarm genellikle fark edilir. Kaybolan alan, değişen anlam veya eksilen kaynak ise hiç alarm üretmeyebilir. İkisinin maliyetini kendi ortamınızda ölçmeden hangisinin daha yaygın olduğunu söylemek doğru olmaz.

Kaynağın olay gönderdiğini ve hacmini izlemek yararlıdır. Ayrıştırma veya alan anlamı değiştiğinde hacim aynı kalabilir. Bu yüzden alan doluluğu, örnek ham kayıt ve tespit replay'i hacim kontrolünü tamamlar.



Şekil 2.6 Temsili bir dakikalık pencerelerde EPS ve seçilmiş olayların CommandLine doluluğu.

Hacim izlemesine alan doluluğunu ekleyin. Payda, kuralın baktığı olay türü olmalı; Sysmon EID 1 komut satırını bütün Sysmon olaylarına bölmeyin. Null ve boş metni aynı kuralla ele alın. Hiç olay üretmeyen makineler bu sorguda görünmez; onları varlık envanteriyle karşılaştırın.

DOLULUK — AYNI OLAY TÜRÜ VE AYNI BOŞLUK POLİTİKASI

```
# SPL; sourcetype ve EventCode alanı yerel sözleşmedir.
index=win sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational"
  EventCode=1 earliest=-24h
| eval dolu=if(isnotnull(CommandLine) AND CommandLine!="",1,0)
| stats count AS toplam sum(dolu) AS dolu_sayi BY host
| eval oran=round(100*dolu_sayi/toplam,1)
| where oran < 90

# ES|QL; eşleşen EID 1 ve dataset esas alınır.
FROM logs-windows.sysmon_operational-*
| WHERE event.code == "1"
| EVAL dolu = CASE(process.command_line IS NOT NULL
                AND process.command_line != "", 1, 0)
| STATS toplam=COUNT(*), dolu_sayi=SUM(dolu) BY host.name
| EVAL oran=ROUND(100.0*dolu_sayi/toplam,1)
| WHERE oran < 90
# %90 örnek uyarı eşiğidir. Sıfır olaylı host, envanterden bulunur.
```

Sorgunun `BY host` kısmı önemlidir. Toplam oranı izlemek, sorunun bir makine grubunda başladığı ve yayıldığı durumu geç yakalar; makine bazında bakmak, yeni dağıtılan bir yapılandırmanın hangi grupta bozulduğunu doğrudan gösterir.

Ölçülecek alan seçimi de önemlidir. Her alanı izlemek gereksiz; izlenmesi gereken, üzerine tespit yazılmış olanlardır. Veri sözleşmesi burada ikinci kez işe yarar: sözleşmede sağlanan alan olarak listelenen her alan, doluluk izlemesinin de kapsamına girer. Böylece izleme listesi elle bakılan bir dosya olmaktan çıkıp sözleşmeden türeyen bir çıktı hâline gelir.

Tablodaki yüzdeler ve süreler temsili başlangıç koşullarıdır; ürün varsayılanı veya evrensel eşik değildir. Kaynağın dönemsel dağılımına göre ayarlayıp kesinti ve yanlış uyarı örnekleriyle sınayın.

Gösterge	Araştırılacak durum	Örnek uyarı koşulu
Hacim (EPS)	Kaynak kesilmesi veya hacim değişimi	Referans bandın %40 altı
Alan doluluğu	Parser veya olay kapsamı değişimi	Referansın 10 puan altı
Ayrı değer sayısı	Sabitlenme veya kesilme	Beklenen dağılıma göre ani düşüş
Alan uzunluğu	Olası kırpılma	Uzunluk dağılımında beklenmeyen düşüş
Zaman sapması	Saat kayması veya toplama gecikmesi	5 dakikadan büyük fark
Gönderen varlık	Ajan veya envanter uyumsuzluğu	Referansın %10 altı
Yeni alan	Olası kaynak sürümü değişimi	Bilgi amaçlı inceleme

Komut satırı bir uzunluk sınırında kesiliyorsa, boş olmadığı için doluluk oranı bunu göstermeyebilir. Ortalama ve yüzdelikler, belli bir uzunlukta yığılmaya işaret edebilir; aynı uzunluktaki içerik değişimini kanıtlamaz. Kaynaktaki ham kayıtla alınan değeri karşılaştırın ve kendi sınır değerlerinizde test olayları kullanın.

SAHADAN NOT — REFERANSI ÖNCEDEN AL

Doluluk oranını izlemenin işe yaraması için bir referans değere ihtiyacınız var, ve o referansı her şey yolundayken almanız gerekiyor. Yeni bir kaynak bağladığınız hafta kritik alanların doluluk oranını ölçüp sözleşmeye yazın. Aylar sonra bir şey bozulduğunda, oranın düşük olup olmadığını ancak bu sayı sayesinde bilebilirsiniz. Referansı olmayan bir ölçüm size bir sayı verir; referansı olan bir ölçüm bir karar verir.

2.11 Kapsama envanteri

Bölümü, Bölüm 1'de disiplinin üçüncü çıktısı olarak saydığımız şeye bağlayarak kapatalım: neyi görmediğinizin dürüst dökümü. Kapsama envanteri bu dökümün veri tarafıdır ve üç katmanlı bir sorudur.



Şekil 2.7 Temsili varlık envanteri; bütün oranların paydası 1.000 varlıktır.

Varlık kapsaması için envanterdeki makineleri olay gönderen kaynaklarla karşılaştırın. Ajanı olmayan sunucu, görünmeyen alt ağ ve yalnız yerel diske kayıt yazan uygulama bu karşılaştırmada araştırılacak örneklerdir. Bunları bütün kurumlarda görülen ölçülmüş bulgular olarak sunmuyorum.

İkinci katman olay türü kapsamasıdır: o makinelerden hangi olay türleri geliyor? Bir sunucunun log göndermesi, Sysmon'un orada kurulu olduğu ya da denetim politikasının doğru ayarlandığı anlamına gelmez. Windows sunucularınız kapsam içinde olabilir ama Sysmon yalnızca birkaçında kurulu olabilir; DNS logları gelebilir ama yalnızca başarısız sorgular için.

Üçüncü katman alan kapsamasıdır: o olaylarda gereken alanlar gerçekten dolu mu? Bu, 2.10'daki doluluk ölçümünün kapsama tablosuna bağlandığı yerdir. 4688 toplanıyor olabilir ama komut satırı politikası yalnızca bir OU'da açık olabilir.

Şekil 2.7'deki sayılar öğretim amaçlıdır. Önemli ayrım şudur: "Windows'tan log geliyor" ile "komut satırına dayanan bu kural bütün Windows varlıklarında çalışabilir" aynı kapsam değildir. Payda, olay türü ve alan yeterliliği ayrı yazılmalıdır.

ATT&CK'in veri modelini sürümüyle birlikte kullanın. Eski Data Sources modeli v18 ile kullanımdan kaldırıldı. Bu baskıda referans v19.2'dir; Detection Strategies, Analytics ve bunların veri bileşenleri incelenir. Bir analitiğin gereksinimini envantere çevirmek yine mühendislik işidir; teknik etiketi, alanların ortamınızda var olduğunu göstermez.

Teknik sürümü değişince taktik adları ve eşlemeler de gözden geçirilir. Kaynak paketindeki v19.2 teknik envanteri, yazılı kimliğin varlığını kontrol eder; etiketin kural davranışına uygunluğunu insan incelemesi belirler.

> **VERİ YOKSA KABUL SINIRINI GÖSTERİN**
>
> Veri sözleşmesi veya sentetik olaylarla bir mantık prototipi hazırlanabilir. Gerçek telemetri olmadan üretimde çalıştığı söylenemez. Toplama, ayrıştırma ve tespit ekipleri gerekli kaynağı birlikte kurup sınamalıdır; tamamlanma süresi ortama bağlıdır.

Veri, şema, eşleme ve sözleşme birbirine bağlandı. Bir sonraki bölümde bunları kullanan tespitin yapısına bakacağız: mantık, bağlam, yanıt ve kapsam.

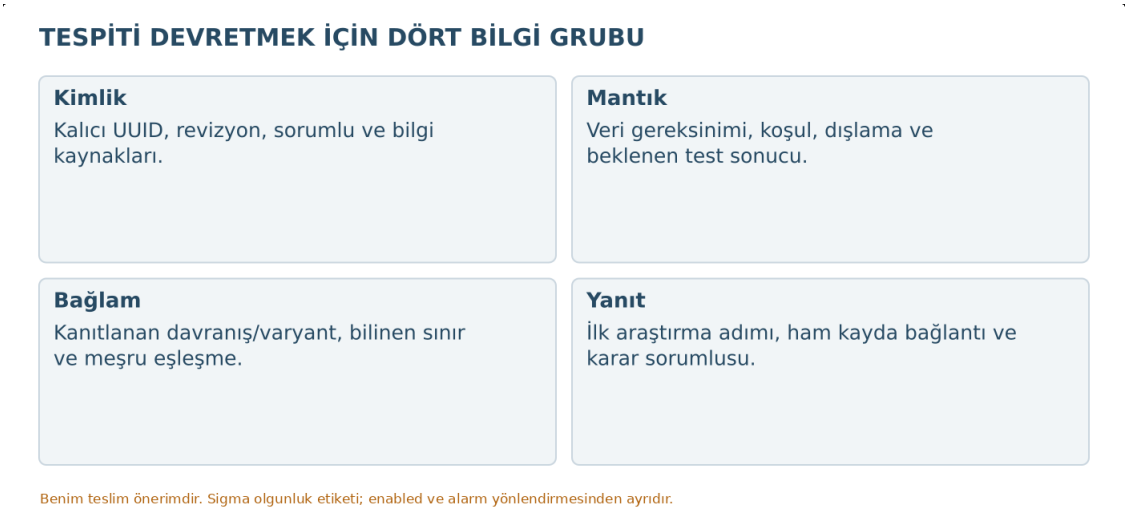
BÖLÜM 03

İyi Bir Tespitin Anatomisi

Bu bölüm bir tespitin parçalarını, isabet ve kapsama ölçülerini, kullandığım tespit türlerini ve bir fikrin hangi iş akışına uygun olduğunu ele alıyor.

3.1 Bir tespitin dört parçası

Bir tespiti devrederken kimliği, mantığı, bağlamı ve yanıtı birlikte yazmayı öneriyorum. Veri gereksinimleri ve davranış kapsamı da bu parçalarda açıklanır. Böylece sonraki kişi kuralın ne için çalıştığını ve bir alarmda ne yapacağını anlayabilir.



Şekil 3.1 Tespiti devretmek için önerdiğim dört bilgi grubu.

Kimlik, kuralı bir varlık hâline getirir: kalıcı bir kimlik numarası, okunabilir bir başlık, sürüm, yazar ve durum bilgisi. Kimliksiz bir kural izlenemez; hangi alarmın hangi kuraldan geldiğini, o kuralın ne zaman değiştiğini ve son sürümde neyin düzeltildiğini söyleyemezsiniz. Kimlik numarası başlığa bağlı olmamalıdır, çünkü başlıklar değişir.

Mantık, kuralın ne aradığıdır: veri kaynağı, seçim koşulları, dışlamalar ve bunları birleştiren ifade. Bölüm 4 ve 5 bu parçaya ayrıldı.

Bağlam, kuralın kendisi hakkında söylediklerinden oluşur: hangi ATT&CK tekniğini hedefliyor, hangi alanlara dayanıyor, hangi meşru durumlar bu kuralı yanlış tetikler. Bilinen false positive'lerin kuralın içinde yazılı olması, gece üçte alarma bakan analiste doğrudan zaman kazandırır.

Yanıt, alarmı inceleyen kişiye ilk adımları verir: hedeflenen davranış gerçekleşmişse ne anlama gelir, hangi kayıtlara bakılır ve hangi koşulda eskalasyon yapılır? Kuralı yazarken kullandığımız bağlamın gerekli kısmını alarma da aktarmalıyız.

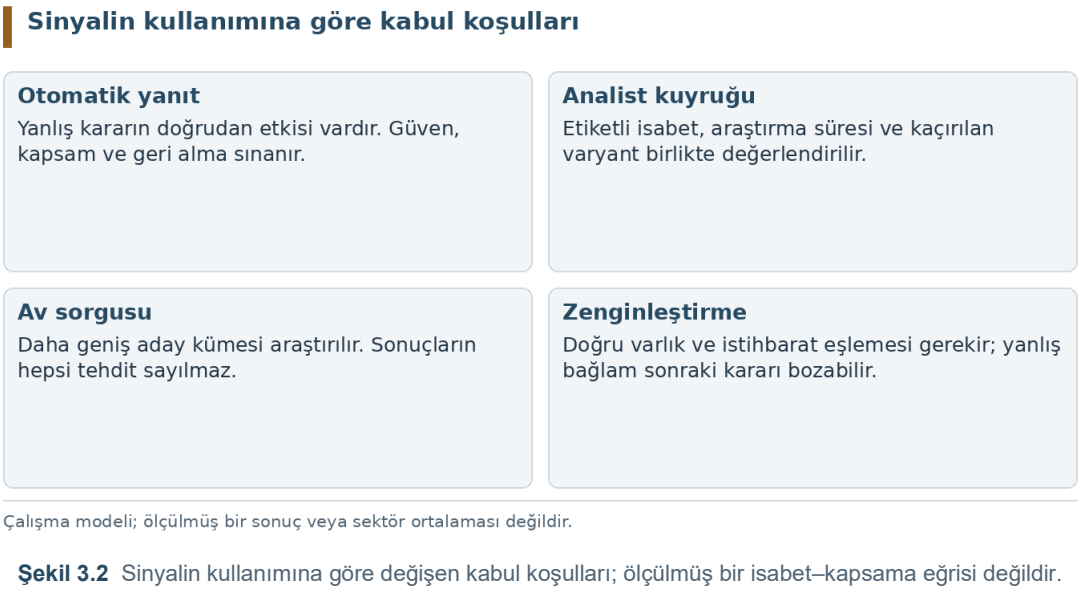
> **ALARM METNİNİ BİR BAŞKASIYLA SINAYIN**
>
> Kuralı yazmamış, gerekli temel eğitimi almış bir analist örnek alarmı inceleyebiliyor mu? Ona ham kayıt ve araştırma bağlantılarını verin. Nerede ek bilgiye ihtiyaç duyduğunu kaydedip metni düzenleyin. Tek bir okuyucunun değerlendirmesi bütün analistlerin aynı sonuca varacağını kanıtlamaz.

3.2 İsabet ve kapsama

Aynı veri kümesinde bir koşulu gevşetmek, eşleşen olay kümesini büyütebilir; eklenenlerin ne kadarı hedef olay, ne kadarı meşru iş, ölçümle anlaşılır. Daha iyi bağlam eklemek ise isabeti ve kapsamayı birlikte iyileştirebilir. İki ölçüyü ayrı ayrı hesaplamak gerekir.

> **TANIM — İSABET VE KAPSAMA**
>
> Etiketli bir kümede isabet TP/(TP+FP), kapsama TP/(TP+FN) olarak hesaplanır. TP hedef sınıfa doğru eşleşme, FP yanlış eşleşme, FN kaçırılan hedef olaydır. Bilinen test veya olay kümesinde FN sayılabilir. Üretimde bilinmeyen saldırıların tamamı bilinmediğinden genel recall aynı kesinlikle hesaplanamaz. Davranış eşleşmesi ile tehdit isabetini ayırın; benign true positive tehdit payına eklenmez.

Sabit veri ve karar mekanizmasında eşiği değiştirirken isabet ile kapsama arasında ödünleşim olabilir. Ama daha iyi alan eşlemesi veya daha iyi bir özellik, ikisini birden iyileştirebilir. Hangi ölçüyü öne alacağımız, sinyalin kullanımına ve hata bedeline bağlıdır.



Şekil 3.2 Sinyalin kullanımına göre değişen kabul koşulları; ölçülmüş bir isabet–kapsama eğrisi değildir.

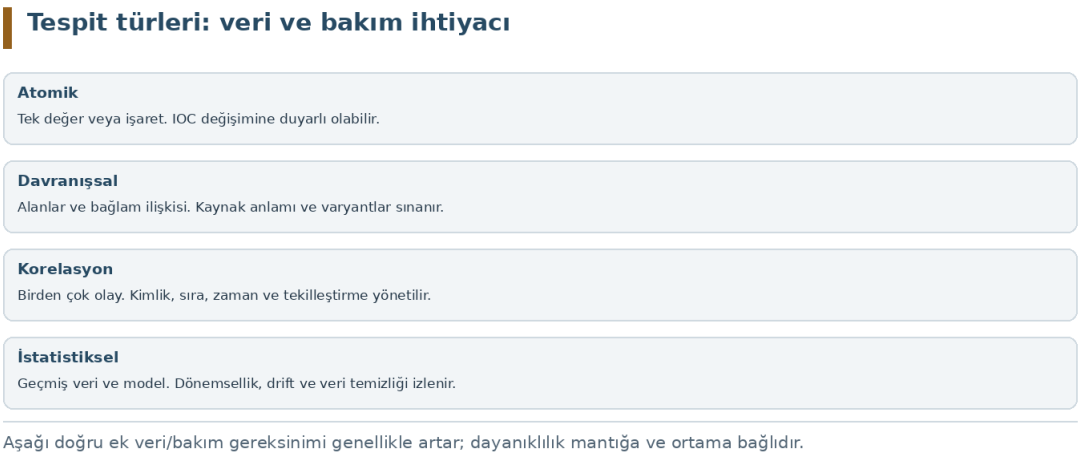
Otomatik yanıt yüksek doğruluk ister; yanlış hesap kilitlemenin doğrudan maliyeti vardır. Analist kuyruğunda bir miktar gürültü kabul edilebilir. Av sorgusu daha geniş çalışabilir. Zenginleştirme tek başına alarm üretmese de yanlış varlık veya hatalı istihbarat eşlemesi kararı bozabilir; onun doğruluğunu da ölçmek gerekir.

Gürültülü bir mantık, doğrudan alarm yerine av sorgusu veya zenginleştirme olarak kullanılabilir. Buna karar verirken hedef davranışı, araştırma yükünü ve bağlamın yararını tekrar değerlendirin.

> **DİKKAT — İSABETİ ORTAMDAN BAĞIMSIZ KONUŞMAYIN**
>
> Bir kuralın isabeti kuralın özelliği gibi konuşulur, oysa büyük ölçüde ortamın özelliğidir. Aynı Sigma kuralı, yönetim araçları düzenli ve imzalı olan bir ortamda yüksek isabetle çalışırken; her makinede farklı script'lerin döndüğü bir ortamda gürültü basar. Bir topluluk kuralının "kaliteli" olması, sizin ortamınızda isabetli olacağı anlamına gelmez. İsabet ancak kendi verinizde ölçüldükten sonra bilinir.

3.3 Tespit türleri ve dayanıklılık

Bu bölümde atomik, davranışsal, korelasyon ve istatistiksel yaklaşımları bir çalışma modeli olarak kullanıyorum. Gereken geçmiş veri ve bakım işi yaklaşımın uygulanışına bağlıdır. Atlatma dayanıklılığı için ise seçilen mantığı ve varyantları ayrıca sınamak gerekir.



Şekil 3.3 Tespit türlerinin veri ve bakım ihtiyacı. Aşağı yön artan ihtiyacı gösterir; evrensel dayanıklılık sıralaması değildir.

Atomik tespit, belirli bir hash, IP veya tam dosya yolu gibi bir değeri arar. Yazımı sade olabilir; isabeti ve ömrü kaynak doğruluğuna ve değerin değişimine bağlıdır. Dosya hash'i değişince aynı hash kuralı artık eşleşmez; bunun başka işaretleri de göremeyeceği anlamına gelmez.

Davranışsal tespit, gerçek ebeveyn–çocuk ilişkisi, komut satırı ve kimlik bağlamı gibi özellikleri birlikte değerlendirir. WMI örneği bu türdendir. Bazı IOC değişimlerine dayanabilir; atlatma zorluğu ise kuralın neyi şart koştuğuna bağlıdır.

Korelasyon, olayları tanımlanmış varlık ve zaman koşullarıyla birleştirir. Örneğin beş dakikadaki başarısız oturum yığını ile sonraki başarı birlikte araştırılabilir. Tek olayın anlamı bağlama bağlıdır; pencereyi daraltmak bir varyantı kaçırabilir, genişletmek ilgisiz olayları birleştirebilir.

İstatistiksel tespit, seçilmiş bir geçmiş dağılımına veya yenilik ölçüsüne bakar. Araç adını aşan sinyaller üretebilir; fakat öğrenme zehirlenmesi, dağılım değişmesi ve açıklanabilirlik sorunları taşır. Saldırganın her koşulda en zor atlatacağı tür olduğu varsayılmamalıdır.

Tür	Yazma işi	Bakım/veri ihtiyacı	Atlatma sınırı
Atomik	Genellikle az	Gösterge güncelliği	Gösterge değişince kaçabilir
Davranışsal	İlişki tasarımı	Alan ve iş bağlamı	Başka davranış/varyant
Korelasyon	Pencere ve kimlik	Durum, gecikme, tekilleştirme	Zincir ve zaman değişebilir
İstatistiksel	Model ve etiket	Geçmiş veri, kayma, açıklama	Normal taklidi/zehirlenme

Kütüphanede kalıpları, hedef davranışa ve bakım kapasitesine göre seçiyorum. Tek olay mantıkları, korelasyonlar ve istatistiksel tespitler farklı gereksinimleri karşılar. Belirli bir dağılımı olgunluğun kanıtı saymak yerine, seçilen yaklaşımın veri ihtiyacını, kaçırdığı varyantları ve işletme yükünü ölçmek gerekir.

İLK GÖRÜLMEYİ BAĞLAMIYLA KULLANIN

Bir değer yalnız tutulmuş geçmişte ilk kez görülmüş olabilir. Kaynak kapsamını, saklama süresini ve listenin yenilenme politikasını yazın. İlk görülmeyi kötü niyetle eşitlemeyin; varlık rolü ve başka davranışlarla ilişkilendirin. Maliyetini hedef veri üzerinde ölçün.

3.4 Eyleme dönüklük: alarm ne söylemeli

Alarm üreten bir tespitte çıktı da teslimatın parçasıdır. İnceleyen kişi ne olduğunu, neden araştırıldığını ve ilk hangi kayıtlara bakacağını anlayabilmelidir. Anlaşılırlık, mantık doğruluğu ve kapsamla birlikte değerlendirilir.

ALARM ÇIKTISI — TEMSİLİ

```
[HIGH] Office uygulaması kodlanmış PowerShell başlattı
kural: DE-0031 · teknik: T1059.001
host: SRV-0142 · kullanıcı: CORP\svc_backup
doğrudan zincir: winword.exe → powershell.exe -enc ...
kanıt: süreç oluşturma kaydı + varsa 4104 betik bloğu
belirsizlik: uzak/yerel veya kötü niyet bu olaydan tek başına çıkmaz

İLK ADIMLAR
1. Ham süreç kaydını ve gerçek ebeveyn kimliğini doğrula.
2. Varsa 4104 içeriğini ve ağ bağlantılarını ilişkilendir.
3. Meşru Office otomasyonu olup olmadığını iş sahibiyle doğrula.
ESKALASYON: doğrulanmış şüpheli yük ve devam faaliyetine göre IR.
```

Bu örnek doğrudan Office → PowerShell olayını bağlamıyla anlatıyor. Hesap türü ve ilk görülme bilgisi telemetri veya doğrulanmış zenginleştirmeden gelmelidir. Elde yoksa bunları kesin bilgi gibi eklemeyin.

Bağlamın miktarını değil işe yararlığını değerlendirin. Özet, karar için gereken bilgiyi taşısın; ayrıntılı ham kayda bağlantı verilsin. Kararı değiştirmeyen ve araştırmayı kolaylaştırmayan metin, alarmı gereksiz yere uzatabilir.

Alarmın bir de teslim edildiği yer vardır ve bu sık atlanır. Bir tespit çaldığında iş tespit mühendisinin masasından çıkar; triyaja, oradan gerekirse olay müdahalesine geçer. Bu devir noktasında kuralın taşıması gereken üç şey vardır: **ne olduğu** (iddia), **neye dayandığı** (hangi olaylar, hangi alanlar) ve **neyin belirsiz olduğu** (kuralın bilinen sınırları).

Üçüncü bilgi, kuralın neyi göremediğidir. Analistin “bu kural yalnız bu varyantı yakalar, zincirin devamını göstermez” sınırını bilmesini özellikle önemsiyorum. Bölüm 14.4’te bu sınırın araştırmaya nasıl yardımcı olduğunu göreceğiz.

Devir çift yönlüdür. Analistin kapanış kaydı, Bölüm 9.7’deki ayarlama döngüsünü besler. Kuralın amacı ve sınırı analiste gider; gözlenen sorunlar, bağlam ve karar gerekçesi de mühendise döner.

> **ALARM BAŞLIĞINDA DAVRANIŞI SÖYLEYİN**
>
> Başlık, olayın nesnesini ve davranışını söylesin: “Office uygulaması kodlanmış PowerShell başlattı.” Bir analiste örnek alarm verip başlıktan hangi iddiayı çıkardığını sorun. Ham kanıt bu ifadeyi destekliyor mu? Şüpheliliğin nedenini bağlamda açıklayın; kötü niyeti yalnız süreç ilişkisinden çıkarmayın.

3.5 Şiddet, güven ve risk

level alanını doldururken şiddet ile güveni ayırmak gerekir. Bütün içeriğe high vermek önceliklendirmeyi zorlaştırabilir; ortam ve varlık etkisi de alarmın değerlendirmesine katılır.

Şiddet (severity) şunu sorar: bu alarm gerçekse ne kadar kötü? Bir domain controller üzerinde credential dump şiddetlidir; bir test makinesinde aynı şey daha az şiddetlidir. Şiddet, olayın *sonucuyla* ilgilidir. **Güven (confidence)** ise şunu sorar: bu alarmın gerçek olma ihtimali nedir? Kuralın geçmiş isabet oranı, mantığın darlığı ve verinin güvenilirliği bunu belirler.

İkisini tek bir sayıya sıkıştırmak bilgi kaybettirir. Düşük güvenli ama çok yüksek şiddetli bir sinyal (domain controller'da olağandışı bir işlem) hızlı bakılmayı hak eder, çünkü yanılma bedeli büyüktür. Yüksek güvenli ama düşük şiddetli bir sinyal (tek bir başarısız oturum) beklemeye alınabilir. Tek bir “high” etiketi bu iki durumu ayırt edemez.

	Düşük güven	Orta güven	Yüksek güven
Yüksek şiddet	Hızlı bak — yanılma bedeli büyük	Öncelikli	En yüksek öncelik
Orta şiddet	Kuyruğa al	Normal akış	Öncelikli
Düşük şiddet	Zenginleştirmeye çevir	Kuyruğa al	Toplu değerlendir

Risk biriktirmede sinyaller, tanımlanmış varlık veya kimlik için belirli bir sürede puana dönüşür. Alarm eşiğini geçen toplam araştırmaya alınabilir. Alışılmadık oturum saati, yeni araç ve beklenmedik bağlantı birlikte kullanılabilir; bu birleşimin yararı etiketli örneklerle ölçülür.

Analist, risk alarmının neden şimdi oluştuğunu görebilmelidir: hangi sinyal, hangi ağırlıkla, hangi zaman aralığında birikti? Puanın yanında katkı olaylarını ve model sürümünü gösterin; eşik ile ağırlıkların yararını ölçün.

3.6 Metadata: kuralı devredilebilir kılmak

Sigma metadata’sı kimliği ve teknik bağlamın bir kısmını taşır; detection mantığı da dosyadadır. Araştırma ve yanıt adımları ise kuralın yanındaki belgeye bağlanabilir. Aşağıdaki örneği, Bölüm 3.1’deki teslimat bilgilerini birlikte tutmanın başlangıcı olarak okuyun.

SIGMA — DOĞRUDAN OFFICE → KODLANMIŞ POWERSHELL

```
title: Office uygulamasından kodlanmış PowerShell
id: 4f2a91c7-6b0e-4d31-9a52-1c7e5f8b2d64
status: experimental
description: >-
  Doğrudan Office ebeveynli powershell.exe sürecindeki -enc veya
  -EncodedCommand kullanımını seçer. Ara süreçli zincirleri kapsamaz.
Author: Ömer Şayak
date: 2026-03-14
modified: 2026-10-06
references:
  - https://attack.mitre.org/techniques/T1059/001/
logsource:
  category: process_creation
  product: 32indows
detection:
  selection_parent:
    ParentImage|endswith:
      - '\winword.exe'
      - '\excel.exe'
      - '\powerpnt.exe'
  selection_enc:
    Image|endswith: '\powershell.exe'
    CommandLine|contains:
      - ' -enc'
      - ' -EncodedCommand'
  condition: selection_parent and selection_enc
fields: [ParentImage, Image, CommandLine, User, Computer]
falsepositives:
  - Office eklentisi veya makro kullanan meşru otomasyon
level: high
tags: [attack.execution, attack.t1059.001, pattern.relationship]
x_rule_revision: dwell-1.1-office-r1
```

Üç alanı özellikle okuyorum. İd kalıcı kural kimliğidir; dosya taşınsa veya başlık değişse de geçmişi bağlamaya yardım eder. Falsepositives bilinen meşru eşleşmeleri açıklar. Fields ise araştırmada gösterilmesi önerilen alanları belirtir. Hedefteki çıktı ayarı ayrıca sınanır.

Sigma status, kuralın olgunluk durumunu anlatır; üründeki çalıştırma veya bildirim ayarını kendiliğinden değiştirmez. Bu kitapta experimental/test için gölgede ölçüm, stable için kanıtlı üretim dağıtımı öneriyorum. Dağıtıcı bu yerel politikayı açıkça uygular. Gölge kural çalışır; eşleşmeleri operasyon kuyruğuna yönlendirilmez.

SAHADAN NOT — METADATA DEPO POLİTİKASIDIR

İstenen alanları CI'da açıkça denetleyin. Standart bir alana yalnız yok/boş diye bakmak yeterli değildir; türü ve anlamı da kontrol edilir. Falsepositives: [] geçerli olabilir. Korelasyonun zorunlu alanları tek olay kuralından farklıdır. Üretim doğrulama şartı ise bu kitabın ayrı depo politikasıdır.

3.7 Kural mı, av mı, zenginleştirme mi

Bir tespit fikri doğrudan alarma dönüşmeyebilir. Önce verisini, karar koşulunu ve tek başına araştırmaya değer olup olmadığını üç soruyla değerlendirelim.



Şekil 3.4 Veriyi, test edilebilir kararı ve kullanım amacını değerlendiren öneri akışı.

İlk soru veri yeterliliğidir. Eksik alan veya kaynak varsa bunu veri talebine dönüştürün. Daha az ayrıntı taşıyan alternatif telemetri kullanılabiliyorsa iddiayı onun gösterdiği davranışla sınırlandırın.

İkinci soru davranışın test edilebilir biçimde tarif edilip edilemediğidir. Belirsiz "olağandışı" tanımı önce araştırma gerektirir. İstatistiksel bir model de eşiği, öğrenme verisi ve hata politikası tanımlandığında tespit olarak işletilebilir.

Üçüncü soru: tek başına eyleme değer mi? Bir sürecin ilk kez görülmesi doğru bir bilgi olabilir; yine de doğrudan vaka açmaya yetmeyebilir. Aynı bilgi başka bir alarmı araştırırken yararlı bağlam sağlayabilir.

> **AYNI FİKRİN ÜÇ FARKLI KULLANIMI**
>
> Fikir: servis kimliğinin beklenmeyen etkileşimli oturumu.
> Önce 4624 ve LogonType kapsamını doğrulayın. Hesabı yalnız ad deseninden tanımayın; TargetUserSid gibi kararlı kimliği güncel hesap envanterinde servis türüne bağlayın. 2 veya 10 oturum türü bu bağlamda değerlendirilir.
> İş politikasına göre doğrudan alarm, dar ve onaylı bakım istisnası veya risk bileşeni seçilebilir. Meşru kullanımın varlığı davranışı otomatik olarak güvenli yapmaz; seçimi ve kanıtını belgeleyin.

Bir sonraki bölüm bu yapının mantık kısmına giriyor: Sigma'nın kitapta kullandığımız temel alanları, modifier'ları, korelasyonları ve derleme hattı.

BÖLÜM 04

Sigma: Kural Dili

Bu bölümde Sigma'nın temel kural yapısını, logsource ve detection mantığını, sık kullanılan modifier'ları, condition ifadelerini ve korelasyonları ele alıyorum. Tam şartname yerine burada kullanılan özelliklere odaklanıyorum; ayrıntılı başvuru kaynakçada.

4.1 Neden ortak bir kural dili

Alan adlarının yanında sorgu dilleri ve tespit motorları da değişir. Ortak mantığı sürümlü bir kaynakta tutmak bakım işini kolaylaştırabilir. Yine de AQL araması, QRadar CRE kuralı, SPL araması, Elastic kural türleri ve KQL analitiği aynı nesne değildir; hedefin koşullarını ayrıca doğrulamak gerekir.

Sigma bu sorunu kural mantığını taşınabilir bir biçimde ifade ederek çözer. Kuralı YAML olarak bir kez yazarsınız, bir derleyici onu hedef platformun diline çevirir. Kazanç yalnızca çeviri kolaylığı değildir; asıl kazanç mantığın tek bir yerde, insan tarafından okunabilir hâlde durmasıdır. Bir kural incelemesinde artık sorgu sözdizimi yerine tespitin kendisi tartışılır.

> **SIGMA KURALINI HEDEF MOTORDA AYRICA SINAYIN**
>
> Bu kitaptaki SIEM dağıtım yolunda Sigma dosyası hedef sorguya dönüştürülür. Her özellik her hedefte aynı biçimde desteklenmeyebilir; çıktı ve alan eşlemesi incelenir. Derleme, hedefte kabulün kanıtı değildir. Paketin sınırlı yerel matcher'ı seçilmiş mantığı sentetik olaylarla yorumlar; canlı motorun davranışını doğrulamaz. Hedef testi ve emülasyon Bölüm 7–8'de ele alınır.

4.2 Kural yapısı

Bir tek olay Sigma kuralını dört bölgeyle okumak yararlıdır: kimlik, veri kaynağı, mantık ve bağlam. Bu bölgeler, Bölüm 3'teki teslimatın teknik kısmını taşır; yanıt adımları ayrıca belgelenir.



Şekil 4.1, tam Sigma dosyasının bölümlerini gösteriyor. Tek başına selection yazmak dosyayı tamamlamaz; logsource, condition ve metadata da kendi görevini yerine getirir.

Tek olay kuralında title, logsource ve detection zorunludur. Korelasyon dokümanı ise ayrı türdür; logsource/detection yerine correlation içerir. Aşağıdaki tablo, bu kitapta sık kullanılan alanları özetler. Depomuzun istediği metadata, standardın zorunluluklarından ayrıca tanımlanır.

Alan	Zorunlu	Ne işe yarar
`title`	Evet	Kısa ve iddia bildiren başlık; alarmda görünür
`id`	Hayır (ama şart)	Kalıcı UUID; başlık değişse de sabit kalır
`status`	Hayır	`experimental` · `test` · `stable` · `deprecated` · `unsupported`
`description`	Hayır (ama şart)	Kural ne arar, hangi zincirde görülür
`references`	Hayır	Kaynak: ATT&CK sayfası, blog, olay raporu
`author` / `date`	Hayır	Sahiplik ve yaş; `modified` ile birlikte
`logsource`	Evet	Kuralın hangi veriye bakacağı
`detection`	Evet	Arama mantığı: selection, filter, condition
`fields`	Hayır	Alarmda gösterilecek alanlar
`falsepositives`	Hayır (ama şart)	Bilinen meşru tetikleyiciler
`level`	Hayır	`informational` → `critical`
`tags`	Hayır	ATT&CK taktik/teknik ve diğer sınıflandırma

status dağıtım politikamızın girdisidir. experimental, test, stable, deprecated ve unsupported standart değerlerdir. Hangi ortamda çalışacağına ve nasıl bildirim üreteceğine dağıtıcı karar verir. Deprecated içeriği tarihçe için tutup üretim manifestinden çıkarmak, bu kitapta önerilen bakım tercihidir.

4.3 logsource: kuralın nereye bakacağı

logsource veri kapsamını tarif eder. category, product ve service yaygın anahtarlardır; definition gibi ek açıklama alanları da kullanılabilir. Kapsamın hedef veri kümesine çevrilmesi pipeline ve entegrasyona bağlıdır.

`product` üretici ya da platformdur: `windows`, `linux`, `aws`, `zeek`. `service` o platform içindeki belirli bir kaynak ya da kanaldır: `sysmon`, `security`, `sshd`, `cloudtrail`. `category` ise olayın *türüdür* ve platformdan bağımsızdır: `process_creation`, `network_connection`, `dns_query`, `file_event`, `registry_set`.

category: process_creation, süreç oluşturma verisine yönelik taşınabilir bir niyet belirtir. Sysmon EID 1 ile Windows 4688 farklı alanlar sunabilir; dönüşümün gerekli tür, anlam ve kapsamı koruduğu ayrıca sınanır. service: sysmon ise belirli kaynak sözleşmesini tarif eder. Başka kaynağa uyarlamada etiketi değiştirmek yeterli değildir; alanlar ve gerçek olaylarla eşdeğerlik doğrulanır.

LOGSOURCE — ÜÇ AYRI AÇIKLAMA DOKÜMANI

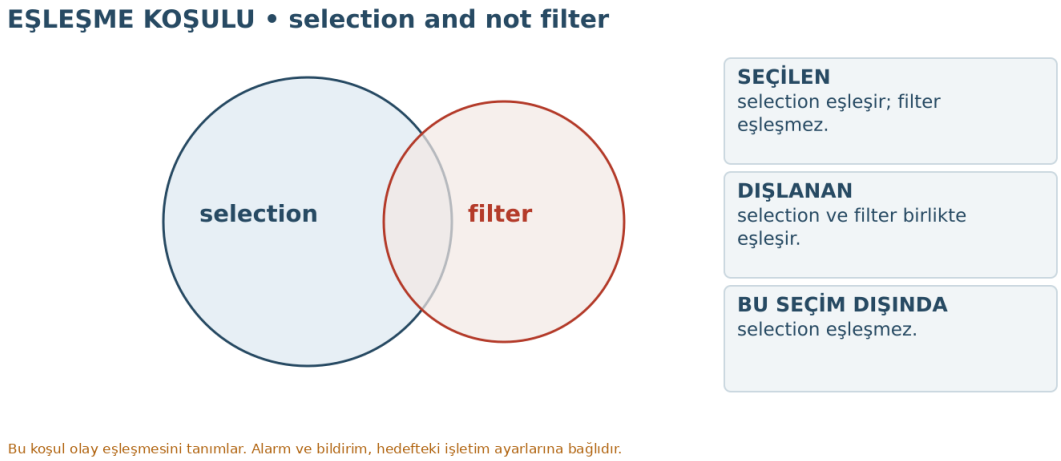
```
logsource:
  category: process_creation
  product: windows
---
logsource:
  product: windows
  service: security
---
logsource:
  product: windows
  service: sysmon
  definition: "Sysmon EID 1; ProcessCreate kaydı etkin olmalı."
# Bunlar üç alternatif kapsam parçasıdır; tam kurallar değildir.
```

`definition` alanı belge niteliğindedir; derlemeye etki etmez ama kuralın hangi ön koşulla çalıştığını yazılı hâle getirir. Bölüm 2'deki veri sözleşmesi fikrinin kural seviyesindeki karşılığıdır ve kuralın neden çalmadığını araştıran kişiye ilk ipucunu verir.

category: process_creation taşınabilir bir niyet belirtir. ParentCommandLine gibi her kaynakta bulunmayan alan kullanıyorsanız, Security 4688'e geçişte aynı kuralın çalışacağını varsaymayın; alan gereksinimini ayrıca doğrulayın.

4.4 detection: selection, filter, condition

detection içinde seçimler ve bunları birleştiren condition bulunur. selection ve filter adları yaygın adlandırmalardır; ayrı standart anahtar türleri değildir. Dışlama, condition içinde ilgili seçimin olumsuzlanmasıyla uygulanır.



Şekil 4.2 selection and not filter koşulunda seçilen ve dışlanan olay kümeleri.

Bir arama tanımının içindeki alanlar **VE** ile bağlanır; aynı alana verilen liste değerleri ise **VEYA** ile. Bu tek kural, Sigma sözdiziminin yarısını açıklar.

SELECTION — VE / VEYA; DETECTION PARÇASI

```
selection:
  Image|endswith:         # bu liste OR
    - '\cmd.exe'
    - '\powershell.exe'
  User|startswith: 'CORP\' # Image ile AND
selection_alt:            # liste içindeki bloklar OR
  - Image|endswith: '\wmic.exe'
  - Image|endswith: '\rundll32.exe'
# Birinci seçim: (cmd VEYA powershell) VE CORP kullanıcısı.
# İkinci seçim: wmic VEYA rundll32.
# Bunlar iki ayrı açıklama; tam dosya ve condition değildir.
```

condition'a eklenen dışlama, hangi olayların eleneceğini belirler. Kimlik, gerçek süreç kökeni ve yapılan işin bağlamıyla dar bir koşul tanımlayın. Bu alanların yalnız metin içinde geçmesi güvenli kullanım kanıtı sayılmaz.

DIŞLAMA — GENEL MANTIK PARÇASI

```
# Geniş: bütün PowerShell olaylarını dışlayabilir.
filter_broad:
  Image|endswith: '\powershell.exe'

# Dar örnek: doğrulanmış bir işin kimliği ve gerçek kökeni.
# ApprovedJobId, doğrulanmış envanter/iş kaydından eklenir.
filter_env_job:
  User: 'CORP\svc_deploy'
  ParentImage: 'C:\Program Files\Dagitim\agent.exe'
  ApprovedJobId: 'Dwell-Example-Job'
# condition: selection and not filter_env_job
# Tam bir Sigma kuralı değildir; Office örneğine eklenmez.
```

SAHADAN NOT — HER DIŞLAMAYA BİR TARİH VE GEREKÇE YAZIN

Dışlamalar zamanla birikir ve kimse neden eklendiklerini hatırlamaz. Altı ay sonra kimse `svc_deploy` dışlamasının hâlâ gerekli olup olmadığını bilemez, kaldırmaya da cesaret edemez. Basit bir alışkanlık bunu çözer: her dışlamanın üstüne bir yorum satırı — hangi tarihte, hangi bilet için, hangi gerekçeyle eklendi.

Bir adım ötesi, dışlamalara son kullanma tarihi koymaktır. Altı ayda bir süresi dolan dışlamaları listeleyip gözden geçirmek, kural mezarlığının dışlama tarafındaki karşılığını önler.

4.5 Modifier'lar

Alan adından sonra dikey çizgiyle eklenen modifier'lar, eşleşmenin nasıl yapılacağını belirler. Bunlar Sigma'nın ifade gücünü taşıyan asıl mekanizmadır ve zincirlenebilirler.

Modifier	Ne yapar	Örnek
contains	Metnin içinde arar	CommandLine|contains: '-enc'
startswith	Başlangıcı eşler	Image|startswith: 'C:\Users'
endswith	Sonu eşler	Image|endswith: '\cmd.exe'
all	Listedeki değerleri birlikte ister	CommandLine|contains|all: [a, b]
cased	Metni harf duyarlı eşler	User|cased: 'CORP\Admin'
re	Varsayılan harf duyarlı regex	CommandLine|re: 'From.?Base64'
base64	Değeri base64'e dönüştürür	CommandLine|base64: 'whoami'
base64offset	Üç hizalama için dönüşüm üretir	CommandLine|base64offset|contains
cidr	IP ağ aralığını eşler	source.ip|cidr: '10.0.0.0/8'
lt lte gt gte	Sayısal karşılaştırır	EventID|gt: 4000
windash	Bayrakta - ve / biçimlerini kapsar	CommandLine|windash|contains: '-enc'
fieldref	Başka alanın değeriyle karşılaştırır	TargetUser|fieldref: SubjectUser
exists	Anahtarın varlığını sınar	CommandLine|exists: false

base64offset, bir parçanın Base64 akışındaki üç bayt hizalamasını dikkate alan arama değerleri üretir. PowerShell EncodedCommand UTF-16LE bekler; bu nedenle aranan düz metin önce wide/utf16le ile dönüştürülür. Bu teknik tüm gizleme biçimlerini çözmez; farklı yüklerle test edilir.

windash, seçilmiş bayrak metni için tire ve bölü işareti varyantlarını karşılayabilir; komut satırının bütün argümanlarını ayrıştırmaz. Metin eşleşmesi varsayılan olarak harf duyarsızdır; cased harf duyarlılığı ister. Regex varsayılanı farklıdır. exists alanın mevcut olup olmadığını sınar; null veya boş değer de mevcut bir alanda bulunabilir. Hedef arama dilinin karşılığını ayrıca sınayın.

> **MODIFIER ZİNCİRİ — SEÇİM PARÇASI**
>
> CommandLine|wide|base64offset|contains: 'IEX (New-Object'
>
> PowerShell EncodedCommand UTF-16LE bekler. Önce wide (utf16le) dönüşümü, sonra base64offset ve içerme eşleşmesi uygulanır. Bu satır tam bir kural değildir. Paket testleri, farklı hizalamalardaki yükleri sınar; hedef regex/arama davranışı ayrıca doğrulanır.

4.6 condition ifadeleri

`condition`, tanımladığınız blokları birleştiren mantıksal ifadedir. Basit hâliyle `and`, `or`, `not` kullanır; ama asıl gücü toplu ifadelerdedir.

CONDITION — ALTERNATİFLER, TEK DOSYA DEĞİL

```
# Her satır ayrı bir condition seçeneğidir.
# condition: selection
# condition: selection and not filter_x
# condition: selection and not 1 of filter_*
# condition: selection and not all of filter_*
# condition: 1 of selection_*
# condition: all of selection_*
```

`1 of filter_*` ile `all of filter_*` arasındaki fark, dışlama tarafında ciddi sonuçlar doğurur. `not 1 of filter_*` yazdığınızda *herhangi bir* dışlama eşleştiğinde olay elenir; `not all of filter_*` yazdığınızda ise elenmesi için *tüm* dışlamaların birden eşleşmesi gerekir. İlki geniş, ikincisi dardır ve bunları karıştırmak, kuralın ya çok sessiz ya çok gürültülü olmasına yol açar.

VARLIK, DOLULUK VE YOKLUK

Sigma'da exists:true anahtarın mevcut olmasını ister; değeri null, boş metin veya boş liste olabilir. Dolu metin koşulu ayrı yazılır. Eksik anahtar ile mevcut null değerini aynı fixture saymayın. Hedef motorun alan indeksleme, NOT ve null davranışını ayrıca sınayın; yerel matcher'ın sonucu canlı SIEM kanıtı değildir.

4.7 Korelasyon kuralları

Buraya kadarki her şey tek bir olaya bakıyordu. Bölüm 3.3'te korelasyon tespitlerinden söz etmiştik; Sigma bunu ayrı bir kural türüyle karşılar. Korelasyon kuralı kendi başına bir arama yapmaz, daha önce tanımlanmış kuralları referans alır ve onların üzerine bir zaman penceresi ile gruplama uygular.

Korelasyonda sayım, ilişki ve sıra

event_count
Pencere içinde toplam olay sayısı; ör. 5m içinde ≥20 başarısız oturum.

value_count
Belirtilen alanın farklı değer sayısı; ör. 10m içinde >3 TargetHost.

temporal
Referans kurallar aynı grup ve zaman aralığında görülür; sıra aranmaz.

temporal_ordered
Referans kurallar tanımlı sırayla görülür; hedef backend desteği ayrıca gerekir.

Ortak sözleşme: referans kurallar, group-by, timespan ve türe uygun condition.

Şekil 4.3 Korelasyon örnekleri: olay sayımı, farklı değer sayımı ve sıralı ilişki. Sırasız temporal ayrıca vardır.

KORELASYON — DÖRT YAML DOKÜMANI

```yaml
title: Başarısız oturum
id: c56e12af-1035-46fd-a54d-1b45a8c29998
name: basarisiz_oturum
logsource: {product: windows, service: security}
detection:
  selection: {EventID: 4625}
  condition: selection
---
title: Başarılı oturum
id: 4e5c7917-5193-4a2c-96a6-b77a76d6459e
name: basarili_oturum
logsource: {product: windows, service: security}
detection:
  selection: {EventID: 4624}
  condition: selection
---
title: Beş dakikada yirmi başarısız oturum
id: 357fb1eb-1ee6-4b0e-9aaf-6486c343f3cf
name: basarisiz_yigin
correlation:
  type: event_count
  rules: [basarisiz_oturum]
  group-by: [TargetDomainName, TargetUserName, Computer]
  timespan: 5m
  condition: {gte: 20}
---
title: Başarısız oturum yığınından sonra başarı
id: f9e8d56b-b613-4b76-bb8a-4be9c4d1f253
status: experimental
description: >-
  Aynı domain, kullanıcı ve hedefte başarısız oturum yığınından sonra
  başarılı oturum arar. Bu ilişki hesabın ele geçirildiğini tek başına kanıtlamaz.
correlation:
  type: temporal_ordered
  rules: [basarisiz_yigin, basarili_oturum]
  group-by: [TargetDomainName, TargetUserName, Computer]
  timespan: 15m
  condition: {gte: 2}
falsepositives: [Parolayı yanlış yazıp daha sonra doğru oturum açılması]
level: high
tags: [attack.credential-access, attack.t1110]
x_rule_revision: dwell-1.1-brute-force-r1
```

Örnek dört YAML dokümanından oluşuyor: iki temel olay kuralı, bir sayım ve bir sıralı korelasyon. Aynı domain, kullanıcı ve hedef kullanılıyor; yalnız kullanıcı adına göre farklı hesapları birleştirmiyoruz. Başarısız yığından sonra başarı araştırma sebebidir, tek başına ele geçirme kanıtı değildir. Zincirleme korelasyon desteği derleyici ve hedef motorla ayrıca doğrulanır.

Bu çok aşamalı korelasyon pySigma ve resmî şemayla ayrıştırılmıştır. Burada sabitlenen Splunk backend temporal_ordered dönüşümünü, Lucene backend ise korelasyonu desteklemediği için derleme hata verir. Eşlikçi queries/brute_force_ordered.spl hedefe özgü arama taslağıdır; native Splunk replay'i yapılmış sayılmaz. Pencere, sıra ve geç gelen olaylar hedefte ayrıca sınanır.

Tür	Ne sayar	Tipik kullanım
`event_count`	Aynı kuralın kaç kez tetiklendiği	Brute-force, tarama
`value_count`	Bir alanın kaç farklı değer aldığı	Port tarama, hesap sayımı
`temporal`	Farklı kuralların aynı pencerede tetiklenmesi	Çok aşamalı saldırı
`temporal_ordered`	Aynısı, ama sıraya bağlı	Önce şu, sonra bu

> **OLAY ZAMANI İLE GEÇ VERİYİ AYIRIN**
>
> Davranışın beş dakikalık koşulu, olay gerçekleşme zamanları arasındaki ilişkiyi anlatabilir. Kaynakların farklı gecikmeyle ulaşması ise arama geçmişi ve geç veri kabulü sorunudur. Hangi saatin kullanıldığını yazın; hedef motor destekliyorsa geç gelen kayıtları kapsayan lookback veya kabul süresi tanımlayın. Aynı olayı tekrar alarm yapmamak için tekilleştirmeyi de sınayın.

4.8 Kuralı hedefe indirmek

Yazılan kural, hedef platformun sorgusuna çevrilerek çalışır hâle gelir. Bu işi `sigma-cli` ve platform backend'leri yapar; araya giren pipeline ise Bölüm 2.4'te kurduğumuz alan eşlemesini uygular.



Şekil 4.4 Derleme ve hedef kabulü ayrı adımlardır; hedef listesi temsili örnektir.

SIGMA-CLI — PAKET KURULUMU VE DOĞRULAMA

```
python -m pip install -r requirements-lock.txt
sigma list targets
sigma list pipelines

# Resmî şema + ayrı depo politikası; fixture dosyaları ayrılır.
python -m tools.sema_kontrol rules --as-of 2026-10-06
python -m tools.test_rules rules
python -m tools.derle

# Tek dosya için örnek hedefler:
sigma convert -t splunk -p splunk_windows rules/office_enc_powershell.yml
sigma convert -t lucene -p pipelines/sysmon-to-ecs.yml rules/office_enc_powershell.yml
# --without-pipeline gerçek bir seçenektir; alan eşlemesini atlar.
```

Derleme çıktısını inceleyin. Eşlikçi pakette aynı Office kuralı için Splunk ve Lucene çıktıları ile kullanılan pipeline dosyaları bulunur. Çıktının oluşması, hedefin alan türleri veya harf duyarlılığıyla eşleştiğini ayrıca kanıtlamaz.

AYNI KURAL — DERLEME ÇIKTISI ÖRNEĞİ — HEDEFTE YENİDEN ÜRETİLMELİ

```
# Splunk; splunk_windows pipeline
ParentImage IN ("*\\winword.exe", "*\\excel.exe", "*\\powerpnt.exe") Image="*\\powershell.exe"
CommandLine IN ("* -enc*", "* -EncodedCommand*") | table
ParentImage,Image,CommandLine,User,Computer

# Lucene; dar dwell-sysmon-to-ecs pipeline
(event.dataset:windows.sysmon_operational AND event.code:1) AND
((process.parent.executable:(*\\winword.exe OR *\\excel.exe OR *\\powerpnt.exe)) AND
(process.executable:*\\powershell.exe AND (process.command_line:(*\ \-enc* OR *\ \-
EncodedCommand*))))

# Kaynak/dataset ve keyword harf davranışı sözleşmede doğrulanır.
# Satır kırılması dizgi içindir; sorgu compiled/ içinde tek satırdır.
```

Derleme, desteklenmeyen modifier veya pipeline koşulunda hata verebilir. Bazı backend'ler eşlenmemiş alanı aynen aktarabilir; bu nedenle derleme başarısı alanın hedefte var olduğunu garanti etmez. CI sonucu, kaynak sözleşmesi ve hedef replay'i birlikte incelenir.

4.9 Kural yazım disiplini

Sözdizimini bilmek yetmez; okunabilir ve bakımı yapılabilir kural yazmak ayrı bir alışkanlık kümesidir. Aşağıdakiler, sahada tekrar tekrar işe yaradığını gördüğüm kurallardır.

Blok adları anlam taşısın. `selection1`, `selection2` yerine `selection_parent`, `selection_encoded`, `filter_sccm`. Altı ay sonra kurala dönen kişi ilk okumada ne olduğunu anlar. **Dışlamayı ayrı bloklara ayırın.** Tek bir dev `filter` yerine gerekçesine göre ayrılmış küçük bloklar, birini kaldırmayı güvenli hâle getirir.

Tam yol yerine ucu eşleştirin. `Image: 'C:\Windows\System32\cmd.exe'` yerine `Image|endswith: '\cmd.exe'` yazın; ilki 32-bit yol, farklı sürücü ya da farklı Windows dizini durumunda kaçırır. Bunun tersi de doğrudur: dışlama yazarken tam yol kullanın, çünkü orada gevşeklik kör nokta üretir.

Bir kurala açık bir iddia verin. Birden fazla dal gerektiğinde alarmda hangi dalın eşleştiğini taşıyın ve her dalı ayrı test edin. Aksi hâlde gürültünün hangi mantıktan geldiği izlenemez.

> **SAHADAN NOT — KURALI TERS OKUMAK**
>
> Bir kuralı yayına almadan önce yaptığım son kontrol şu: kuralı saldırganın gözünden okumak. “Bu kuralın yakalamaması için ne yapmam gerekir?” Cevap genelde şaşırtıcı derecede basittir — dosyayı başka bir adla çalıştırmak, bayrağı `/` ile yazmak, komutu iki parçaya bölmek.
>
> Bulunan her kaçış yolu iki sonuçtan birine gider: ya kural genişletilir, ya da kaçış yolu kabul edilip kuralın açıklamasına yazılır. İkincisi de meşrudur; asıl sorun, kaçış yolunun bilinmemesidir.

Sigma’nın bu kitapta kullandığımız yapılarını gördük. Şimdi aynı dille kurulan farklı mantıklara geçeceğiz: eşleşme, ilişki, eşik, nadirlik, sıra ve sapma.

BÖLÜM 05

Kural Mantığı Kalıpları

> *Sigma sözdizimini bilmek, iyi kural yazmaya yetmez. Aynı dille çok farklı kalitede tespitler kurulabilir. Bu bölüm sahada tekrar eden altı mantık kalıbını ele alıyor: eşleşme, ilişki, eşik, nadirlik, sıra ve sapma. Her kalıbın neyi gerektirdiğini, nerede kırıldığını ve hangi durumda seçilmesi gerektiğini kuruyor.*

5.1 Kalıp düşünmek

Deneyimli bir detection engineer, yeni bir tespit fikriyle karşılaştığında sıfırdan düşünmez. Fikrin hangi mantık kalıbına oturduğunu tanır ve o kalıbın bilinen tuzaklarıyla işe başlar. Bu, satranççının açılış bilmesine benzer: her tahtayı baştan hesaplamak yerine tanıdık yapıyı görüp oradan devam eder.

Bu altı kalıbı, tespit fikrini düzenlemek için kullanıyorum. Her tespiti eksiksiz sınıflandıran bir standart değildir. Geçmiş veri ve bakım ihtiyacı arttıkça maliyet de artabilir; saldırganın atlatma zorluğu otomatik olarak aynı sırayı izlemez.

BU KİTABIN ALTI MANTIK KALIBI

Kalıp	Karar için örnek veri	Geçmiş / durum gereksinimi
Eşleşme	Alan değeri veya gösterge	Tek olay; varsa liste sürümü
İlişki	Süreç–ebeveyn veya kimlik–tür	İlişki alanları; gerekirse birleştirme
Eşik	Tanımlanmış varlık için sayım	Pencere ve sayaç
Nadirlik	İlk/seyrek değer	Kapsam ve geçmiş kayıt politikası
Sıra	Bağlanmış olay dizisi	Varlık, sıra ve zaman durumu
Sapma	Referanstan ayrılan değer	Sabit referans veya sürümlü model

Yerel sınıflandırma; bakım maliyeti ve atlatma dayanıklılığı aynı sırayla artmak zorunda değildir.

Şekil 5.1 Bu kitapta kullanılan altı kalıbın veri ve geçmiş gereksinimi.

Gereken geçmiş, kalıba göre değişir. Tek olay eşleşmesi karar için olaylar arası durum tutmayabilir. Eşik ve sıra bir pencereyi; nadirlik ve sapma geçmiş referansı kullanır. Öğrenme süresi her durumda haftalar olmak zorunda değildir. Model bozulduğunda geri yükleme, yeniden öğrenme veya geçici alternatif kararları veri durumuna göre seçilir.

5.2 Eşleşme: bilinen kötüyü aramak

En basit kalıp, bir alanın bilinen değere eşleşmesidir. Hash, IP veya alan adı listesi hızlı bir başlangıç sağlayabilir. İsabet, listenin güncelliğine ve göstergenin paylaşılan altyapıya ait olup olmadığına bağlıdır.

IOC eşleşmeleri için güncellenen referans listeleri kullanılabilir. Listeyi istihbarat, olay ve av sonuçları besler; kaynağın güvenilirliği, geçerlilik süresi ve geri alma yöntemi ayrıca tanımlanır. Elle yazılmış koşul da bazı dar durumlarda uygun olabilir.

SIGMA — NORMALLEŞTİRİLMİŞ DNS ADI

```
title: Normalleştirilmiş DNS adının gösterge listesiyle eşleşmesi
id: 140f194d-30f8-4b13-a5bb-d4c022ab0cf5
status: experimental
description: Örnek alan adlarını tam eşleştirir; listedeki .example adları gerçek IOC değildir.
logsource: {category: dns_query}
detection:
  selection:
    QueryNameNormalized: [kotu-alan-1.example, kotu-alan-2.example]
  condition: selection
falsepositives: []
level: high
x_rule_revision: dwell-1.1-dns-r1
```

IOC LİSTESİNİN YAŞINI İZLEYİN

Gösterge listesinde kaynağı, eklenme tarihini, geçerlilik süresini ve kaldırma kararını tutun. Alanın türünü ve eşleme biçimini sınayın. Eski veya ortak kullanılan bir değer meşru kaydı da eşleştirebilir; IOC eşleşmesi tek başına ihlal kanıtı değildir.

5.3 İlişki: alanlar arası bağ

İlişki kalıbı bir olayın alanları arasındaki bağı arar. Word ve PowerShell ayrı ayrı meşru olabilir; Word'ün PowerShell başlatması incelemeye değer bir ilişkidir. Ancak eklenti veya otomasyon da bunu yapabilir. İlişkiyi kötü niyetle eşitlemeden bağlamı araştırın.

En yaygın ilişki, doğrudan süreç ebeveynliğidir. Aşağıdaki ikinci örnek ise sabit dosya adı ile meşru dizin koşulunu karşılaştırır; fieldref kullanmaz. fieldref, TargetUser|fieldref: SubjectUser gibi iki alanın değerini birbirine bağlayan ayrı bir modifier'dır.

İLİŞKİ — İKİ AYRI DETECTION PARÇASI

```
# 1: doğrudan ebeveyn ilişkisi
detection:
  selection:
    ParentImage|endswith: ['\winword.exe', '\excel.exe']
    Image|endswith: ['\cmd.exe', '\powershell.exe', '\wscript.exe']
  condition: selection
---
# 2: sabit ad + izinli dizin; fieldref değildir.
detection:
  selection:
    Image|endswith: '\svchost.exe'
  filter_paths:
    Image|startswith: ['C:\Windows\System32\', 'C:\Windows\SysWOW64\']
  condition: selection and not filter_paths
# Gerçek Windows dizini ve 32/64-bit kapsamı ayrıca doğrulanır.
```

İkinci örnek, sistem ikilisinin beklenen yolunu kontrol eder. Hangi işletim sistemi ve ikili sürümünün hangi dizinlerde bulunabileceğini envanterden doğrulayın. Meşru bir SysWOW64 yolunun unutulması, o yolu kullanan süreçlerin yanlış eşleşmesine neden olabilir; örneği bütün ikililere aynı listeyle kopyalamayın.

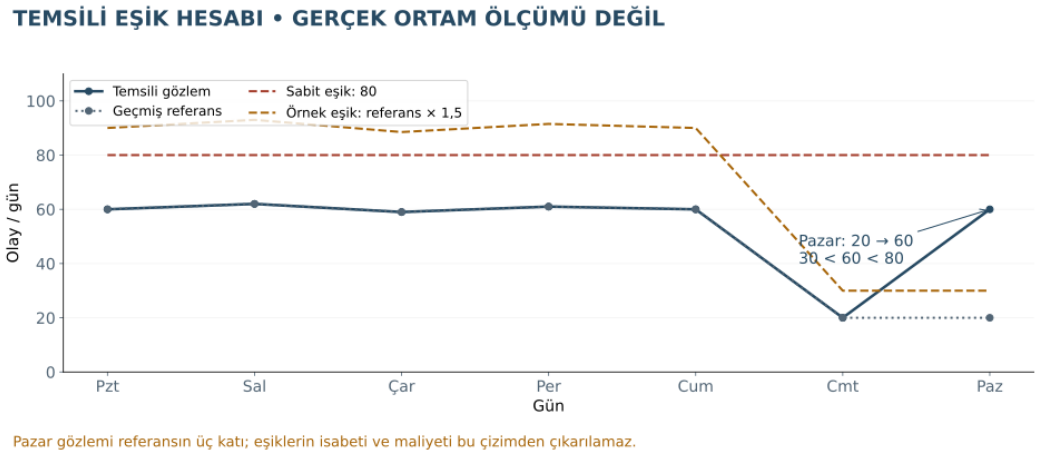
SAHADAN NOT — SOYAĞACINA İKİ KUŞAK YUKARIDAN BAKMAK

Doğrudan winword.exe → powershell.exe ile winword.exe → cmd.exe → powershell.exe aynı ilişki değildir. İkinci zincir için ara sürecin ProcessGuid'si ile çocuğun ParentProcessGuid'si birleştirilir. WMI'de oluşturan istemci ve gerçek ebeveyn ayrılabilir; winword → WmiPrvSE zinciri varsayılarak çizilmez. Gerekirse WMI istemci faaliyeti ayrı telemetriyle ilişkilendirilir.

5.4 Eşik: kaç kere, ne kadar sürede

Üçüncü kalıp, tek bir olayın anlamsız ama tekrarının anlamlı olduğu durumları karşılar: brute-force, tarama, veri sızdırma. Sigma tarafında `event_count` ve `value_count` korelasyonlarıyla ifade edilir (Bölüm 4.7).

Eşik seçerken sayının yanında sayılan olayı, varlığı, pencereyi ve karşılaştırma işlemini tanımlayın. Tek bir sabit eşiği farklı varlıklara uygulamadan önce bunların normal dağılımını ve kaçırılan örnekleri karşılaştırın.



Şekil 5.2 Temsili günlük olay sayıları ve iki örnek eşik; gerçek ürün ölçümü değildir.

Şekil 5.2 hesaplanmış temsili bir örnektir. Pazar referansı 20 olay/gün, gözlenen değer 60'tır: üç katına çıkar, fakat 80'lik sabit eşiğin altında kalır. Referansın 1,5 katı olan 30'luk örnek eşik aşılır. Bu hesap bir ürünün gerçek ortam başarısını göstermez; hafta içi sonuçları ve yanlış alarmlar da ölçülmelidir.

Uyarlanabilir eşikte varlığın geçmişi, aynı zaman diliminin geçmiş değerleri veya benzer rolü paylaşan bir grubun dağılımı referans alınabilir. Grup referansı, yeni bir varlık için başlangıç sağlayabilir; fakat grubun geçmişi ve benzerliği yeterli değilse güvenilir sonuç vermez. Maliyet ve isabet, veri ile uygulamaya göre ölçülür.

Eşik türü	Nasıl kurulur	Güçlü yanı	Zayıf yanı
Sabit	Elle seçilen sayı	Basit, açıklanabilir	Ortam çeşitliliğini görmez
Varlığa göre	Her makinenin kendi geçmişi	Hassas	Yeni makinede veri yok
Zamana göre	Geçmiş haftaların aynı saati	Mevsimselliği görür	Uzun geçmiş ister
Gruba göre	Rol grubunun ortancası	Yeni makinede de çalışır	Grup tanımı gerektirir

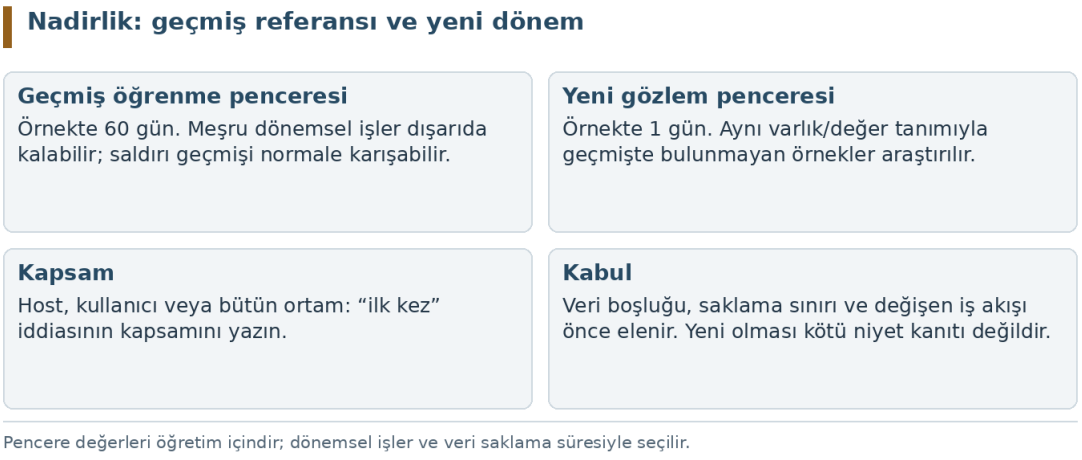
SABİT PENCERENİN SINIRINI TEST EDİN

Temsili örnekte 19 deneme bir sabit dilimde, 19 deneme sonraki dilimde kalırsa dilim başına 20 eşiği aşılmaz. Bu olayların tümü herhangi bir beş dakikalık aralığa sığıyorsa kayan pencere farklı sonuç verebilir. Sabit, örtüşen ve kayan pencere davranışını sınır fixture'larıyla ölçün. Eşiği otomatik düşürmeyin; kaçırılan örnek, yanlış alarm, tekilleştirme ve maliyeti birlikte değerlendirin.

5.5 Nadirlik: ilk kez görülen

Nadirlik, bir değerin tanımlanan kapsamda ilk kez veya seyrek görülmesini araştırır. Yeni süreç, kullanıcı–sunucu ilişkisi veya yayıncı örnekleri bu amaçla izlenebilir. Uygulama maliyeti, saklanan geçmişe ve değerin doğru kimlikle birleştirilmesine bağlıdır.

Nadirlik kalıbı iki pencere gerektirir ve bunları ayırmak kritiktir.



Şekil 5.3 Nadirlik kalıbının iki penceresi ve üzerinde durduğu varsayım.

Kısa öğrenme penceresi, ayda bir çalışan meşru işi hiç görmeyebilir. Uzun pencere ise geçmişteki saldırgan davranışı normal kabul etme riskini artırır. Örnekte altmış gün kullanılıyor; bu bir genel eşik değildir. Dönemsel işleri, saklama süresini ve veri temizliğini dikkate alarak seçin.

"Bu makinede ilk kez" ile "bu ortamda ilk kez" farklı iddialardır. Kapsamı genişletmek veya iki ölçüyü birlikte kullanmak, sinyal kümesini değiştirir. Yeni görülmenin ne kadar yararlı olduğunu yerel etiketli örneklerle ölçün; tek başına ciddiyet atamayın.

NADİRLİK — ORTAMDA YENİ VE SEYREK SÜREÇ

```
index=win EventCode=1 earliest=-60d
| stats earliest(_time) AS ilk_gorulme dc(host) AS kac_host
        count AS toplam BY Image
| where kac_host<=2 AND toplam<=5 AND ilk_gorulme>=relative_time(now(),"-24h")
| eval yas_gun=round((now()-ilk_gorulme)/86400,1)
| sort - toplam
# Ortam çapında ilk görülme; host bazında ilk görülme hesabı değildir.
# 60 gün saklanan geçmişte hiç görülmeme, tarihte hiç olmama değildir.
```

ÖRNEK — TEMSİLİ AĞIRLIKLI PUAN

Aynı varlıkta 60 dakika içinde seçilmiş sinyallere 2, 3, 3, 1 ve 4 puan verildiğini varsayalım. Toplam 13'tür. Bu örnek politikada 6–8 orta, 9 ve üzeri yüksek öncelik sayılır. Adımlardan biri eksik olsa da toplam eşik aşılabilir. Bu, sıralı korelasyondan ayrı bir karar modelidir; puanlar olasılık veya ölçülmüş güven değildir. Meşru diziler, yanlış eşleşmeler ve kaynak kapsamıyla birlikte sınanır.

5.6 Sıra: zinciri yakalamak

Sıra kalıbı, farklı olayların belirli bir sırada gerçekleşmesine bakar. Birden çok sinyalin birlikte görülmesi bağlam ekleyebilir. Ancak sıranın görülmesi kötü niyeti veya yüksek güveni tek başına kanıtlamaz; meşru zincirlerle birlikte sınanır.



Şekil 5.4 Temsili davranış dizisi ve bundan ayrı tasarlanan ağırlıklı risk toplamı.

Zincirin bileşenleri ayrı sinyaller olarak tutulabilir. Sıralı korelasyon bunların belirli varlık, sıra ve süreyle gerçekleşmesini arar. Bir halkası eksik zincir bu koşulu sağlamayabilir; kalan sinyallerin yine eşleşmesi veya başka bir korelasyonun devreye girmesi ayrı test edilir.

Pencere, hedeflenen olay dizisinin zaman koşuludur. Aralığa sığmayan bir dizi kaçabilir; geniş aralıkta ilgisiz olaylar birleşebilir. Aynı örnekleri farklı pencerelerde sınarken sıra, gecikme, tekilleştirme, yanlış birleşme ve kaçırılan varyantı birlikte kaydedin.

ÖRNEK — AĞIRLIKLI RİSK TOPLAMINI YORUMLAMAK

Şekil 5.4'teki temsili ağırlıklar 2 + 3 + 3 + 1 + 4 = 13 verir. Bu örnek politikada 6–8 puan orta, 9 ve üzeri yüksek önceliktir. Puan, olasılık veya ölçülmüş güven düzeyi değildir.

Sıralı korelasyon ve risk toplamı farklı kararlar verir. Toplam eşik bazı adımlar eksik olsa da aşılabilir; olay sırası yalnız toplama bakarak anlaşılmaz. Hangi modelin kullanılacağı hedef davranışa, meşru zincirlere ve yerel test sonuçlarına göre seçilir.

5.7 Sapma: normalden uzaklaşma

Sapma kalıbı, gözlenen davranışı bir geçmiş dağılımla karşılaştırır. "Bu kullanıcı olağan günlük sayının on katı dosyaya erişti" bunun bir örneğidir. Sayısal farkın anlamı iş bağlamına ve modelin geçerliliğine bağlıdır.

Sapma tespitinde açıklanabilirlik, dağılım değişimi ve yeni varlığın verisi ayrıca değerlendirilir. Analist, hangi değerin hangi referanstan ayrıldığını görebilmelidir. Referans değişince model yeniden sınanır. Yeni varlıkta geçmiş yetersizse belirsizlik yazılır; uygun grup referansı veya ayrı kabul koşulu seçilir.

Sapma fikrini önce açıklanabilir bir hesapla sınamayı öneriyorum. Ortanca ve IQR bir başlangıç olabilir; hangi dağılım ve dönemde anlamlı olduklarını ölçmek gerekir. Örneğin sıfır IQR, seyrek veri ve değişen iş takvimi için ayrı davranış tanımlayın. Bu tercih her ortamda yeterli sonuç vereceği iddiası değildir.

SAPMA — ADAY GÜN GEÇMİŞTEN AYRI

```
index=file_access earliest=-30d@d latest=@d
| bin _time span=1d
| stats count AS olay_sayisi BY user _time
| eval aday=if(_time=relative_time(now(),"-1d@d"),1,0)
| eval gecmis=if(aday=0,olay_sayisi,null())
| eventstats median(gecmis) AS ortanca p75(gecmis) AS q3
          p25(gecmis) AS q1 count(gecmis) AS gecmis_gun BY user
| where aday=1 AND gecmis_gun>=7
| eval iqr=q3-q1, esik=ortanca+3*iqr
| where olay_sayisi>esik AND olay_sayisi>50
| eval aciklama="geçmiş ortanca=".ortanca.", dün olay=".olay_sayisi
# Erişim OLAYI sayılır; benzersiz dosya sayısı değildir.
# Olay olmayan günler ayrıca sıfırla doldurulmadı: aktif gün baseline'ı.
# Zaman dilimi, sıfır günler ve örnek eşikler üretimde ayrıca seçilir.
```

aciklama alanı, sayılan şeyin olay mı yoksa benzersiz dosya mı olduğunu da söylemelidir. Örnekte dosya erişim olayları sayılır. Aday günün değeri, yalnız geçmiş günlerden hesaplanan ortanca ve IQR ile karşılaştırılır.

Makine öğrenmesi, modelin bazı özelliklerini veriden kurmak için kullanılabilir. Kuralı işleten kişi model kapsamını, verisini, karar nedenini ve hata davranışını anlayabilmelidir. Aşağıdaki üç soru değerlendirmeyi başlatır.

Modeli hangi verinin ve öğrenme döneminin kurduğunu yazın; öğrenme verisinin etkilenmesi kararları bozabilir. Bunun kapsamı modele bağlıdır. Doğrulamada model sürümünü, özellikleri ve veriyi sabitleyin. Yeniden eğitim veya rastgelelik varsa koşular değişebilir; aynı sabit modelin her çalışmada farklı sonuç vereceğini varsaymayın.

Model sinyalini alarm, av veya risk değerlendirmesinde kullanırken kabul koşulunu açık yazın. Açıklanabilirlik ve yerel etiketli sonuçlar, araştırma sırasında önemlidir. Her modelin aynı katmanda veya yalnız zenginleştirme olarak çalışması gerektiğini varsaymıyorum.

5.8 Kalıp seçmek ve birleştirmek

Bir tespit fikri genelde birden çok kalıpla ifade edilebilir ve seçim, elinizdeki veriye ve kabul edebileceğiniz bakım yüküne bağlıdır. Aynı tehdit için üç farklı kalıbın nasıl kurulacağını görmek, seçimin nasıl yapıldığını en iyi anlatan örnektir.

> **ÖRNEK — CERTUTIL İNDİRMESİ İÇİN ÜÇ YAKLAŞIM**
>
> Eşleşme, certutil ve -urlcache metnini arar. İlişki, buna gerçek ebeveyn bağlamını ekler. Nadirlik, certutil'in geçmiş kullanımını karşılaştırabilir; bu da araç adına bağlıdır. Araçtan bağımsız nadirlik istiyorsanız bütün süreçler, ağ hedefleri veya indirme davranışı üzerinde ayrı model kurun. Başka araca geçildiğinde certutil kuralının ayakta kaldığı söylenemez.

Burada tek bir ideal kalıp dağılımı önermiyorum. Hedef davranış için en anlaşılır ve sürdürülebilir yaklaşımı seçin; gerekirse farklı kalıpları birlikte kullanın. Kütüphane sağlığını kalıp sayısından değil, veri yeterliliği, doğrulanmış varyantlar ve bakım sonuçlarından değerlendirin.

> **KALIP ETİKETİ ENVANTER BİLGİSİDİR**
>
> pattern.* etiketleri hangi yaklaşımların kullanıldığını saymaya yardım eder. Dağılım tek başına olgunluğu veya atlatmaya dayanıklılığı göstermez. Bu sonuçlar için veri gereksinimi, varyant ve atlatma testlerinin kanıtı gerekir.

Bir sonraki bölümde kuralın hedeflediği davranışı ATT&CK ile adlandıracağız. Etiket, mantığın yerini almaz; kapsama raporunu kanıtla birlikte okunur hâle getirir.

BÖLÜM 06

ATT&CK Eşleme ve Kapsama

> *Bir kütüphanenin neyi kapsadığını söyleyebilmek için ortak bir dile ihtiyaç var. Bu bölüm MITRE ATT&CK'e eşlemenin disiplinini, kapsama haritasının üç katmanını, kapsama yüzdesinin neden yanıltıcı bir metrik olduğunu ve hangi tekniğe önce çalışılacağına nasıl karar verildiğini ele alır.*

6.1 ATT&CK'i doğru okumak

MITRE ATT&CK saldırgan taktik ve tekniklerini ortak adlarla ele almamızı sağlar. Kuralı bu sözlükle adlandırmak kapsama konuşmasını kolaylaştırır. Etiketi tamamlanmış kontrol olarak okumayın: hangi davranışın, hangi veri ve kanıtla görüldüğünü de gösterin.

Baştan netleştirilmesi gereken üç şey var. **ATT&CK bir öncelik sıralaması sunmaz.** Katalogdaki tekniklerin hepsi eşit önemde ya da eşit olası sayılmaz; hangisinin sizin için önemli olduğunu ATT&CK söylemez, tehdit profiliniz söyler. **Kapsanmayan her teknik bir eksik sayılmaz.** Ortamınızda macOS yoksa, macOS tekniklerini kapsamamanız bir boşluk değildir. **Ve en önemlisi: eşleme bir doğrulama sayılmaz.** Bir kurala etiket yapıştırmak, o kuralın çalıştığını göstermez.



Şekil 6.1 Bir ATT&CK hiyerarşi örneği; etiket kanıtlanan davranışa göre seçilir.

Taktik amaç, teknik yöntem, alt teknik ise daha özel uygulamadır. Mantık belirli bir alt tekniği gösteriyorsa ona eşleyin. Yalnız genel davranış görünüyorsa, ayrıntı uydurmak yerine üst teknik veya gerekçeli eşleme boşluğu bırakın.

KONUK KATKI — ATT&CK SAYFASINI OKUMAK

Muhammed Faruk Koyuncu Tespit ve Müdahale Mühendisi

Bir tekniği test etmeye karar verdiğimde ilk baktığım şeylerden biri, o tekniğin gerçek saldırılarda nasıl kullanıldığı oluyor. Özellikle ATT&CK'teki Procedure Examples bölümünü ve oradaki APT grupları, campaign'ler veya malware örneklerini inceliyorum. Ardından mümkünse bunların dayandığı threat intelligence raporlarına gidiyorum.

Buradaki amacım ATT&CK'teki tekniği birebir teorik tanımından çalıştırmak değil; gerçek bir saldırganın aynı tekniği hangi yöntemlerle uyguladığını görmek. Aynı technique altında farklı grupların farklı implementation'ları varsa bunlar bana test varyantı oluşturmak için de fikir veriyor.

Bu yaklaşım testin gerçekçiliğini artırıyor. Ayrıca tekniği çalıştırdığımda hangi process, command line, registry, network veya başka telemetry'leri görmeyi beklemem gerektiği konusunda da daha iyi bir öngörü sağlıyor.

ATT&CK'i doğrudan bir payload repository gibi değerlendirmiyorum. Her teknik için "şu komutu çalıştır" şeklinde hazır bir test vermiyor. Buna karşılık Procedure Examples, sub-technique'ler ve özellikle Detection Strategy bölümleri benim için oldukça değerli. Technique Description ise daha çok davranışın amacını ve sınırlarını anlamak için işe yarıyor; tek başına payload oluşturmak için bazen fazla genel kalabiliyor.

Tekniği önceliklendirirken de yalnızca ATT&CK'te bulunmasına bakmıyorum. Gerçek saldırılarda ne kadar kullanıldığı, bizim environment'ımızla ne kadar ilgili olduğu, gerekli telemetry'nin elimizde olup olmadığı ve mevcut detection setimizde o davranış için bir coverage gap bulunup bulunmadığı benim için daha belirleyici oluyor.

Yani kabaca yaklaşımım şu şekilde oluyor: önce gerçek saldırgan davranışını anla, sonra bunu bizim ortamda güvenli şekilde reproduce et, hangi telemetry'yi üretmesi gerektiğini belirle ve en sonunda mevcut detection'ın bunu gerçekten görüp görmediğini test et.

6.2 Eşleme disiplini

Eşleme kolay göründüğü için özensiz yapılır ve özensiz eşleme, kapsama haritasını sessizce yanlışlar. Sahada gördüğüm üç yaygın hata var.

Fazla eşleme. Bir kurala ilgisi olabilecek her tekniği etiketlemek. Office'ten doğan PowerShell'i yakalayan bir kurala `T1059.001` doğru, `T1566` (phishing) ise spekülatiftir; kural phishing'i yakalamıyor, phishing'in olası bir sonucunu yakalıyor. Fazla eşleme, kapsama haritasını olduğundan geniş gösterir.

Eşleme davranışa dayanmalı. Certutil -urlcache ile dosya indirme T1105 kapsamında değerlendirilebilir. Certutil'in imzalı olması bu işlemi T1218 yapmaz; 52avig execution için ayrıca yürütme davranışı gerekir. Decode kullanımı ise T1140 ile ayrı incelenir.

Teknik ve alt teknik seviyesini tutarlı kullanın; fakat sırf bir alt teknik mevcut diye onu seçmeyin. Kaydın gösterdiği davranış o ayrıntıyı desteklemelidir.

ETİKET — DAVRANIŞ İÇİN SEÇİM PARÇASI

```
tags:
  - attack.execution
  - attack.t1059.001
  - pattern.relationship
  - platform.windows
# T1218.011 ancak rundll32 proxy execution mantığı varsa eklenir.
# Taktik/teknik ilişkisi v19.2 envanterinden ayrıca incelenir.
```

ETİKETİ ENVANTER VE DAVRANIŞLA KONTROL EDİN

Kural mantığı ATT&CK etiketini kendiliğinden doğrulamayabilir. Pakette kimliğin sabit envanterde bulunması ayrıca denetlenir; geçersiz kimlik reddedilebilir. Mevcut bir tekniğe ait etiketin davranışa uygunluğu ise kanıt ve insan incelemesi ister.

6.3 Kapsama haritasının üç katmanı

Bölüm 2.11'de veri kapsamasının üç katmanda daraldığını görmüştük. Tespit kapsaması da benzer biçimde katmanlıdır ve bu katmanları ayırmadan çıkarılan harita, kendinize anlattığınız bir hikâyeye dönüşür.

SEÇİLMİŞ VARYANTLAR İÇİN TEMSİLİ KAYIT

Kontrol	Varyant A	Varyant B	Varyant C
Gerekli veri	Mevcut	Kısmi	Yok
Etkin hedef kuralı	Mevcut	Mevcut	Yok
Güncel revizyon + varyant kanıtı	Mevcut	Yok	Yok

Her sütun seçilmiş bir varyanttır. "Mevcut", ATT&CK tekniğinin bütün uygulamalarını kapsamaz.

Şekil 6.2 Seçilmiş varyantlar için temsili veri, etkin kural ve kanıt kaydı.

Birinci katman veri yeterliliğidir. V19.2 Detection Strategies ve Analytics açıklamalarından başlangıç gereksinimleri çıkarılabilir; gerçek alanlar, olay kapsamı ve varlıklar kendi envanterinizden doğrulanır. Bu satır bir teknik etiketinden kendiliğinden dolmaz.

İkinci katman, ilgili davranışı hedefleyen kuralın varlığı ve hedefteki etkin durumudur. Bu katman dosya envanterini gösterir; doğrulama kanıtı ayrı izlenir.

Üçüncü katman doğrulamadır. Hangi kural revizyonu, hangi varyantı, hangi veriyle ve ne zaman yakaladı? Kontrollü emülasyon, replay veya doğrulanmış olay bu kaydı besleyebilir. Başarılı bir varyant testi bütün tekniğin kapsandığı anlamına gelmez.

KAPSAMA — ÇALIŞAN PAKET MODÜLÜNÜ KULLANMAK

```
import json
from pathlib import Path
from tools.kapsama import layer

priority = json.loads(Path("contracts/priority-techniques.json").read_text())
result = layer("rules", priority, "2026-10-06", max_age=90)
Path("layer.json").write_text(
    json.dumps(result, ensure_ascii=False, indent=2), encoding="utf-8")
# Tam toplama ve başarı politikası: tools/kapsama.py + tools/core.py.
# Katman v4.5; domain ve 54avigatör sürümü dâhil.
```

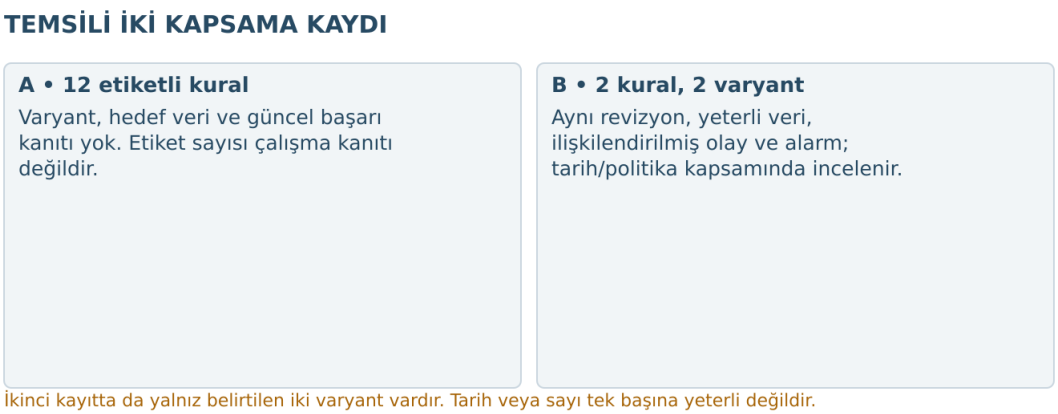
Betik öncelikli teknik listesini temel alır; kuralsız teknikleri de gösterir ve aynı tekniğe bağlı bütün kuralları korur. Güncel başarı, mevcut telemetri ve aynı revizyon gerekir. Son test ile son başarılı doğrulamanın koşu, varyant, kapsam ve kanıt bilgileri de tutarlı olmalıdır. Harita yalnız belirtilen varyantı gösterir; ham kanıtın veya veri envanterinin yerine geçmez.

6.4 Kapsama yüzdesi neden yanıltıcı

“ATT&CK kapsamamız %78” gibi bir oran, payda ve ölçüm tanımı yazılmadığında belirsizdir. Hangi platformlar, teknikler, varyantlar ve kanıt düzeylerinin sayıldığını görmeden oranı yorumlayamayız.

Payda, değerlendirdiğiniz platform ve tehdit kapsamına dayanmalıdır. Öncelikli teknik listesini tarih ve gerekçesiyle belirleyin; kapsam dışı platformları ve henüz veri bulunmayan davranışları ayrı gösterin. Kurum ihtiyacı incelenmeden bütün Enterprise matrisini tek bir oranla özetlemek yanıltabilir.

Bir tekniğe kural bağlamak, tek başına başarılı tespit kanıtı değildir. Etiket sayısını artırmak rapordaki oranı büyütebilir; veri yeterliliği ve güncel varyant testi yoksa bu artışın savunmaya katkısını bilmiyoruz.



Şekil 6.3 Temsili iki kayıt: sayı ve tarihin yanında revizyon, varyant ve kanıt gerekir.

Teknikleri eşit ağırlıkla saymak önceliği gizleyebilir. Gerçekleşme olasılığı ve etkiyi kurum verisiyle değerlendirin; veri ve bakım maliyetini de ekleyin. Çok sayıda düşük öncelikli kutuyu boyamak, kritik bir boşluğu kapatmakla aynı sonuç değildir.

Daha anlamlı üç gösterge öneriyorum: başarılı varyantı bulunan teknik sayısı, öncelikli teknik listenizde bu kanıta sahip olanların oranı ve doğrulamanın yaşı. Her sayının yanında varyantı, kural

revizyonunu ve kanıt kapsamını gösterin. Bir varyantın başarısı tekniğin bütün uygulamalarını kapsadığımız anlamına gelmez.

> **PAYDAYI VE VARYANTI BİRLİKTE GÖSTERİN**
>
> Öncelikli teknik listenizi tarih ve gerekçesiyle tanımlayın. Temsili bir rapor, "öncelikli 42 tekniğin 27'sinde en az bir güncel başarılı varyant kaydı var" diyebilir. Yanına varyantlar, revizyonlar ve sınırlar eklenir. Bu sayılar gerçek bir kurum ölçümü değildir; 27 tekniğin bütün uygulamalarının kapsandığını da söylemez.

6.5 Hangi tekniğe önce

Kapsama boşluklarınızı gördünüz; hepsini birden kapatamayacağınıza göre bir sıralama gerekiyor. Bu sıralamayı boşluğun kendisine bakarak yapmak yaygın bir hatadır. Doğru okuma, boşluğu tehdit profiliyle birlikte değerlendirmektir.



Şekil 6.4 Önerilen öncelik matrisi; olasılık, etki ve maliyet kurum verisiyle değerlendirilir.

Önceliklendirmede dört bilgi kaynağını birlikte kullanabiliriz. Hiçbiri tek başına kesin olasılık vermez; güncelliğini, kapsamını ve kurumla ilişkisini ayrı değerlendirin.

Kaynak	Sunduğu bağlam	Sınır
Kurum olayları	Gerçek etki ve görülen davranış	Geçmiş, görünür olaylarla sınırlıdır
Av bulguları	Yerel veri ve şüpheli örüntü	Hipotez ve etiket doğrulanmalıdır
Tehdit istihbaratı	Aktör ve davranış bilgisi	Güncellik ve kurum ilişkisi değişebilir
Sektör raporları	Daha geniş gözlem	Örneklem bütün sektörü temsil etmeyebilir

Bir başka ölçüt, aynı veri yatırımıyla görülebilecek öncelikli davranışlardır. Süreç oluşturma telemetrisi birden çok tespiti besleyebilir; fakat bir kaynağın varlığı bütün taktiğin kapsandığı anlamına gelmez. Kazanımı tek tek davranış ve doğrulama üzerinden hesaplayın.

BOŞLUKLARI KAPATIRKEN ORTAK KAYNAK İHTİYACINI ARAYIN

Aynı telemetri, ayrı ayrı doğrulanan birden çok davranış için kullanılabilir. Bu bir yatırımı paylaşma fırsatıdır; toplam maliyet ve kapsanan varyantlar ayrıca ölçülür. Yeni kaynak isteyen davranışı yalnız maliyeti yüksek diye aşağı koymayın. Olasılık, etki, mevcut açık ve kabul edilebilir gecikmeyle birlikte önceliklendirin.

6.6 Kapsamayı yaşayan bir şey olarak tutmak

Kapsama haritası ortamla birlikte değişmelidir. Kaynak, kural revizyonu veya ATT&CK envanteri değiştiğinde kaydı güncelleyin. Aşağıdaki üç adımı otomatikleştirmeyi öneriyorum; insanın kapsam ve kanıt incelemesi yine gerekir.

Haritayı kural deposu, öncelikli teknik listesi, veri envanteri ve doğrulama kayıtları birlikte üretmelidir. Örnekte güncellik eşiği 90 gündür; kritik davranışlarda daha kısa seçilebilir. Son koşu başarısızsa veya kural değişmişse eski başarıyı bugünkü doğrulama gibi göstermeyin.

Doğrulamanın yaşını göstermek haritada daha çok belirsizlik çıkarabilir. Bu, bakım ihtiyacını görünür kılar. Yeniden test dönemi kuralın riski, veri değişimi ve kurumun kabul politikasına göre belirlenir.

BAŞARILI DOĞRULAMA KAYDI

x_last_test her koşuyu, x_last_successful_validation son başarıyı taşır. Alanlar doğru türde doldurulur. Güncel kabul için iki kayıt aynı başarılı koşunun tarih, kimlik, revizyon, yöntem, varyant, teknik listesi ve kanıtını tutarlı göstermelidir. Missed/no_data eski başarıyı güncel yapmaz. Kayıt tutarlılığı, kanıtın gerçekliğini bağımsız olarak doğrulamaz.

Yazmak kısmı tamamlandı. Kitabın üçüncü kısmı Doğrulamak ile devam ediyor: önce birim testleri ve regresyon, sonra gerçek telemetri üzerinde uçtan uca doğrulama.

BÖLÜM 07

Testi Kurmak

> *Kitabın üçüncü kısmı burada başlıyor. Buraya kadar kural yazmayı anlattık ve çalıştıklarını varsaydık. Bu bölüm o varsayımı kaldırıyor: bir tespitin nasıl test edileceğini, sentetik veriyle birim testin nasıl kurulduğunu, regresyonun neyi yakaladığını ve bir kuralın üretime çıkmadan hangi kapılardan geçmesi gerektiğini ele alıyor.*

7.1 Varsayımı kaldırmak

Test edilmemiş bir tespitin neyi gördüğünü bilmiyoruz. Bu bölümde kuralın hangi veri ve koşullarda çalıştığını sınamaya geçiyoruz.

Bazı arızalar derleme veya çalışma hatası üretir; bazıları ise yalnız eşleşmemeye yol açar. Yanlış alan, eksik veri veya geniş dışlama ikinci grupta kalabilir. Test ve veri sağlığı izlemesi ikisini birlikte ele alır.

Test, belirli koşullarda kuralın eşleşip eşleşmediğini ayırır. Doğrulanmış olay incelemesi, ham telemetri kontrolü ve replay de sessizliğin nedenini anlamaya yardım eder. Hiçbiri bütün bilinmeyen davranışları ortaya çıkarmaz.

SAHADAN NOT — "KURALIMIZ VARDI" CÜMLESİ

Bir olay sonrası retrospektifte en sık duyduğum cümlelerden biri: "ama bizim bunun için bir kuralımız vardı." Loglara bakıldığında kuralın aylardır hiç çalmadığı görülür. Sebep genelde basittir — bir alan adı değişmiş, bir dışlama fazla geniş yazılmış, ya da kural derlenirken bir modifier düşmüştür.

Bu cümlenin tersini söyleyebilmek için tek bir şey gerekiyor: "kuralımız var ve geçen hafta test ettiğimizde çaldı." İkisi arasındaki fark, bu bölümün tamamıdır.

7.2 Test piramidi

Testi burada dört düzeyde ele alıyorum: yapı, birim, hedef entegrasyonu ve emülasyon. Bunlar birbirini tamamlayan kontrollerdir; tek bir düzeyin geçmesi bütün tespitin kabul edildiğini göstermez.



Şekil 7.1 Dört test düzeyinin kanıt kapsamı; sıklık ve maliyet yerel plana bağlıdır.

Şema kontrolü, dosya türünü ve alanların yapısını denetler. ATT&CK kimliğinin envanterde varlığı ve depo metadata politikası ek kontrollerdir; etiketin davranışa uygunluğu da inceleme ister. Kontroller her değişiklikte otomatik çalıştırılabilir.

Bu kitapta birim testi, seçilmiş mantığı sentetik olaylarla yerel Python ortamında sınar. Canlı SIEM veya olay üreten Windows laboratuvarının yerini tutmaz; süresi örnek sayısına ve araca bağlıdır. Hedef entegrasyonu, gerçek alan ve sorgu davranışını; emülasyon ise belirli yürütme–olay–alarm zincirini ayrıca sınar. Bu bölüm yerel testleri, Bölüm 8 emülasyonun nasıl yürütüleceğini ele alır.

Birim ve yapı kontrollerini sık, hedef replay ve emülasyonu ihtiyaç ve riskle uyumlu çalıştırmayı öneriyorum. Maliyetleri kurumda ölçülür. Birim testi ile emülasyon farklı arızaları gösterdiğinden birinin geçmesi diğerini gereksiz yapmaz.

Düzey	Kontrol örneği	Kanıtlamadığı	Önerilen tetikleyici
Yapı	Sözdizimi ve alan türü; ek envanter politikası	Davranışa uygun mantık	Her değişiklik
Birim	Seçilmiş pozitif/negatif ve sınır fixture'ları	Gerçek hedef alanı ve yürütme	Her değişiklik
Hedef entegrasyonu	Gerçek veri, çeviri, alan ve pencere	Test edilmeyen davranış varyantı	Hedef/kaynak değişimi
Emülasyon	Belirli varyantın yürütme–olay–alarm zinciri	Test edilmeyen varyantlar	Risk ve değişime göre

7.3 Birim testi: iki tür örnek

Bir kuralın birim testi, kural mantığını elle hazırlanmış olaylar üzerinde koşturmaktan ibarettir. Kritik nokta, iki tür örneğin birden gerekmesidir.



Şekil 7.2 Seçilmiş pozitif ve negatif fixture'ların beklenen sonucu.

Pozitif fixture tek başına yeterli değildir. Her kaydı eşleştiren bir koşul da pozitif örneği geçebilir. Eşleşmemesi beklenen seçilmiş örnekler ekleyin; bunların geçmesi yalnız o örneklerin sonucunu gösterir. Gerçek meşru işlerin tamamına dair sonuç için hedef ölçümü gerekir.

falsepositives alanındaki meşru senaryolar iyi test adaylarıdır. Ancak benign true positive, kuralın doğru eşleştiği meşru davranış olabilir. Dışlama tasarlanmadıysa ondan negatif sonuç beklemek yanlış olur. Her fixture'da expected değerini kuralın açık kapsamına göre yazın.

FIXTURE — UUID İLE BAĞLANAN AÇIK BEKLENTİ

```
cases:
  - name: Word doğrudan kodlanmış PowerShell başlatıyor
    rule_id: 4f2a91c7-6b0e-4d31-9a52-1c7e5f8b2d64
    expected: true
    event:
      ParentImage: 'C:\Program Files\Office\winword.exe'
      Image: 'C:\Windows\System32\powershell.exe'
      CommandLine: 'powershell.exe -enc SQBFAFgA'
  - name: Office ebeveyni yok
    rule_id: 4f2a91c7-6b0e-4d31-9a52-1c7e5f8b2d64
    expected: false
    event:
      ParentImage: 'C:\Windows\explorer.exe'
      Image: 'C:\Windows\System32\powershell.exe'
      CommandLine: 'powershell.exe -enc SQBFAFgA'
# Tam varyant ve eksik alan örnekleri aynı isimli .test.yml içindedir.
```

Burada test dosyasını kuralın yanında tutuyorum. Başka bir dizin düzeni de UUID ile güvenilir bağlantı kurulursa kullanılabilir. Bağlantıyı yalnız dosya gövde adına göre kurmayın; farklı dizinlerde aynı ad bulunabilir.

DİKKAT — SENTETİK OLAYIN SINIRI

Fixture'da Image gerçek kaynakta olduğu gibi tam yol taşımalıdır. Anonimleştirilmiş güncel kayıt iyi bir şablondur; fakat tek şablon bütün kaynak ve sürümlerin gerçekçiliğini garanti etmez. Eksik alan, farklı olay sürümü ve parser değişimini ayrı örneklerle sınayın.

7.4 Testi çalıştırmak

Test dosyaları tek başına bir şey yapmaz; onları koşturan bir çalıştırıcı gerekir. Mantık basittir: kuralı yükle, olayı yükle, eşleşip eşleşmediğine bak, beklenenle karşılaştır.

BİRİM TESTİ — TANIMLI MATCHER İLE

```
import json
from tools.test_rules import run

result = run("rules")
print(json.dumps(result, ensure_ascii=False, indent=2))
if not result["passed"]:
    raise SystemExit(1)
# Tam çalıştırıcı tools/test_rules.py; motor tools/matcher.py.
# Fixture kimliği UUID; office.ps.yml → office.ps.test.yml.
# Korelasyon için bu motor kullanılmaz.
```

Çalıştırıcı kuralı UUID ile seçer, noktalı dosya adını doğru korur ve eksik test dosyasını raporlar. Tek olay testleri pySigma'nın ayrıştırdığı AST üzerinde çalışır. Korelasyon ve hedef motor davranışı bunun dışında kalır; desteklenmeyen özellik sessizce geçmez.

Yerel matcher, pakette belirtilen tek olay düğümlerini uygular; cased harf duyarlı eşleşmeyi, exists ise null dâhil anahtar varlığını sınar. Desteklenmeyen düğüm hata verir. Bu tam Sigma/SIEM motoru değildir. Korelasyonun zaman, pencere ve tekilleştirme davranışı hedefte sınanır.

7.5 Regresyon: değişikliğin görünmeyen etkisi

Mevcut kurala dışlama eklemek, regresyon testinin önemli kullanım alanlarından biridir. Önceki pozitif varyantların kaybolmadığını ve meşru eşleşmelerin beklendiği gibi değiştiğini aynı kümede kontrol edin.



Şekil 7.3 Temsili bir dışlama değişikliğinin regresyon örneklerine etkisi.

Şekil 7.3 temsili bir regresyonu gösteriyor: gürültüyü kesen geniş bir dışlama, pozitif senaryoları da silebilir. Buradaki sayılar bir saha ölçümü değildir. Dışlama değiştiğinde korunması gereken varyantları yeniden test etmek, bu kaybı görünür kılar.

Regresyon testi bu etkiyi değişiklik anında görünür kılar. Dışlama eklendiğinde test paketi çalışır ve iki pozitif örneğin artık eşleşmediğini söyler. Mühendis o anda üç seçenekten birini bilinçli olarak seçer: dışlamayı daraltmak, etkilenen senaryolar için ayrı bir kural yazmak, ya da kaybı kabul edip kuralın açıklamasına yazmak. Üçü de meşrudur; körü körüne devam etmek değildir.

> **DIŞLAMAYI DARALTMA PLANI**
>
> Servis hesabı önekini bütünüyle dışlamak yerine, doğrulanmış hesap kimliği ile onaylı işin gerçek bağlamını birlikte kullanmayı deneyin. Dosya yolunun komut satırında geçmesi tek başına onay kanıtı değildir. Bölüm 9.5'teki doğrulanmış yük hash'i ve ebeveyn bağlamı gibi daha dar koşullar uygulanabilir. Bu bir tasarım örneğidir; burada iki testin geçtiği veya belirli sürede gürültünün kesildiği iddia edilmez.

7.6 Üretime çıkan yol

Testler tek tek anlamlıdır ama asıl değeri bir hatta dizildiklerinde üretirler. Bir kuralın fikirden üretime giden yolu, üzerinde bilinçli kapılar olan bir hat olarak kurulmalıdır.



Şekil 7.4 Üretim kabulü için yedi kapı. İlk üçü otomatikleştirilebilir; çalışma süresi ortama bağlıdır.

Şema, derleme ve birim testi otomatikleştirilebilir. Mantığın amacını, kapsamını ve dışlamasını ikinci bir kişi de okumalıdır. Bunların ardından gerçek hedefte replay ve emülasyon, gölge ölçümü ve üretim kabulü gelir. Otomatik kontrollerin geçmesi, sonraki kapıları tamamlamış sayılmaz.

Kapı	Kontrol	Sorumlu
Şema	Doğru tür/alan, ayrı depo politikası	Otomatik
Derleme	Hedef özellik ve alan desteği	Otomatik
Birim testi	Açık pozitif/negatif beklentiler	Otomatik
İnceleme	Mantık, sınır, dışlama ve yanıt	İkinci göz
Hedef ve emülasyon	Gerçek veri/alarm ile uçtan uca kanıt	Kontrollü koşu
Gölge	Çalışan kuralın eşleşme ve operasyon yükü	Ölçüm
Üretim	Kanıt, sahiplik ve geri alma	Kabul kararı

Gölge aşamasında kural çalışır ve eşleşmeler saklanır; operasyon kuyruğuna bildirim gönderilmez. Bunun için ayrı bir alan/indeks veya ürünün uygun ölçüm mekanizması gerekir. enabled=false çalıştırmayı durdurur. status etiketi tek başına gölgeyi kurmaz.

CI — EŞLİKÇİ PAKET İÇİN TAM İŞ AKIŞI

```
name: dwell-dogrulama
on: [pull_request, workflow_dispatch]
jobs:
  check:
    runs-on: ubuntu-24.04
    steps:
      - uses: actions/checkout@v4
      - uses: actions/setup-python@v5
        with:
          python-version: '3.12'
      - run: python -m pip install -r requirements-lock.txt
      - run: python -m tools.sema_kontrol rules --as-of 2026-10-07
      - run: python -m tools.test_rules rules
      - run: python -m tools.derle
      - run: python -m pytest tests -q
```

7.7 Testin sınırları

Bölümü dürüst bir uyarıyla kapatmak gerekiyor, çünkü test bir güvence duygusu üretir ve o duygu hak edilmemişse tehlikelidir.

Birim testi yalnızca düşündüğünüz senaryoları kapsar. Yazdığınız pozitif örnekler, saldırganın kullanabileceği varyantların tamamı sayılmaz; testiniz geçtiğinde kuralınızın çalıştığını değil, *düşündüğünüz durumlarda* çalıştığını bilirsiniz. Bölüm 4.9'daki "kuralı ters okumak" alışkanlığı, test örneklerini genişletmenin en pratik yoludur.

Sentetik olay, gerçek telemetri sayılmaz. Bir kural birim testini geçip üretimde hiç çalmayabilir, çünkü gerçek kayıtta o alan hiç dolmuyordur. Bunu yakalayan şey entegrasyon testi ve Bölüm 2.10'daki alan doluluk izlemesidir.

Ve testin kendisi çürür. Test örnekleri de kurallar gibi eskir; ortam değiştiğinde gerçekçiliğini kaybederler. Yılda bir kez test örneklerini üretimden alınmış güncel kayıtlarla tazelemek, kütüphane bakımının parçası sayılmalıdır.

ÖRNEK — BİRİM TESTİ GEÇERKEN HEDEF BOZULABİLİR

Kuralların baktığı indeksin taşındığını düşünün. Mantık doğru kaldığı için sentetik birim testleri geçebilir; hedef sorgu ise boş indekste çalışır. Gerçek veri üzerinde entegrasyon testi, veri sağlığı kontrolü ve emülasyon bu farklı arızayı sınar. Bu kutu ölçülmüş bir vaka veya yakalama yüzdesi sunmuyor.

Bir sonraki bölüm, bu testleri gerçek telemetriye bağlayacak: atomik varyantlar, Caldera koşuları, gecikme ve sonuç kaydı.

BÖLÜM 08

Adversary Emulation

> *Test piramidinin tepesine geldik. Bu bölüm tekniği gerçekten çalıştırıp tespitin çalıp çalmadığını gözle görmeyi ele alıyor: atomik testlerden Caldera ile tam zincir emülasyonuna, tespit gecikmesinin ölçülmesine, bulgunun kurala çevrilmesine ve emülasyonu güvenli yürütmeye kadar.*

8.1 Emülasyon ne sorar

Adversary emulation, saldırganın yaptığı işleri kontrollü biçimde yapıp savunmanın bunları görüp görmediğini ölçmektir. Sözcük benzerliği yüzünden sızma testiyle karıştırılır, oysa ikisi farklı soru sorar ve farklı çıktı üretir.

ÜÇ FAALİYETİN ÖRNEK SORULARI

Faaliyet	Sorulabilecek soru	Örnek çıktı
Sızma testi	Zafiyet hangi erişim/etkiyi sağlıyor?	İstismar ve etki kanıtı
Saldırgan emülasyonu	Seçilmiş davranış yürüdü ve görüldü mü?	Yürütme, ham olay, savunma sonucu
Purple team	Savunmayı birlikte nasıl geliştiriyoruz?	Paylaşılan test, düzeltme ve yeniden ölçüm

Amaçlar ve çıktılar örtüşebilir; tespit ekibi gerekli soruya göre bu faaliyetlerden yararlanır.

Şekil 8.1 Üç faaliyetin örnek soruları; hangi sonuç gerektiğine göre seçilir.

Sızma testi, istismar edilebilir zafiyetleri ve bunların etkisini araştırabilir. Saldırgan emülasyonunda ise seçilmiş davranışların yürütülmesini, üretilen telemetriyi ve savunmanın tepkisini birlikte ölçüyoruz. İkisinin de bulguları savunmayı geliştirebilir. Komutun yürütülmesi ile tespitin başarıyla çalışması ayrı sonuçlardır.

Emülasyonda gizlenme de test konusu olabilir. Basit görünür bir varyantla toplama hattını doğruladıktan sonra daha sessiz veya farklı varyantlar denenebilir. Amaç, önceden yazılmış kapsam için savunmanın ne gördüğünü ve ne kaçırdığını ölçmektir.

8.2 Atomik testler: en küçük birim

Atomik testler, belirli davranışı kontrollü olarak üretmek için küçük bir başlangıç sağlayabilir. Atomic Red Team'de ön koşul ve cleanup bilgileriyle testler bulunur. Her testi kendi kapsamı ve yan etkileriyle okuyun; tek test bütün tekniği temsil etmez.

Atomik test tekrarlanabilir bir başlangıç verir; aynı komutun ürettiği olaylar yine işletim sistemi, izinler, politika ve araç sürümüne bağlıdır. Karşılaştırma yaparken bu koşulları da kaydedin.

RUNDLL32 — LABORATUVAR KOMUT PLANI

```
# emulation/dwell_test.c: zararsız DwellTest export'u.
# MSVC x64 ortamında derlenir; Windows'ta ayrıca çalıştırılır.
# 1. DLL'nin doğrudan çağrılması
rundll32.exe "C:\DwellLab\dwell_test.dll",DwellTest
# 2. Boşluklu yoldan aynı export
rundll32.exe "C:\DwellLab\path with spaces\dwell_test.dll",DwellTest
# 3. Farklı uzantılı PE dosyası; uzantısız olduğu iddia edilmez.
rundll32.exe "C:\DwellLab\payload.bin",DwellTest
# Dosyaları oluşturan/temizleyen tam plan: emulation/rundll32_lab.ps1.
# Bu baskıda Windows native koşusu yapılmadı.
```

Varyantların amacı, kuralın dosya uzantısı gibi yüzey özelliklerine gereksiz bağlı olup olmadığını sınamaktır. Birim testinin geçmesi, DLL'nin hedef Windows'ta çalıştığını veya Sysmon olayının üretildiğini göstermez; bunlar ayrı koşu kanıtıdır.

SAHADAN NOT — VARYANT SAYISI KAPSAM KANITI DEĞİLDİR

Tek komutla başarılı test, yalnız o varyant için kanıttır. Üç varyant bir başlangıç önerisi olabilir; üçü geçince bütün teknik kapsandı denmez. Bayrak, gerçek ebeveyn, yol, hesap ve kaynak sürümündeki anlamlı değişiklikleri ayrı test edin.

KONUK KATKI — PAYLOAD VE VARYANT TASARIMI

Muhammed Faruk Koyuncu Tespit ve Müdahale Mühendisi

Benim için payload'dan önceki en önemli aşama hangi adversary behavior'ı, yani hangi ATT&CK technique veya sub-technique'ini test edeceğimizi doğru belirlemek.

Burada her zaman bir vulnerability olmak zorunda değil. ATT&CK'teki birçok technique normal sistem fonksiyonlarının veya meşru araçların adversary tarafından kötüye kullanılmasına dayanabiliyor. Eğer seçtiğimiz technique gerçekten exploitation tabanlıysa, o zaman ilgili vulnerability'yi, exploitation path'ini ve bunun gerçek saldırılardaki kullanım şekillerini ayrıca inceliyorum.

Technique'i belirledikten sonra mümkün olduğunca gerçek dünya procedure'larına bakıyorum. ATT&CK Procedure Examples, APT grupları, campaign'ler ve varsa ilgili threat intelligence raporları burada benim için önemli referanslar. Bilinen bir vulnerability veya attack path ise daha önce kullanılan exploitation yöntemlerini ve TTP'leri de inceliyorum.

Sonrasında tek bir payload ile test yapmak yerine aynı adversary behavior için birden fazla test variant'ı oluşturuyorum. Pratikte genellikle dört varyantla başlıyorum fakat dört benim için sabit bir sayı değil; technique'in implementation çeşitliliğine göre sayı değişebiliyor.

Bu varyantların bir kısmını mevcut detection'ın yakalamasını beklediğim baseline senaryolar olarak kullanıyorum. Buradaki amaç önce kuralın gerçekten hedeflediğimiz davranışı görebildiğini doğrulamak.

Diğer varyantlarda ise aynı adversary objective'i farklı implementation'larla gerçekleştiriyorum. Buradaki amaç bir sistemi yalnızca bypass etmek değil; detection'ın sınırını ölçmek. Yani kural gerçekten adversary behavior'ı mı tespit ediyor, yoksa yalnızca belirli bir command, process veya implementation'a mı bağımlı, bunu anlamaya çalışıyorum.

Örneğin aynı ATT&CK technique iki farklı yöntemle gerçekleştirildiğinde birinci varyant yakalanıp ikinci varyant yakalanmıyorsa, burada ikinci varyanta sadece "tespiti atlattı" diye bakmıyorum. Neden yakalanmadığını araştırıyorum. Telemetry farklı mı oluştu, ilgili event SIEM'e ulaşmadı mı, parsing/normalization problemi mi var, yoksa detection logic belirli bir implementation'a fazla mı bağımlı; bunları ayırmaya çalışıyorum.

> Testleri hazırlarken mümkün olduğunca her varyant için expected telemetry'yi de önceden belirliyorum. Böylece test sonunda yalnızca “alert geldi/gelmedi” sonucu çıkarmak yerine detection zincirinin hangi aşamada çalıştığını veya kırıldığını görebiliyorum.
>
> Eğer ATT&CK veya threat intelligence tarafında benzer bir procedure bulabilirsem varyantları oluştururken gerçek saldırgan davranışlarını referans alıyorum. Eğer yeterli bir procedure yoksa da technique'in davranışsal amacını koruyarak farklı execution yöntemleri ve telemetry yolları üzerinden test case'leri oluşturuyorum.

8.3 Caldera: kavramlar

Atomik testleri birden fazla makinede ve sırayla yürütmek için bir çatı kullanılabilir. MITRE Caldera bu seçeneklerden biridir. Burada beş temel kavramıyla ele alıyorum.



Şekil 8.2 Caldera kavramları: profile, ajan grubu, planner ve fact'lerle kurulan koşu.

Kavram	Nedir	Tespit mühendisi için anlamı
agent	Hedefte komutları yürüten ajan (ör. sandcat, manx)	Ajan kimliği ile gerçek host kimliği ayrı kaydedilir
ability	Seçilmiş davranışın yürütme tanımı	Komut, platform ve beklenen telemetri sınanır
adversary	Seçilmiş ability'leri ilişkilendiren profil	Koşu planının bir bileşeni
operation	Belirli ayarlarla yürütülen koşu	Yürütme, ham olay ve alarm bu koşuya bağlanır
planner	Uygun adımların yürütme kararlarını etkileyen mantık	Gerçek sıra ve seçim koşu kaydından incelenir

Caldera yürütme sonucunu raporlar. Tespit değerlendirmesinde ham telemetri ve SIEM alarmı ayrıca aranır: komutun dönmesi, olayın toplanması ve kuralın eşleşmesi üç ayrı sonuçtur.

8.4 Kendi ability'nizi yazmak

Hazır ability'ler ihtiyacınıza uymuyorsa seçtiğiniz varyant için bir yürütme tanımı yazabilirsiniz. YAML dosyası yalnız tanımı taşır; betiğin ajana aktarılması, fact'lerin çözülmesi, yetkiler, telemetri ve cleanup da sınanmalıdır.

CALDERA ABILITY — BENZERSİZ GÖREV ADI

```
- id: 7c1f4a92-3d5b-4e18-9a06-2f8c1b7e4d55
  name: Zamanlanmış görev oluşturma telemetrisi
  description: >-
    Görev oluşturma telemetrisi üretmek için laboratuvar planı.
    TASK_NAME koşuya özgü, daha önce olmayan bir ad olmalıdır.
  tactic: persistence
  technique:
    attack_id: T1053.005
    name: 'Scheduled Task/Job: Scheduled Task'
  platforms:
    windows:
      psh:
        command: |
          & '.\emulation\task_lab.ps1' -TaskName '#{dwell.task_name}' -Create
        cleanup: |
          & '.\emulation\task_lab.ps1' -TaskName '#{dwell.task_name}' -Cleanup
        parsers: []
# Tam betik, oluşturduğu nesnenin kaydını tutar; /f ile ezmez.
# Script yolu ve fact, kurulu Caldera/ajan ortamına aktarılmalıdır.
```

Bu kitabın koşu politikasında cleanup ve sonucunun kontrolü bulunur. Caldera'da cleanup isteğe bağlı bir özelliktir; kurumun kabulü ayrıca tanımlanır. Temizlenmeyen test nesneleri sonraki araştırmayı karıştırabilir. description içine hedeflenen davranışı ve varyantı yazın; yürütme başarısını sonradan kanıtla ekleyin.

ABILITY EŞLEMESİ TEST PLANI TAŞIR

İnsan tarafından okunabilir etiket ile ability UUID'sini ayırın; kalıcı eşlemeyi UUID üzerinden tutun. Bir kurala ability bağlamak test planını gösterir. Başarı için aynı koşunun yürütme, telemetri ve alarm kanıtı gerekir; eşleme tek başına kapsama doğrulaması değildir.

8.5 Bir koşuyu yürütmek

Bu kitapta koşuyu hazırlık, yürütme ve sonuç incelemesi olarak planlıyorum. Önce ability UUID'sini, kural revizyonunu, host kapsamını, beklenen ham olayı ve alarmı kaydedin. Başarı koşulunu sonuçları gördükten sonra değiştirmeyin.

Koşuda yürütme kimliği, gerçek host, ajan kimliği ve host üzerinde çalıştırma zamanı tutulur. Delegation zamanı, yürütme başlangıcı değildir; paw da makine adı değildir. SIEM alarmıyla ilişkilendirme yapılırken ortak koşu kimliği ve saat senkronizasyonu kullanılmalıdır.

KOŞU ÖLÇÜMÜ — AÇIK GİRDİ SÖZLEŞMESİ

```
import json
from pathlib import Path
from tools.kosu import measure

# Caldera ve SIEM adaptörünün normalleştirdiği dosya.
rows = json.loads(Path("fixtures/normalized_run.json").read_text())
result = measure(rows)
Path("run_result.json").write_text(json.dumps(result, indent=2))
# executed_at host yürütme zamanı; delegation zamanı değildir.
# host ile agent_id ayrı. Negatif gecikme ve eksik alan hata verir.
# Tam program: tools/kosu.py. API başlatma çağrısı içermez.
```

Eşlikçi kosu.py, sürüme özgü API çağrısı yerine normalleştirilmiş JSON okur. Kimlik alanları dolu metin, telemetry_present gerçek JSON boolean, gecikme hedefi sonlu ve negatif olmayan sayı olmalıdır. "false" metni kabul edilmez. Zamanlar saat dilimi taşır. Caldera ve SIEM ayrı adaptörlerle bağlanır; gerçek yürütme zamanı bilinmiyorsa gecikme uydurulmaz.

8.6 Sonucu ölçmek

Emülasyonun ürettiği asıl değer, ikili bir “yakaladı / yakalamadı” cevabı değildir. Ölçülecek üç şey vardır ve üçü de farklı bir eyleme yol açar.



Şekil 8.3 Temsili zaman kaydı: yürütmeden alarma 38, alarmdan açılmasına 142 saniye.

Tespit gecikmesi gerçek yürütme zamanı ile alarmın oluşturulması arasındaki süredir. Ajan, taşıma, indeksleme ve arama sıklığı bunu etkiler. Tek bir “normal” süre yoktur; hedefi tehdidin hızına ve hattın ölçülen gecikmesine göre koyun. Delegation’dan ölçülen süre başka bir metriktir.

Alarm kalitesi, alarmın Bölüm 3.4'teki eyleme dönüklük ölçütünü karşılayıp karşılamadığıdır. Kural çaldı ama alarm yalnızca “şüpheli aktivite” diyorsa, koşu tam olarak başarılı sayılmaz. **Sonuç kategorisi** ise koşunun hangi kutuya düştüğüdür.



Şekil 8.4 Paket ölçümündeki sonuç sınıfları; etiket kök nedeni belirlemez.

Veri yok sonucunda önce beklenen ham olayı arayın: doğru host, zaman, kaynak ve kimlik kullanıldı mı? Davranışın gerçekten yürütülmesi, olay üretimi ve toplama zinciri ayrı incelenir. Her veri eksikliğini doğrudan altyapıya atamayın.

ÖNCE YÜRÜTMEYİ VE HAM OLAYI, SONRA ALARMI İNCELEYİN

Alarmın gelmemesi tek başına kural hatası değildir. Önce hedef davranışın gerçekten yürütüldüğünü, sonra ham olayın üretimini ve merkeze erişimini kontrol edin. Ardından alanları, kural eşleşmesini ve alarm yönlendirmesini inceleyin. Bu adımlar sorunu daraltır; birden çok arıza birlikte bulunabilir. Görevi sonuç etiketine göre değil, eldeki kanıta göre ilgili sorumluya açın.

KONUK KATKI — ALARM GELMEDİĞİNDE ZİNCİRİ İZLEMEK

Muhammed Faruk Koyuncu Tespit ve Müdahale Mühendisi

Bir tekniği çalıştırdığımız hâlde detection tarafında beklediğimiz izi göremediğimiz birçok durum oldu. Fakat böyle bir durumda doğrudan "kural çalışmadı" sonucuna gitmiyorum. Öncelikle detection zincirinin hangi aşamada kırıldığını anlamaya çalışıyorum.

Örneğin Windows tarafında gerekli audit policy'lerinin aktif olmadığı durumlarla karşılaştık. Böyle bir durumda technique başarılı şekilde çalışmış olsa bile işletim sistemi bizim detection için ihtiyaç duyduğumuz telemetry'yi üretmiyordu. Benzer durumları Linux sistemlerde de yaşadık. Yani bazı testlerde problem detection rule'unda değil, telemetry generation aşamasındaydı.

Başka durumlarda ise log endpoint üzerinde oluşuyordu fakat collector veya forwarding tarafındaki bir problem nedeniyle SIEM'e ulaşmıyordu. Burada da rule'u değiştirmek herhangi bir şeyi çözmez; öncelikle telemetry pipeline'ın düzeltilmesi gerekir.

SIEM tarafında oldukça sık karşılaştığımız başka bir problem de parsing ve normalization oldu. Ham log SIEM'e gelmesine rağmen detection'ın kullandığı command, process, user veya benzeri alanlar doğru parse edilmediğinde rule condition eşleşmeyebiliyor. Böyle bir durumda aslında telemetry mevcut fakat detection tarafından kullanılabilir hale getirilememiş oluyor.

Tabii test tarafında da hata yapabildiğimiz durumlar oluyor. Öncelikle test ettiğimiz technique'in gerçekten beklediğimiz şekilde execute olup olmadığını doğruluyoruz. Çünkü başarısız olmuş veya gerçek adversary behavior'ı doğru temsil etmeyen bir testi detection failure olarak değerlendirmek yanlış olur.

Bu nedenle süreci biraz iteratif yürütüyorum. Önce technique'in gerçekten başarıyla execute edildiğini doğruluyorum, ardından endpoint'in beklenen telemetry'yi üretip üretmediğine, bu telemetry'nin collector üzerinden SIEM'e ulaşıp ulaşmadığına, doğru parse ve normalize edilip edilmediğine ve en sonunda rule logic'in bu davranışı kapsayıp kapsamadığına bakıyorum.

Yani benim için “alert oluşmadı” tek başına yeterli bir sonuç değil. Asıl önemli olan failure'ın nerede gerçekleştiğini bulmak: test mi hatalıydı, telemetry hiç oluşmadı mı, log SIEM'e ulaşmadı mı, parsing mi başarısız oldu, yoksa telemetry doğru olduğu hâlde detection logic bu implementation'ı kapsamıyor muydu?

Bu ayrımı yaptıktan sonra da problem telemetry tarafındaysa logging veya collection capability'sini, parsing tarafındaysa normalization'ı, detection tarafındaysa rule logic'i geliştiriyoruz. Böylece yapılan test yalnızca tek bir saldırının yakalanıp yakalanmadığını göstermekten ziyade kurumun detection capability'sindeki gerçek gap'i ortaya çıkarmış oluyor.

8.7 Bulguyu kurala çevirmek

Koşu raporu, teşhis edilebilir bir iş listesine dönüşmelidir. “Çalmadı”, “geç çaldı” ve “veri yok” sonuçlarında önce yürütme, veri, zaman ve eşleme kanıtını inceleyin. Görevi bulduğunuz nedene göre tespit, toplama veya dağıtım sorumlusuna açın; sonuç etiketi tek başına kök nedeni söylemez.

Paketteki tools.kosu ölçüm kaydını üretir; tools.sonuc_yaz ise sonucu kural metadata’sına işler. Bunlar ayrı adımlardır. Aynı koşunun yürütme, olay ve alarm kanıtı ilişkilendirilmeden yalnız “detected” metninden başarı kaydı çıkarılmamalıdır.

SON TEST VE BAŞARILI DOĞRULAMA AYRI

```
import json
from pathlib import Path
from tools.sonuc_yaz import update

record = json.loads(Path("fixtures/validation_run.json").read_text())
found = update("rules", "4f2a91c7-6b0e-4d31-9a52-1c7e5f8b2d64", record)
if not found:
    raise SystemExit("Kural bulunamadı")
# Tam modül yorumları korur. Sonuç missed/no_data ise gecikme null.
# Başarılı doğrulama yalnız detected + present + kanıt ile ilerler.
```

Son test ve son başarılı doğrulama ayrı saklanır. Harita, bu kayıtların aynı güncel koşuyu tutarlı biçimde gösterip göstermediğini kontrol eder. Son koşu başarısızsa eski başarı güncel kabul edilmez. Otomasyon kayıt tutarlılığını denetler; kanıtın gerçekliği ham olay, koşu ve alarm kayıtlarıyla değerlendirilir.

8.8 Güvenli emülasyon

Emülasyon, etkisi önceden değerlendirilmiş komutlarla yürütülmelidir. Aşağıdaki üç önlemi bu kitabın koşu politikası olarak öneriyorum. Kapsam, durdurma ve cleanup doğrulaması riski yönetmeye yardım eder; her kazayı önlediklerini iddia etmiyorum.

Yetki yazılı olmalı. Kimin, hangi sistemlerde, hangi tarih aralığında, hangi teknikleri çalıştırmaya yetkili olduğu önceden yazılıp onaylanmalıdır. Bu yalnızca bürokrasi değildir; bir emülasyon komutu gerçek bir alarm ürettiğinde, IR ekibinin bunu doğrulayabileceği bir kayıt olması gerekir.

Yıkıcı teknikler üretime çıkmaz. Veri silme, şifreleme simülasyonu, servis durdurma, kimlik bilgisi değiştirme gibi teknikler yalnızca izole laboratuvarda çalıştırılır. Üretimde çalıştırılacak teknikler, geri alınabilir ve zararsız olanlarla sınırlanır.

Her koşunun bir temizliği olmalı. Ability'lerin `cleanup` adımı tanımlı olmalı ve koşu sonunda gerçekten çalıştığı doğrulanmalıdır. Bırakılan bir zamanlanmış görev, aylar sonra bir threat hunting bulgusu olarak karşınıza çıkar.

Kontrol	Üretim ortamı	Laboratuvar
Yıkıcı etki	Bu kitabın planında kullanılmaz	İzole kapsam ve ayrı kabul gerekir
Kimlik bilgisi değişimi	Ayrı onaylı kapsam gerektirir	Ayrı test kimliği ve geri dönüş gerekir
C2 hedefi	Onaylı iç test hedefi	Kontrollü ve izole hedef
Yetki/kapsam kaydı	Zorunlu	Zorunlu
Cleanup doğrulaması	Bu koşu politikasında zorunlu	Bu koşu politikasında zorunlu
IR koordinasyonu	Koşu planına göre önceden	Paylaşılan izleme varsa koordine edilir

> **KOŞUNUN KİM TARAFINDAN BİLİNDİĞİNİ KAYDEDİN**
>
> Bildirim ve güvenlik koordinasyonu kurumun koşu planına göre yapılır. Değerlendiren ekibin önceden ne bildiğini de rapora yazın; bu bilgi sonucu etkileyebilir. Yalnız bir kişiye bildirmek tarafsız ölçüm garantisi değildir. Durdurma yetkisi ve olay ayırma yöntemi her koşuda belirli olmalıdır.

8.9 Doğrulamayı sürekli hâle getirmek

Tek seferlik bir emülasyon değerlidir ama bir fotoğraftır. Ortam değişir, kurallar körelir, log kaynakları taşınır ve dünkü doğrulama bugün geçersiz olabilir. Bölüm 6.6'daki “doğrulamanın yaşı” fikri burada karşılığını bulur.

Yeniden test takvimini kritik davranışlara, değişiklik hızına ve bakım kapasitesine göre kurun. Aylık veya üç aylık döngü bir başlangıç olabilir. Mantık ya da veri sözleşmesi değişince ilgili doğrulama da yenilenmelidir.

Ticari BAS araçları ve kurumun kendi emülasyon hattı farklı maliyetler taşır. Lisans bedelini, kurulum ve bakım emeğini, desteklenen senaryoları birlikte karşılaştırın. Hiçbir seçeneğin her kurumda daha ucuz olduğu varsayılmamalıdır.

> **TEMSİLİ HAFTALIK DOĞRULAMA PLANI**
>
> Önce yaşlanan ve öncelikli doğrulama kayıtlarını seçin. Laboratuvarda yürütme ve cleanup’ı sınayın. Kabul edilmiş kapsamda koşuyu yürütün; gerçek yürütme zamanı, ham olay ve alarmı ilişkilendirin. Sonuçları teşhis ederek görevlere dönüştürün, kayıtları ve haritayı güncelleyin. Hangi gün ve ne kadar emek gerekeceğini ekibin koşu verisinden ölçün.

Bir kuralın yakalamasını görmek işin bir tarafı. Sonraki bölümde meşru davranışların ürettiği yükü ölçüp, kapsam kaybını da hesaplayarak ayarlayacağız.

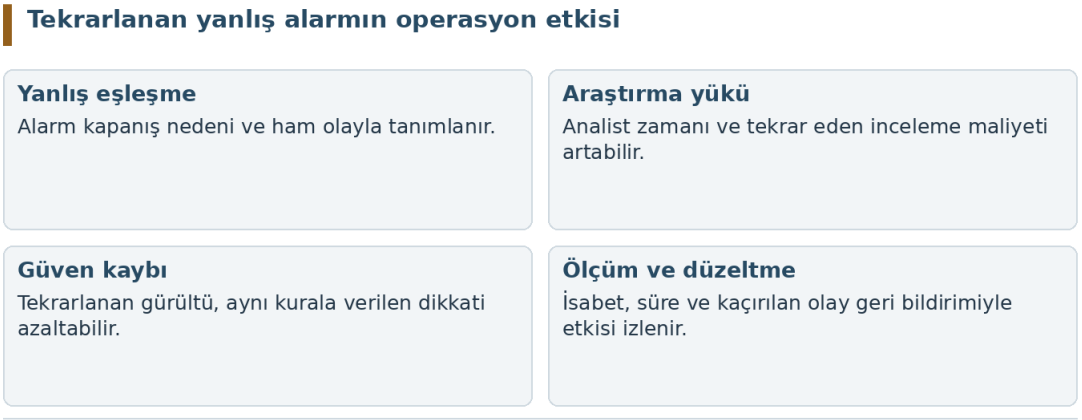
BÖLÜM 09

False Positive Mühendisliği

Emülasyon, seçilmiş davranışın yürütülmesini ve savunmanın tepkisini ölçer. Üretimdeki toplam gürültü için ayrıca alarm ve inceleme verisi gerekir. Bu bölüm araştırma maliyetini, yanlış eşleşmenin kaynağını ve ayarlama sonrası kapsam değişimini ele alır. Üçüncü kısmı burada kapatıyoruz.

9.1 Gürültünün gerçek maliyeti

Yanlış alarmlar yalnız inceleme süresini artırmaz; tekrar ettiklerinde analistin aynı kurala verdiği dikkati de azaltabilir. Bu yüzden gürültüyü hem araştırma yükü hem güven açısından izlemek gerekir.



Şekil 9.1 Sürekli yanlış alarmın analist güvenini aşındırmasını gösteren şema; ampirik eğri değildir.

Şekil, yanlış alarmlar tekrarlandıkça kurala duyulan güvenin azalabileceğini gösteriyor. Bunun için sabit bir çöküş eşiği vermiyorum. Operasyonel etkiyi kapanış kayıtları, inceleme süresi ve kaçırılan olay geri bildirimiyle ölçmek gerekir.

Gürültülü bir kuralın gerçek olayı da otomatik alışkanlıkla kapatılabilir. Bunun için kapanış nedenleri, yinelenen alarmlar ve sonradan bulunan kaçırmalar birlikte incelenmelidir.

Benzer alarmlara da aynı kapanış alışkanlığı taşınabilir. Tuning işini yalnız alarm sayısını azaltma hedefiyle yürütmeyin; geriye kalan kapsamı ve analistin kararını da izleyin.

> **BAŞARISIZLIKTAN SONRA KARAR VERİN**
>
> Önce komut yürütmesi, veri, zaman, alan eşlemesi ve kuralın hedefteki durumunu kontrol edin. Gerekli mantığı düzeltip yeniden test etmek, sinyali av veya risk kullanımına taşımak ya da gerekçeli biçimde devre dışı bırakmak seçenekler arasındadır. Etiketi değiştirmek başarısız testi başarıya çevirmez.

9.2 Gürültüyü ölçmek

Ayarlamadan önce ölçmek gerekir. Aşağıdaki beş gösterge alarm yükünü ve inceleme sonucunu farklı açılardan gösterir. Aynı dönem ve etiket sözleşmesi kullanılmadan aralarında karşılaştırma yapılmamalıdır.

Gösterge	Hesap	Sınır
Tehdit isabeti	Doğrulanmış tehdit / kararlı değerlendirilen kayıt	Benign, kararsız ve yinelenen etiket politikası açık
Günlük yoğunluk	Dönem alarmı / gün / etkilenen varlık	Sıfır varlık ve zaman dilimi kontrol edilir
Yoğunlaşma	İlk 5 varlığın alarm payı	Dışlama kanıtı değildir
Kapanış dağılımı	Her kapanış sınıfının payı	Değerlendirilmeyenlerin oranı ayrıca
Tekrar	Aynı olay/kural tekrarları	Aynı varlıktaki yeni olaydan ayrılır

Yoğunlaşma, araştırmaya nereden başlayacağınızı söyler. İki yüz alarmın yüz doksanı bir sunucudan geliyorsa meşru toplu iş, bozuk parser veya gerçek saldırı olabilir. Tek başına bu sayı dışlama gerekçesi değildir. Ham kayıt ve iş bağlamı incelenmelidir.

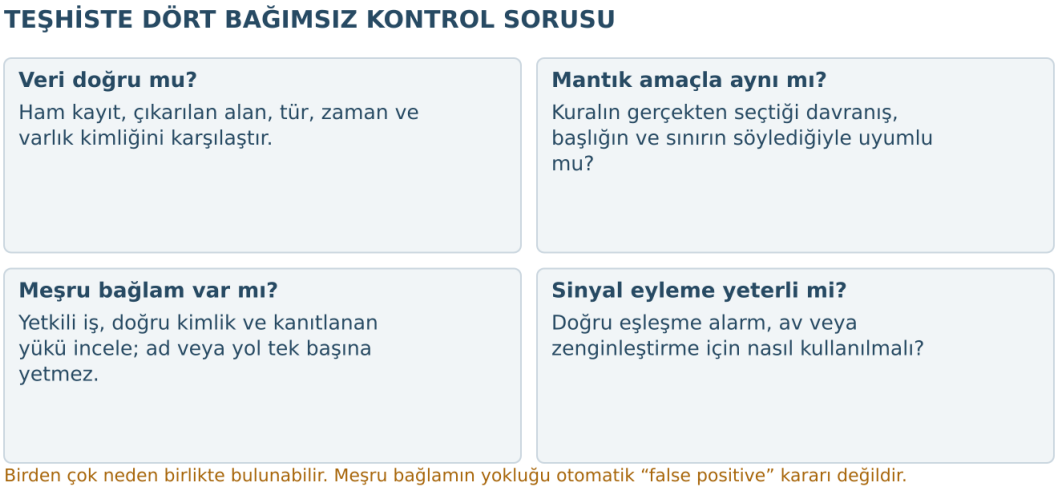
GÜRÜLTÜ — ETİKETLİ PAYDA VE GÜNLÜK YOĞUNLUK

```
index=alerts earliest=-14d@d latest=@d
| stats count AS toplam dc(host) AS varlik
    sum(eval(kapanis_nedeni="true_positive")) AS tehdit
    sum(eval(in(kapanis_nedeni,"true_positive","benign_true_positive",
                          "false_positive_kural","false_positive_veri"))) AS kararli
    BY rule_id
| eval isabet=if(kararli>0,round(100*tehdit/kararli,1),null())
| eval gunluk=round(toplam/14,1)
| eval yogunluk=if(varlik>0,round(toplam/14/varlik,2),null())
# İsabet yalnız kararlı, değerlendirilen tehdit etiketleriyle hesaplanır.
# Yoğunlaşma; alt arama veya varsayılan top sınırı yok.
index=alerts earliest=-14d@d latest=@d rule_id="DE-0031"
| stats count BY host
| eventstats sum(count) AS toplam
| sort 0 - count
| head 5
| stats sum(count) AS ilk_bes max(toplam) AS toplam
| eval pay=if(toplam>0,round(100*ilk_bes/toplam,1),null())
```

Haftalık gürültü listesi, inceleme işlerini seçmeye yardımcı olur. Hacmin yanında kritik kapsam kaybını ve araştırma süresini de önceliklendirmeye katın.

9.3 Kaynağı bulmak

Yanlış alarmın çözümü kaynağına bağlıdır. Burada dört gruplama kullanıyorum; gerçek olayda birden çok neden birlikte bulunabilir.



Şekil 9.2 Yanlış alarm teşhisinde bağımsız kontrol soruları; nedenler birlikte bulunabilir.

Veri arızası. Alan yanlış eşlenmiş veya anlamı değişmiş olabilir. Doluluk izlemesi boş alanı yakalar; yanlış anlamla dolu alanı yakalamayabilir. Örnek kayıt, veri sözleşmesi ve entegrasyon testi birlikte gerekir.

Kural hatası. Eşleşen olay hedeflenen davranışı göstermiyorsa mantık yeniden incelenir. Daraltma veya dışlama değişikliğinin ne kaybettirdiği pozitif örneklerle ölçülür; adlandırması tek başına çözümün doğruluğunu belirlemez.

Meşru kullanımda olay gerçekten gerçekleşmiş ve mantık doğru eşleşmiş olabilir. Dar dışlama, kapsamı ölçülerek değerlendirilebilir. Sinyal doğru fakat tek başına araştırmaya değmiyorsa alarm yerine av veya zenginleştirme kullanımı da düşünülür.

DİKKAT — DIŞLAMA, TEŞHİSİN YERİNE GEÇMEZ

Sahada en sık gördüğüm tuning hatası, dört kaynağı ayırt etmeden doğrudan dışlama yazmaktır. Dışlama hepsinde gürültüyü keser; ama üç durumda yanlış sorunu çözer. Bozuk bir parser'ın ürettiği gürültüyü dışlamayla susturmak, aynı parser'a dayanan diğer kuralların da bozuk olduğu gerçeğini gizler.

Pratik kural: dışlama yazmadan önce "bu alarm neden geldi" sorusunu yanıtlayabiliyor olun. Yanıtlayamıyorsanız henüz teşhis koymamışsınız demektir.

KONUK KATKI — GÜRÜLTÜNÜN KAYNAĞINI AYIRMAK

Sarp Gezer Tehdit Tespit Mühendisi

İlk adım, analistin neden false positive değerlendirmesi yaptığını anlamak ve alarmı oluşturan kayıtları incelemektir. "Bu işlem normal" denildiğinde, işlemi normal kabul ettiren bilginin de ortaya konması gerekir. Daha önce incelenmiş bir bakım faaliyeti söz konusu olabilir veya aynı alarm sürekli geldiği için artık üzerinde durulmuyor olabilir. Analistin geri bildirimi bu nedenle değerlidir, fakat kural üzerinde yapılacak değişiklik, alarmın ne sıklıkta geldiği kadar hangi nedenle gereksiz görüldüğüne de dayanmalıdır.

İnceleme ham logdan başlar. Logda yazan olay ile SIEM'in ayrıştırdığı alanlar karşılaştırılır. Kullanıcı adı doğru alana geliyor mu, başarılı ve başarısız işlemler doğru ayrılıyor mu? Kuralın kullandığı alan boşsa veya başka bir bilgiyi taşıyorsa, koşullar üzerinde yapılacak düzenleme sorunu çözmeyebilir. Bu yüzden parsing kontrolü, kural düzenlemesinin öncesinde yapılır. Özellikle farklı kaynaklardan gelen loglarda, alan adının aynı olması içeriğinin de aynı olduğu anlamına gelmez.

Ardından kuralın hangi kayıtları bir araya getirerek alarm ürettiğine bakılır. Tek bir kullanıcının başarısız girişleri mi sayılıyor, yoksa farklı kullanıcıların hareketleri aynı kaynak IP altında mı toplanıyor? Kaynak IP alanına gerçek istemci yerine yük dengeleyicinin adresi geliyorsa, birbirinden bağımsız işlemler tek bir kaynaktan yapılmış gibi görünebilir. Aynı işlemin birden fazla log üretmesi de olay sayısını artırabilir. Böyle bir durumda eşik yükseltilmeden önce, sayılan şeyin ne olduğu açıklığa kavuşturulmalıdır.

Veri doğruysa kuralın koşulları değerlendirilir. Tam bir kullanıcı adını kontrol etmek için contains kullanılması veya belirli bir işlem için ham logun tamamında genel bir kelime aranması, gereğinden geniş eşleşmeler oluşturabilir. Burada tercih, mümkün olduğu ölçüde parse edilmiş alanlar üzerinden çalışmak ve tam eşleşme gereken yerde eşitlik koşulu kullanmaktır. Bununla birlikte, her contains koşulu yanlış değildir. Alanın tam dosya yolu mu yoksa yalnızca işlem adı mı taşıdığı bilinmeden koşul değiştirilirse, bu kez beklenen olaylar kaçırılabilir.

Son aşamada olayın ortam içindeki karşılığı değerlendirilir. İşlemi yapan hesabın görevi ve hedef sistemin kullanım amacı burada belirleyicidir. İlgili ekipten alınan "bu bir bakım işlemi" açıklamasının, logdaki zaman ve işlem bilgisiyle örtüşmesi beklenir. Veri yanlış ayrıştırılmışsa parsing düzeltilir. Koşul gereğinden genişse kural daraltılır. Faaliyet doğru tespit edilmiş ve ortamda beklenen bir işlemse, istisnanın hangi sınırlar içinde tanımlanacağı değerlendirilir. Böylece bütün false positive bildirimlerine aynı müdahale uygulanmamış olur.

9.4 Baselining: normali öğrenmek

Ortam gerçeğinden kaynaklanan gürültüyü doğru kesmenin ön koşulu, o ortamın normalini bilmektir. Baselining, tuning'in teşhis aşamasıdır: kuralı tetikleyen aktiviteyi susturmadan önce anlamak.

Gölgede eşleşmeleri kullanıcı, gerçek ebeveyn, zaman ve komut kalıbına göre gruplayın. Tablo araştırma adaylarını gösterir; hangi grubun meşru olduğunu iş sahibi ve ham kayıtla doğrulamadan dışlama yazılmaz.

BASELINE — OFFICE KURALININ TEMSİLİ ÇIKTISI

```
index=shadow rule_id="DE-0031" earliest=-30d
| stats count AS adet dc(host) AS host_sayisi values(ParentImage) AS ebeveynler
        min(_time) AS ilk max(_time) AS son BY User
| eval sure_gun=round((son-ilk)/86400,1)
| sort - adet
# Temsili çıktı; gerçek ölçüm değildir:
# CORP\svc_rapor : excel.exe ebeveynli yoğun otomasyon
# CORP\svc_eklenti : winword.exe ebeveynli eklenti işi
# CORP\ayse : winword.exe ebeveynli az sayıda olay
# DE-0031 doğrudan Office ebeveyni ister; SCCM/explorer burada eşleşmez.
# Yüksek hacim meşruiyet kanıtı değildir; iş sahibiyle doğrulayın.
```

Temsili çıktı, yüksek hacimli iki otomasyon hesabı ile az sayıdaki kullanıcı olayını ayırıyor. Yüksek hacim meşruiyet kanıtı değildir. Her grubun işi doğrulanmadan dışlama yazılırsa az görülen şüpheli olaylar da kaybolabilir.

9.5 Dışlama tasarımı

Dışlama, seçilmiş olayları bu kuralın eşleşme kümesinden çıkarır. Hangi hedef varyantların da dışarıda kaldığını ayrıca sınayın. İstisnayı doğrulanmış işlemin sınırına yakın tutun; seçeneklerin gürültü azalmasını ve kapsam kaybını aynı olay kümesinde karşılaştırın.



Şekil 9.3 Dışlama kapsamlarının nitel karşılaştırması. Yüzdeler veya ölçülmüş kör nokta büyüklükleri verilmez.

Geniş hesap veya host dışlaması birçok farklı davranışı görünmez kılar. Dar dışlama yalnız doğrulanmış işlemi tarif etmelidir. Kimlik, gerçek süreç kökeni ve yürütülen iş bağlamı yararlı ölçütlerdir; üçünün de metinde geçmesi güven kanıtı değildir.

DIŞLAMA — ÇÖZÜLMÜŞ YÜK VE GERÇEK EBEVEYN

```
# Tam Office kuralına eklenen özel detection parçası.
# EncodedPayloadSha256, çözülen UTF-16LE yükün SHA256 değeridir.
filter_env_report:
  User: 'CORP\svc_rapor'
  ParentImage: 'C:\Program Files\Microsoft Office\root\Office16\EXCEL.EXE'
  EncodedPayloadSha256: 'fabaa9baec3d38096b814d56d43c4964790f2684ed6d3bebca9ece251abbf0b8'
# condition: selection_parent and selection_enc and not filter_env_report

# Yapısal denetim kaydı; gerçek bilet yerine örnek adı.
x_exclusions:
  filter_env_report:
    reason: Temsili rapor otomasyonu; doğrulanırsa yalnız sabit yük
    ticket: DWELL-EXAMPLE
    review_date: '2026-12-01'
# Alan sözleşmesi ve tüm eşleşme tuple'ı doğrulanmadan dağıtılmaz.
# Temsili sabit yük: Write-Output 'DWELL rapor testi'
# normalizer: tools.normalize_events.encoded_payload_sha256
# Hash gerçek kurum otomasyonunun ölçülmüş değeri değildir.
```

Dışlamayı ayrı bir blokta tutun. Gerekçe, bilet ve gözden geçirme tarihi x_exclusions gibi yapısal kayıtta yer alsın. Örnekte dışlama, yalnız EncodedCommand tespitiyle aynı kapsamı taşır; onaylı betiği çalıştıran -File komutunu alakasız bir izin gibi eklemiyoruz.

SAHADAN NOT — DIŞLAMAYI ATLATMAYI DENEYİN

Onaylı yolun CommandLine içinde geçmesi, o dosyanın çalıştığını veya imzasının geçerli olduğunu göstermez; inert bir argüman da aynı metni taşıyabilir. EncodedCommand için çözülen yükün gerçek baytlarını hash'lemek, doğrulanmış kullanıcı ve gerçek ebeveynle birlikte dar bir eşleme sağlar. Yine de hesabın veya meşru otomasyonun ele geçirilme riski vardır. Dışlamadan önce bu sınırı yazın ve kötü yük + onaylı yol testi yapın.

KONUK KATKI — BUNU KESERSEM NEYİ KAYBEDERİM

Sarp Gezer Tehdit Tespit Mühendisi

Bir kuralı daraltmadan önce, tespit edilmek istenen davranış açık biçimde tanımlanmalıdır. Kuralın adı bu konuda tek başına yeterli değildir. Örneğin bir silme işlemini her gerçekleştiğinde bildirmek ile kısa sürede yoğun silme faaliyetini tespit etmek farklı amaçlardır. İlkinden ikincisine geçildiğinde alarm sayısı azalabilir, ancak kuralın kapsamı da değişmiş olur. Bu değişiklik yalnızca "false positive azaltıldı" şeklinde değerlendirilmemelidir.

Kayıp hesabı, yeni koşulun dışında kalacak olaylar üzerinden yapılır. Bir kullanıcı hariç tutulacaksa, o kullanıcıyla yapılabilecek şüpheli işlemlerin de dışarıda kalacağı hesaba katılır. Bir sunucu tamamen kapsamdan çıkarılacaksa, karar yalnızca bugünkü gürültüyü etkilemez. Daha sonra aynı sunucuda gerçekleşecek faaliyetler de bu kural tarafından değerlendirilmeyecektir. Bu nedenle istisnanın sınırı, gereksiz alarm üreten faaliyetin sınırına mümkün olduğunca yakın tutulmalıdır. Bir hesaba veya sisteme genel bir güven tanımak yerine, bilinen işlemin hangi koşullarda gerçekleştiği esas alınır.

Snapshot silme üzerine yapılan bir vCenter çalışması bu güçlüğe somut bir örnektir. Çalışmada snapshot oluşturma ve silme olayları ayrı QID'lerle eşlendi. Böylece kuralın hangi olayı değerlendirdiği netleştirildi. Ancak incelenen kayıtlarda yalnızca Administrator hesabı görülüyordu. Kullanıcı adına dayanarak rutin işlem ile şüpheli işlem arasında ayrım yapmak mümkün değildi. Administrator hesabını istisnaya almak, eldeki silme olaylarını da kapsam dışında bırakacaktı.

Bu durumda silme işlemlerinin belirli bir süre içindeki tekrarına dayanan bir eşik değerlendirildi. Fakat bu yaklaşımın da bir bedeli vardır: Eşiğin altında kalan silmeler alarm üretmez. Tek bir silme işleminin de önemli olabileceği bir senaryoda, yalnızca olay sayısını artırmak yeterli bir çözüm sayılmaz. Ayrıca aynı işlemin başlangıç ve tamamlanma kayıtları gibi farklı loglar üretip üretmediği kontrol edilmelidir. Log sayısı ile ayrı işlem sayısı birbirine karıştırılırsa, eşik gerçek faaliyeti doğru temsil etmez.

Bu örnekte zorlayan nokta, mevcut kullanıcı bilgisinin ayrım yapmaya yetmemesiydi. Böyle durumlarda ek bağlamın bulunup bulunmadığına bakılır. İşlemin gerçekleştiği sistem veya doğrulanmış bakım zamanı bir ayrım sağlayabilir. Bu bilgi yoksa, verinin desteklemediği bir kesinlik kural koşullarına yüklenmemelidir. Her silmeyi bildirmek ile yoğun silmeyi bildirmek arasındaki tercih ve bu tercihin dışında kalan olaylar açıkça belirtilmelidir.

Değişiklik sonrasında kontrolün iki yönü vardır. Daha önce gereksiz alarm üreten kayıtların yeni koşulda ne olduğu incelenir; tespit edilmek istenen davranışın hâlâ eşleşip eşleşmediği de kontrol edilir. Mümkün olduğunda eski ve yeni koşullar aynı geçmiş kayıtlar üzerinde karşılaştırılır. Test kaydının yalnızca arama sonucunda görünmesi de yeterli değildir; doğru alanlara ayrışması ve kuralın diğer koşullarını karşılaması gerekir. Alarm sayısındaki düşüş, bu kontrollerle birlikte değerlendirildiğinde anlam kazanır.

9.6 Dışlamanın alternatifleri

Gürültüyü azaltmak için dışlamanın yanında eşiği, gruplamayı, bağlamı ve kullanım amacını değerlendirin. Hangi seçeneğin daha az kapsam kaybı yarattığını aynı veriyle karşılaştırın.

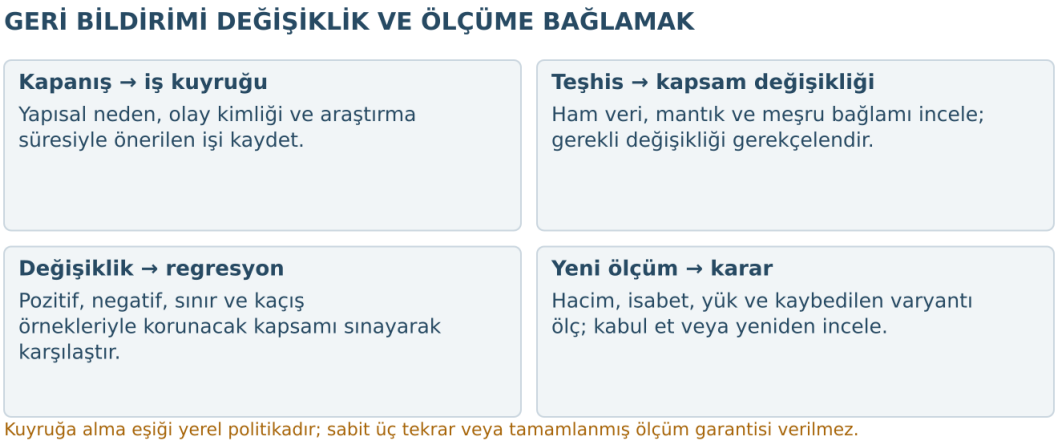
Seçenek	Ne yapar	Ne zaman uygun
Mantığı daraltmak	Kuralın kendisini keskinleştirir	Kaynak kural hatasıysa
Önceliği düşürmek	Alarm üretir ama kuyruğun altına düşer	Sinyal doğru, aciliyet yanlışsa
Zenginleştirme	Alarm üretmez, başka alarma bağlam ekler	Tek başına aksiyona değmiyorsa
Eşiğe bağlamak	Tek olayda susar, tekrarında çalar	Tekil olay normal, yığın anormalse
Zaman koşulu	Yalnızca belirli saatlerde çalar	Meşru iş mesai içindeyse
Risk skoruna katmak	Puan ekler, eşikte alarm üretir	Zayıf ama anlamlı sinyalse
Dışlama	Belirli durumu tamamen susturur	Ortam gerçeğiyse, dar yazılırsa

Eşik, tekil meşru olayları azaltabilir; aynı zamanda eşik altındaki saldırıları da kaçırır. On dakikada dört hedef arıyorsanız tek hedef ve yavaş yayılma kapsam dışında kalır. Kayıp ve varsa telafi av sorgusu yazılmalıdır.

Risk biriktirme, tek başına alarm için yetersiz bir sinyali diğer bağlamla birleştirmenin bir yoludur. Varlık eşlemesi, süre, ağırlık ve eşik de tasarlanır; sonuç etiketli olaylarla ölçülür. Gürültülü her mantığı risk bileşenine taşımak kendiliğinden yarar sağlamaz.

9.7 Tuning döngüsü

Ayarlamayı triyaj geri bildirimiyle birlikte yürütüyorum. Tek seferlik değişiklikten sonra da alarm yükünü, kapsamı ve yeni varyantları izlemek gerekir. Kapanış kaydı, hangi sorunun tekrarlandığını görmeye yardım eder.



Şekil 9.4 Kapanış kaydından değişiklik ve yeniden ölçüme önerilen geri bildirim döngüsü.

Alarm kapanışında nedenin yapısal olarak kaydedilmesi ölçümü kolaylaştırır. Serbest metin açıklama da tutulabilir; tutarlı etiket ve olay kimliği karşılaştırılabilir sayaç üretmek için gereklidir.

KAPANIŞ NEDENLERİ — YEREL ŞEMA

```
kapanis_nedeni:
  - true_positive        # doğrulanmış tehdit, doğru eşleşme
  - benign_true_positive  # davranış var; meşru kullanım
  - false_positive_kural  # mantık hedef davranışı seçmiyor
  - false_positive_veri   # alan/ayrıştırma arızası
  - duplicate             # aynı olayın tekrar kaydı
  - yetersiz_baglam       # henüz karar verilemiyor
# Kapanış etiketleri bu kitabın önerisidir; ürün standardı değildir.
# Meşru eşleşme otomatik dışlanmaz; kapsam kaybı ayrıca ölçülür.
```

benign_true_positive, amaçlanan davranışın doğru eşleştiği fakat meşru olduğu sonucu anlatır. Bu durumda dışlama, kapsam değişikliği veya başka bir iş akışı değerlendirilebilir. false_positive_kural ise amaçlanan mantığın yanlış uygulanmasıdır. Etiketleri ayırmak, doğru düzeltmeyi seçmeyi sağlar.

Döngünün ikinci ucu ölçümün tekrarlanmasıdır. Bir düzeltme yapıldıktan sonra aynı gürültü profili yeniden çalıştırılmalı ve iyileşme sayıyla gösterilmelidir. Ölçülmeyen bir tuning, yapıldığı sanılan bir tuning'dir.

9.8 Kabul edilen gürültü

Bölümü bir kabulle kapatmak gerekiyor: her gürültü kesilmez ve kesilmemelidir. Bazı tespitler doğaları gereği gürültülüdür ve gürültüleri, yakaladıkları şeyin değeri karşısında kabul edilebilir.

Nadir fakat kritik tespitte daha yüksek araştırma maliyeti kabul edilebilir; gerekçe ve kabul eden kişi yazılır. Av sorgusunda aday küme daha geniş olabilir. Her iki durumda yerel sonuçları ölçün; bir domain controller'daki beklenmedik işlemi genel olarak bakım saymayın.

Gürültü hedefini yazmak, sonuçları değerlendirmek için başlangıçtır. Örneğin temsili bir hedef "haftada yaklaşık on alarm" olabilir; gerçekleşen hacim, isabet ve araştırma süresi yine ölçülür. Hedefin yazılı olması tek başına kabul kanıtı değildir. Sapmayı, Bölüm 9.1'deki güven sorunuyla birlikte izleyin.

> **TEMSİLİ GÜRÜLTÜ BÜTÇESİ**
>
> x_expected_alerts_per_week: 10 ve x_expected_precision: 0.3, örnek yerel metadata değerleridir. Kuruma uygun hedef ölçümle belirlenir. Bu alanlar tek başına otomatik uyarı üretmez; sayaç, etiketli örneklem ve sapma kontrolü ayrıca kurulmalıdır. Beklenmeyen sessizlik veri arızası, davranış yokluğu veya değişen mantık gibi farklı nedenlerle araştırılır.

Doğrulama ve ayarlamanın yöntemlerini gördük. Şimdi bunları sürdürülebilir bir depoya ve dağıtım sürecine bağlayacağız.

BÖLÜM 10

Detection-as-Code

> *Kitabın dördüncü kısmı burada başlıyor: buraya kadar öğrendiklerimizi sürdürülebilir bir işletmeye çevirmek. Bu bölüm kural deposunun yapısını, metadata şemasının nasıl zorunlu kılındığını, inceleme sürecini, dağıtım hattını, ortam ayrımını ve geri alma mekanizmasını ele alır.*

10.1 Kuralı yazılım gibi ele almak

Depo, kuralın nerede olduğunu, kimin değiştirdiğini ve hangi sürümün kullanıldığını izlemeyi sağlar. Ürün arayüzünün denetim kaydı da değerli olabilir; ancak taşınabilir kaynak, test ve dağıtım manifesti birlikte yönetilirse değişiklikleri karşılaştırmak kolaylaşır.

Detection-as-code, kuralları sürüm kontrolünde tutup gözden geçirme, test ve dağıtım sürecine bağlamaktır. Yazılım mühendisliği uygulamalarını tespit içeriğine uyarlıyoruz.

Depo ve hat; değişiklik gerekçesini izlemeyi, önceki revizyonu geri yüklemeyi ve dağıtımı tekrar etmeyi kolaylaştırır. Sonuç, hedef bağlantılarına, izinlere ve testlere bağlıdır. Kural sayısı arttığında hattın da kapasitesi, hata davranışı ve bakım ihtiyacı ölçülmelidir.

SAHADAN NOT — TAŞIMA ENVANTERLE BAŞLAR

Mevcut kuralları dışa aktarıp durumlarını sınıflandırın. Depoya alınacak her kuralın sahibi, verisi, testi ve dağıtım karşılığı belli olsun. SIEM'de kalan bütün kurallar bu nedenle ölü sayılmaz; bazıları ürünün özel yapısıyla yönetiliyor olabilir. Taşınmayanların da envanteri ve gerekçesi tutulur.

10.2 Depo yapısı

Depo düzeni, ekibin nasıl çalıştığını belirler. Aşağıdaki yapı sahada işlediğini gördüğüm en sade hâlidir; büyüklüğü ne olursa olsun aynı mantıkla genişler.



Şekil 10.1 Eşlikçi pakette gerçekten bulunan örnek dosya yolları.

Kural, bitişik test ve davranış örneğini yan yana tutmak incelemeyi kolaylaştırır. CI eksik test veya kimlik bağını denetler; aynı klasörde olmak kişinin testi doğru güncellediğini garanti etmez.

contracts/ veri ve doğrulama sözleşmelerini taşır. Bir alan değiştiğinde bağımlı kuralların hangileri olduğunu incelemek için bu kayıtları kullanın. tools/ dizininde kontrol, derleme, kapsam ve örnek dağıtım araçları bulunur; paketteki gerçek yollar Şekil 10.1'de gösterilir.

> **DİZİN DÜZENİNİ DEPO İHTİYACINA GÖRE SEÇİN**
>
> Bu pakette kuralları platform ve kaynak gereksinimine göre düzenliyorum; ATT&CK eşlemesini metadata'da tutuyorum. Bir kural birden çok davranışla ilişkiliyse tek bir teknik dizinine yerleştirmek aramayı zorlaştırabilir. Başka bir düzen de seçilebilir. Esas olan kalıcı kural kimliği, güncel eşleme ve açık dosya yollarıdır. ATT&CK sürüm değişikliği her durumda dizin taşıma zorunluluğu doğurmaz.

10.3 Şemayı zorunlu kılmak

Bölüm 3.6'da önerdiğim depo politikasını burada CI'ya bağlıyoruz. Kural metadata'sı için gerekli alan, tür ve kabul koşullarını tanımlayın. Otomatik kontrol bu koşulları sınar; dolu bir alanın gerçek kanıt taşıdığı ayrıca incelenir.

ŞEMA VE DEPO POLİTİKASI — AYRI KONTROLLER

```
from tools.sema_kontrol import validate

result = validate("rules", "2026-10-06")
for error in result["errors"]:
    print(error)
raise SystemExit(0 if result["passed"] else 1)
# JSON şemaları schemas/ içinde; türü correlation varlığı seçer.
# safe_load_all kullanılır; .test.yml dosyaları kural sayılmaz.
# [] geçerli liste, unsupported geçerli status.
# Stable başarı politikası tools/core.py'de ayrıca uygulanır.
```

Bu paketin stable politikası güncel başarı, mevcut telemetri, varyant ve kanıt bilgisi ister. Son test ile başarılı kaydın aynı koşu ve revizyonu tutarlı göstermesi gerekir. Eksik veya yanlış türde bilgi başarı sayılmaz. Bu yerel kabul politikası Sigma standardının zorunluluğu değildir.

10.4 İş akışı

Depodan üretime geçişi kayıtlı kontrollerle yönetmeyi öneriyorum. Başarısız kontrol, düzeltme ve yeniden denemeye döner. Acil değişiklik için daha kısa bir süreç tanımlanabilir; sorumlu, risk kararı ve sonradan tamamlanacak kontroller de kayda alınır.



Şekil 10.2 Önerilen teslim yolu; Sigma status ve hedef yönlendirmesi ayrı kaydedilir.

Dal aşamasında mantık ve test birlikte değişir. İncelemede otomatik kontroller ile ikinci göz değerlendirmesi yapılır. Gölgede eşleşmeler ölçülür, operasyonel bildirim gönderilmez. Başarılı uçtan uca doğrulama ve kabul edilen gürültüyle üretim manifestine geçilir.

Aktif olay sırasında yeni tespit gerekiyorsa kurumun acil değişiklik yolunu kullanın. İnceleme ve gölge ölçümünün süresi ihtiyaca göre belirlenir; herkes için sabit bir saat öneremem. Hedefteki geçici değişikliği depoya işleyin, kabul ve geri alma koşullarını kaydedin.

10.5 Kural incelemesi

Kural incelemesi kod incelemesine benzer ama bakılan şeyler farklıdır. Sözdizimi zaten otomatik kontrol edilmiştir; insanın bakacağı şey mantık, kapsam ve sürdürülebilirliktir. Aşağıdaki liste, incelemeyi öznel bir yorumdan tekrarlanabilir bir işe çevirir.

Kontrol	Sorulacak soru
İddia	Başlık gerçekten sınanan davranışı söylüyor mu?
Kapsam	Hangi hedef ve meşru işler eşleşiyor?
Kaçış	Hangi varyant veya bağlam mantığı atlatıyor?
Dışlama	Koşul dar ve bağlamı doğrulanmış mı; gerekçe ve tarih var mı?
Veri	Alanlar doğru tür ve anlamla gerçekten geliyor mu?
Test	Pozitif, negatif, sınır ve atlatma örnekleri var mı?
Yanıt	İlk araştırma adımı ve kanıt bağlantısı yeterli mi?
Bakım	Sorumlu, revizyon ve yeniden inceleme koşulu belli mi?

İncelemede kaçış yollarını da deneyin. Bulunan varyant için mantık genişletilebilir veya kapsam sınırı açıkça kaydedilebilir. Onay, bu kararın gerekçesi ve testleri görüldükten sonra verilir.

> ÖRNEK — İNCELEME YORUMU
>
> İyi bir inceleme yorumu genel değil, somuttur:
>
> *"`Image|endswith: '\powershell.exe'` yazmışsın; `pwsh.exe` (PowerShell 7) bu kuralı atlatır ve ortamımızda 40 civarı makinede kurulu. İkisini de kapsayan bir liste kullanalım. Ayrıca `filter_bakim` bloğu yalnızca kullanıcı adına bakıyor — ana süreç koşulu eklemezsek o hesabı ele geçiren biri tespitten tamamen çıkar."*
>
> Bu yorum iki somut kaçış yolu gösteriyor ve ikisi için de çözüm öneriyor. "Bence biraz geniş olmuş" türü bir yorum ise inceleme sayılmaz.

10.6 Dağıtım hattı

Onaylanan bir kuralın hedef platformlara ulaşması elle yapılmamalıdır. Dağıtım hattı, depodaki durumu hedef sistemdeki duruma eşitleyen bir süreçtir.



Şekil 10.3 Paketin Kibana dağıtım örneği; diğer ürünler için ayrı adaptör gerekir.

Dağıtımın idempotent olması, istenen durum ve hedef değişmemişken tekrar çalıştırmanın gereksiz kopya veya güncelleme üretmemesidir. Hedefte sapma varsa ikinci koşu düzeltme planı çıkarabilir. Bu davranışı aynı giriş ve değişmiş hedef örnekleriyle ayrı test edin.

Kalıcı UUID hedefte rule_id olarak korunur. Dağıtıcı yalnız sahiplik etiketi bulunan kuralları yönetir. Envanter sayfalaması tamamlanmadan plan çıkarılmaz; hatalı toplam, yinelenen kimlik ve sayfa sınırı aşımı reddedilir. Toplam değişimini kontrol etmek atomik envanter garantisi vermez; eşzamanlı değişiklikleri ayrıca yönetin.

KIBANA DAĞITICISI — ÖNCE PLAN

```
import os, json
from pathlib import Path
from tools.dagit import Kibana, plan

client = Kibana(os.environ["KIBANA_URL"], os.environ["KIBANA_API_KEY"])
expected = json.loads(Path("manifest.json").read_text())
changes = plan(expected, client.rules())
print(json.dumps(changes, ensure_ascii=False, indent=2))
# Bu örnek yalnız okur ve plan çıkarır.
# Tam araç: python -m tools.dagit manifest.json [--apply]
# Sahiplik: dwell:managed:v1. Tüm sayfalar alınır.
# Gölge enabled=true; ayrı space, actions=[] ve ayrı yönlendirme.
# Aynı alanlar değişmediyse yeniden yazılmaz; unowned kurala dokunulmaz.
```

Gölge kurallar da enabled=true çalışır. Örnekte ayrı Kibana space'i ve boş actions listesi kullanılır; eşleşmeler normal operasyon kuyruğuna bağlanmaz. enabled=false ölçümü durdurur. Kural olgunluğu ile dağıtım ortamı ayrı alanlarda tutulur.

10.7 Kural durumu ve ortamlar

status olgunluk bilgisidir; ortam ve etkinlik dağıtım manifestinin sorumluluğudur. Şekil 10.4 bu kitapta önerdiğim geçiş politikasını gösterir.

SIGMA STATUS • OLGUNLUK, HEDEF ETKİNLİĞİ DEĞİL

Değer	Standardın anlamı / kapsamı
experimental	Henüz test edilmemiş; yanlış pozitif veya kötü eşleşme görülebilir
test	İyileştirme gerekebilir; özel filtreler eksik olabilir
stable	Kararlı olarak değerlendirilmiş olgunluk etiketi
deprecated	Yerine başka içerik geçmiş veya artık uygun görülmeyen kural
unsupported	Bakımı ve desteği sağlanmayan içerik

Yerel kabul kanıtı ayrı politikadır. Hedefte enabled ve yönlendirme ayrıca kontrol edilir.

Şekil 10.4 Sigma'nın beş status değeri; hedef etkinliği dağıtım ayarıdır.

Bu depo için durum geçişlerinin kabul koşullarını ayrıca yazmayı öneriyorum. Gölge ölçümü, varyant doğrulaması ve yerel risk kararı bu koşullara dâhil edilebilir; bunlar Sigma'nın zorunlu geçiş adımları değildir. deprecated etiketi, yerine başka içerik gelmiş veya artık uygun bulunmayan kural için kullanılabilir. Hedefte etkinlik ve alarm yönlendirmesi ayrı kayıttır.

Ortam	Amaç	Çalıştırma	Yönlendirme
Laboratuvar	Kontrollü test	Test planına göre etkin	İzole test kuyruğu
Gölge	Gerçek veride ölçüm	enabled=true	Ayrı space/indeks; operasyon bildirimi yok
Üretim	Kabul edilmiş tespit	Manifest ve kanıta göre etkin	Tanımlı operasyon kuyruğu

Laboratuvar, gölge ve üretimdeki kural revizyonlarını aynı kalıcı kimlikle izleyin. Elle yapılan değişiklik varsa gerçek hedef durumunu kayda alın. Farklı revizyonda yapılan bir test, üretimdeki revizyonun doğrulaması olarak sunulamaz; sonuç yalnız sınanan sürüm ve ortam için geçerlidir.

Gölge alanının uyarıları merkezi vaka kuyruğuna bağlıysa yalnız actions: [] yetmeyebilir. Space/indeks ayrımı ve downstream yönlendirme de doğrulanmalıdır. Üretim manifesti, çalışma ortamını kuralın status değerinden ayrı taşır.

10.8 Geri alma ve sürüm

Detection-as-code'un en somut kazancı, bir değişikliği geri alabilmektir. Ama bu kazancın gerçekleşmesi için geri almanın *önceden denenmiş* olması gerekir. Sahada gördüğüm birçok ekipte depo vardır, hat vardır, ama geri alma hiç denenmemiştir ve ilk gerektiğinde çalışmaz.

Önceki revizyonu geri yüklemek geri almadır; kuralı devre dışı bırakmak ise geçici bir müdahaledir ve kapsama kaybı yaratabilir. Tek kural veya bütün dağıtım için bilinen sürümü, ayarları ve hedef durumu geri yükleyip doğrulayın. İşlem süresi ve ara risk hedef sisteme bağlıdır.

> **GERİ ALMAYI PLANLI OLARAK SINAYIN**
>
> Geri alma planını kontrollü bir değişiklikte deneyin. Önceki kaynak, ayarlar ve hedef durumun gerçekten geri geldiğini doğrulayın; süreyi ve ara riski kaydedin. Üç aylık aralık bir başlangıç önerisi olabilir; takvimi kurumun değişiklik hızına göre seçin. Yetki, anahtar süresi veya hedefteki sapma geri dönüşü etkileyebilir. Başarılı bir prova sonraki bütün koşullar için garanti değildir.

Sürüm etiketleme de bu mekanizmanın parçasıdır. Her üretim dağıtımına bir sürüm numarası vermek ve o numarayı hedef sistemde bir alanda taşımak, “şu an üretimde hangi sürüm çalışıyor” sorusunu tek sorguyla yanıtlanır hâle getirir.

10.9 Erişim ve izlenebilirlik

Kural deposu, kurumun tespit mantığını ve bilinen sınırlarını gösterebilir; erişimi kontrollü olmalıdır. İçeriği bütün kör noktaların tam listesi değildir. Depoda hiç düşünülmemiş bir davranış veya belgelenmemiş veri sorunu da bulunabilir.

Depoya erişimi görevle sınırlandırın ve ana dal değişikliklerini incelemeden geçirin. Hedef yazma yetkisini de en az ayrıcalıkla yönetin; rutin değişiklikleri dağıtım hattından geçirmek izlenebilirliği kolaylaştırır. Acil insan müdahalesi için kayıtlı bir istisna yolu gerekir.

Arayüzden acil müdahale gerekiyorsa kim, neyi, neden ve ne zaman değiştirdiğini kaydedin. Hedef ile depo arasındaki farkı raporlayan denetim bu değişikliği görünür kılar; ardından kalıcı karar depoya işlenir. Farkın otomatik geri yazılması her durumda doğru değildir.

SAPMA DENETİMİ — TANIMLI JSON GİRDİLERİ

```
import json
from pathlib import Path
from tools.sapma import drift

expected = json.loads(Path("fixtures/expected_rules.json").read_text())
actual = json.loads(Path("fixtures/actual_rules.json").read_text())
for rule_id, reason in drift(expected, actual):
    print(rule_id, reason)
# Her iki girdi rule_id/query/enabled/severity/... içeren nesne listesi.
# Ham API kimliği ve ek alanlar yönetilen alanlarla karıştırılmaz.
```

10.10 Topluluk kurallarını içeri almak

Topluluk ve ürün içerikleri bir başlangıç sağlayabilir. Kullanacağınız içeriğin lisansını ve sürümünü kaydedin; veri ihtiyacını, sınırlarını ve yerel kabul testini inceleyin. Hazır içeriği seçmek ile onu üretimde doğrulamak farklı işlerdir.

Yerel değişikliği upstream dosyasına doğrudan yazmak, yeni sürümün alınmasını zorlaştırabilir. Özgün kaynak ve yerel farkı ayrı tutun. Bu yapı çakışmayı ortadan kaldırmaz; değişen koşulları ve birleşmiş çıktıyı incelemek gerekir.



Şekil 10.5 Kaynak ve yerel farkın birleştirilmesi; yeni çıktı tekrar doğrulanır.

Çözüm, upstream'i **hiç düzenlememektir**. Topluluk kuralları depoya olduğu gibi girer ve hiç dokunulmaz; ortamınıza özgü değişiklikler ayrı bir `overrides/` katmanında, yalnızca *farklar* olarak tutulur. Derleme sırasında bir birleştirici ikisini üst üste bindirir.

ÖZEL OVERLAY — SIGMA KURALI DEĞİLDİR

```
id: e011a729-98a6-4139-b5c4-bf6f6dd57c07
revision: dwell-override-r1
level: high
add_filters:
  filter_env_pki:
    User: 'CORP\svc_pki'
    ParentImage: 'C:\Program Files\PKI\pki-agent.exe'
x_exclusions:
  filter_env_pki:
    reason: Örnek PKI işi; gerçek olayla doğrulanır
    ticket: DWELL-EXAMPLE
    review_date: '2026-12-01'
# tools/override.py eski condition'ı korur; filtre adı çatışırsa durur.
# Çıktı experimental olur; önceki başarılı doğrulama devralınmaz.
```

Birleştirici upstream condition'ını parantez içinde korur, yeni dışlamayı onun sonuna and not ile ekler. Yeni filtre adı mevcut adla çakışırsa durur. Değişen mantık, upstream'in stable durumunu veya eski doğrulamasını devralmaz; test ve doğrulama yenilenir.

Upstream dosyasını değiştirmemek güncellemeyi kolaylaştırır; yine de yeni condition, alan veya filtre adı override'la çatışabilir. Sürüm geçişinde birleşmiş çıktı ve testler yeniden incelenir.

TOPLULUK İÇERİĞİNİ YEREL KABULDEN GEÇİRİN

Bu kitabın politikasında yeni ithal edilen içerik önce experimental olarak değerlendirilir. Sigma status alanı kendiliğinden gölge çalışma veya alarm yönlendirmesi kurmaz. Gölge çalışmayı dağıtım manifesti, enabled ayarı ve ayrı çıktı yönlendirmesi belirler.
Üretime geçişte telemetri, varyant kanıtı, gürültü ve araştırma yükü ölçülür. Bütün kuralları incelemeden açmanın kaç alarm üreteceği veya kaçının kabul edileceği önceden sayıyla söylenemez.

10.11 Çok müşterili kütüphane

Bir hizmet sağlayıcıda ya da birden çok iş birimine hizmet veren bir ekipte, aynı kural kütüphanesi farklı ortamlarda çalışır. Her ortamın kendi baseline'ı, kendi meşru araçları ve kendi kritik varlıkları vardır.

Müşteriler için bağımsız kopyalar tutmak, ortak bir düzeltmenin birden çok yerde uygulanmasını gerektirebilir. Buna karşılık bütün ortamları tek bir müşterinin gürültüsüne göre daraltmak, diğer ortamlarda gerekli kapsamı azaltabilir. Ortak mantığı ve yerel farkları ayrı yönetin; her birleşmiş çıktıyı kendi verisi ve kabul koşullarıyla sınayın.



Şekil 10.6 Ortak çekirdek ve ortam farkları; her birleşmiş hedef ayrı kabul edilir.

Ortak davranış mantığını çekirdekte tutup müşteri veya ortam farklarını ayrı yönetmek yararlıdır. Bu katman yalnız eşik ve dışlamadan oluşmayabilir: alan eşlemesi, veri kümesi, platform bağı ve etkinlik durumu da farklılaşabilir. Her farkın nedenini ve testini koruyun.

MÜŞTERİ MANİFESTİ — SIGMA STATUS'TAN AYRI

```
customer: example-a
platform: qradar
rules:
  DE-0031:
    deployment_state: production
    enabled: true
    severity: critical
  DE-0077:
    deployment_state: shadow
    enabled: true
  DE-0102:
    deployment_state: disabled
    enabled: false
    reason: Örnek ortamda gereken süreç telemetrisi yok
# Bunlar özel manifest alanlarıdır, Sigma status değeri değildir.
```

reason, kapalı tutulan bir kuralın gerekçesini kaydetmeye yarar. Müşteri kapsam raporu hazırlanırken manifest ve bu gerekçe birleştirilmelidir. Paketteki kapsama betiği müşteri manifestini kendiliğinden okumaz; bu birleştirme ayrıca uygulanacak bir tasarım adımıdır.

TEKRARLANAN ORTAM FARKINI İNCELEYİN

Aynı override birden çok ortamda görülüyorsa ortak çekirdek için aday olabilir. Önce nedenin ve alan anlamının gerçekten aynı olduğunu gösterin; sonra bütün etkilenen ortamların testlerini çalıştırın. Üç ortamda tekrar etmesi tek başına çekirdeğe taşıma ölçütü değildir.

KONUK KATKI — AYNI KURAL, FARKLI ORTAM

Sarp Gezer Tehdit Tespit Mühendisi

Aynı kuralın farklı ortamlarda farklı davranması beklenebilir. Bir sunucu grubunda seyrek gerçekleşen işlem, başka bir grupta günlük işin parçası olabilir. Otomasyonun yoğun olduğu bir ortamda belirli komutların sık çalışması olağandır; aynı komutların bir kullanıcı bilgisayarında çalışması farklı bir değerlendirme gerektirebilir. Bu nedenle bir müşteride uygun görünen eşik veya istisna, başka bir müşteriye doğrudan taşınmamalıdır.

Ancak farkın ortamın normal işleyişinden kaynaklandığına karar vermeden önce veri tarafı kontrol edilir. Apache logları üzerinde yapılan bir çalışmada, farklı kaynakların log etiketleri aynı değildi ve mevcut ayrıştırma ifadesi bu biçimlerin tamamını karşılamıyordu. Kaynaklara uygun düzenleme yapıldıktan sonra iki kaynaktaki gerçek istemci IP'sinin doğru alana geldiği kontrol edildi. Kaynak IP'ye göre olayları gruplayan bir kural açısından bu, doğrudan sonucu etkileyen bir farktır. Parsing sorunu varken eşikleri karşılaştırmak, iki ortamın aynı bilgiyi ürettiğini varsaymak olur.

Ayrıca bir ortamda az alarm gelmesi, kuralın orada iyi çalıştığını tek başına göstermez. Gerekli loglar gelmiyor olabilir veya kuralın kullandığı alanlar dolmuyor olabilir. Bu nedenle çok alarm üreten ortam kadar sessiz kalan ortam da kontrol edilmelidir. Önce her iki ortamda kuralın ihtiyaç duyduğu verinin bulunduğu doğrulanır, ardından faaliyetlerin sıklığı ve iş içindeki karşılığı değerlendirilir.

Ortak tutulacak bölüm, tespit edilmek istenen davranışın mantığıdır. Ortama göre değişebilecek bölüm ise kuralın kapsamı ve eşikleridir. Örneğin başarısız girişleri izleyen bir kuralın temel amacı korunabilir, fakat olayların hangi kullanıcı veya kaynak üzerinden sayılacağı ortamın yapısına göre belirlenir. Değişken kullanıcı ya da IP listeleri gerektiğinde reference set üzerinden yönetilebilir. Burada listenin neye göre doldurulduğunun ve güncelliğinden kimin sorumlu olduğunun da belli olması gerekir.

Ayrı kural açma kararı, farkın ne kadar büyüdüğüne bağlıdır. Değişiklik yalnızca eşik veya kaynak grubu düzeyindeyse ortak yapı korunabilir. Ancak aynı faaliyet iki grupta farklı anlam taşıyorsa ve her grup için farklı koşullar gerekiyorsa, ayrı kurallar daha anlaşılır olabilir. Tek bir kurala sürekli istisna eklenmesi, zamanla hangi olayların hâlâ kapsamda olduğunu takip etmeyi zorlaştırır. Diğer taraftan gereksiz yere çoğaltılan kurallar da bakım yükü oluşturur; ortak bir hata düzeltildiğinde bütün kopyaların gözden geçirilmesi gerekir.

Bu nedenle her düzenlemede değişen koşulun yanında gerekçesi de tutulmalıdır. Bir eşiğin neden yükseltildiği veya bir hesabın hangi işlem için hariç tutulduğu sonradan anlaşılabilmelidir. İlgili hesabın görevi değiştiğinde ya da uygulama başka bir sisteme taşındığında, bu kayıt sayesinde istisnanın hâlâ geçerli olup olmadığı yeniden değerlendirilebilir.

10.12 Depodan türeyen metrikler

Depo kural durumu, test dosyası ve doğrulama kaydı gibi metadata ölçülerini üretir. Alarm isabeti, çalışma yükü ve hedefte gerçekten etkin olup olmadığı için SIEM ve dağıtım kayıtları da gerekir.

Gösterge	Paketteki karşılığı	Kanıt sınırı
Durum bazında kural sayısı	status alanlarının sayımı	Hedefte enabled olduğunu göstermez
Güncel doğrulama sayısı	core.rule_is_validated; tutarlı iki kayıt	Kayıt politikasını sağlar; ham kanıtı doğrulamaz
Doğrulama yaşı ortancası	Güncel başarılı kayıtların yaşları	Başarısız/eskimiş kayıtlar ayrı gösterilir
Testsiz kural	Bitişik .test.yml dosyası yokluğu	Dosya varlığı test kalitesini göstermez
Süresi geçmiş dışlama	review_date denetimi	Yerel gözden geçirme politikasını gösterir
Ek analiz: kalıp/dışlama sayısı	Etiket ve seçimler ayrıca sayılabilir	Bu özet betik üretmez; dayanıklılık kanıtı değildir
Ek analiz: hedef etkinliği/isabet	SIEM ve dağıtım kayıtları gerekir	Depo metadata'sından çıkarılamaz

Örnekte metrik.py metadata göstergelerini üretir. Çalışma zamanı ve alarm ölçülerini ayrıca birleştirin. Eksik test veya süresi geçmiş dışlama, araştırılacak bir iş listesi oluşturur.

DEPO METRİKLERİ — SADECE METADATA

```
import json
from tools.metrik import metrics

print(json.dumps(metrics("rules", "2026-10-06"), ensure_ascii=False, indent=2))
# ISO dizge ve date türü desteklenir; gelecekteki başarı kabul edilmez.
# Noktalı dosya adı korunur: office.ps.yml → office.ps.test.yml.
# Alarm isabeti/etkin hedef durumu için SIEM kayıtları ayrıca gerekir.
```

10.13 Mevcut kütüphaneyi taşımak

Çoğu ekip sıfırdan başlamaz; yıllar içinde birikmiş bir SIEM kural setiyle işe başlar. Bunu depoya taşımak, 10.1'de uyardığımız toplu dışa aktarma tuzağına düşmeden yapılabilir; anahtar, taşımayı bir envanter çalışmasına çevirmektir.

Mevcut kuralları dışa aktarıp önce sınıflandırın. Aşağıdaki dört grup, depoya alınacak içerik ile bakım ve emeklilik işini ayırmak için bir öneridir.

Kategori	Ölçüt	Ne yapılır
Canlı	Son 90 günde çaldı ve gerçek olay üretti	Önce bunlar taşınır
Sessiz ama gerekli	Hiç çalmadı ama tekniği hâlâ geçerli	Taşınır, doğrulanır
Gürültücü	Çalıyor ama hep FP	Taşınmadan önce düzeltilir
Ölü	Çalmıyor ve tekniği geçersiz	Taşınmaz, kapatılır

Sınıflandırma, taşınacak ve emekliye ayrılacak kuralları görünür kılar. Her sınıfın büyüklüğünü envanterden hesaplayın; önceden çoğunluğun hangi kutuda olacağını varsaymayın. Taşınmayan kuralın gerekçesini de kaydedin.

Her kural için taşıma yolunu seçin. Mantık destekleniyorsa Sigma'da yeniden ifade edilebilir; hedefe özgü özellik gerekiyorsa yerel biçim korunabilir. Otomatik veya elle çevrilmiş çıktıyı aynı kabulden geçirin: veri anlamı, pencere, alan, çıktı ve önceki kanıtlarla karşılaştırma.

ÖRNEK — TAŞIMA EMEĞİNİ HESAPLAMAK

Bir pilot grupta metadata, çeviri, fixture, hedef replay ve inceleme için geçen kişi zamanını ölçün. Sonra taşınacak içerik sayısı ve karmaşıklığıyla plan yapın. Gölge ölçümünün takvim süresi aktif kişi zamanından ayrıdır. Bir kişinin her gün aynı sayıda kural taşıyacağına veya yarısının eleneceğine dair genel oran verilmez.

10.14 Küçük ekipte detection-as-code

Küçük ekip de aynı ilkeleri aşamalı uygulayabilir: önce envanter ve sürüm kontrolü, sonra test, ardından dağıtım ve bakım otomasyonu. Kurulum süresi mevcut altyapı ve içeriğe bağlıdır.

Önce kuralları ve değişiklik gerekçelerini bir depoda tutun. Ardından türüne uygun şema ve politika kontrolü, birim testi ve derleme ekleyin. Hedef doğrulama ve kabul süreci hazır olduğunda otomatik dağıtıma geçin. Takvimi ekibin kapasitesi ve mevcut kütüphanenin durumuyla belirleyin.

Dağıtım otomasyonunu doğrulanmış değişikliklere bağlayın. Test, inceleme, sahiplik, kabul ve geri alma birlikte kurulur. Otomasyon hatayı hızlı yayabilir; testlerin olması bütün dağıtımı risksiz yapmaz.

> **DİKKAT — HAT, DİSİPLİNİN YERİNE GEÇMEZ**
>
> Detection-as-code bir araç kümesidir; tespit kalitesini kendiliğinden artırmaz. Testleri olmayan bir depo, kuralların kötü olduğunu daha düzenli biçimde kaydeder. Metadata'sı zorunlu ama içeriği özensiz doldurulmuş bir kütüphane, boş alanlardan daha kötüdür; çünkü doluluk yanılsaması yaratır.
>
> Hat, disiplini *uygulanabilir* kılar. Uygulanacak disiplin yoksa, hat yalnızca bir dosya deposudur.

Bir sonraki bölüm depodaki içeriğin bakımına ayrıldı: sessizlik, dışlama borcu, yeniden doğrulama ve emeklilik kararları.

BÖLÜM 11

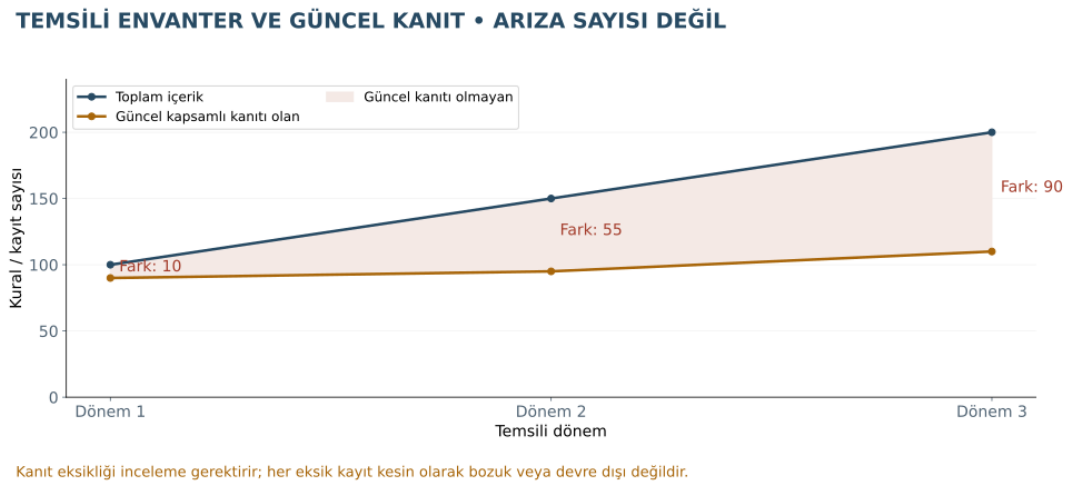
Tespit Borcu ve Kütüphane Bakımı

Kütüphane büyüdükçe bakım ihtiyacı da büyür. Bu bölüm sessiz bozulmanın biçimlerini, gözden geçirme takvimini ve emeklilik kararını ele alıyor.

11.1 Kütüphane neden çürür

Yeni tehdit, varlık ve veri kaynakları yeni içerik gerektirebilir. Kütüphane ise yalnız ekleme yoluyla yönetilmemelidir: inceleme, onarma ve gerekçeli emeklilik de rapora girer. “Yeni kural sayısı” bu işlerin tamamını göstermez.

Kaynak sürümü, alan anlamı, uygulama veya davranış değiştiğinde mevcut kuralın varsayımları bozulabilir. Hangi revizyonun hâlâ uygun olduğunu bakım kanıtıyla değerlendirin; her kuralın mutlaka belirli bir sürede bozulacağını varsaymayın.



Şekil 11.1 Temsili içerik ve güncel kanıt sayıları; aradaki fark arıza sayısı değildir.

Şekil 11.1’deki fark, güncel kanıtı olmayan içeriktir. Bunun tamamını bozuk kural diye sayamayız; bazı kayıtlar eskimiş, bazı davranışlar nadir, bazı tespitler arızalı olabilir. Tespit borcunu inceleme sonucuyla adlandırın; eksik kanıtı başarılı tespit diye raporlamayın.

> **TANIM — TESPİT BORCU**
>
> Etkin görünen içeriğin hedeflediği işi artık yerine getirmeyen veya geçerliliği belirsiz kısmı ve birikmiş bakım işidir. Eski doğrulama yaşı inceleme sinyali olabilir; tek başına her kuralı aynı büyüklükte borç birimi yapmaz. Risk, kapsam ve onarım emeğiyle birlikte değerlendirilir.

Borcun bir de sinsi ikinci etkisi vardır. Bakımsız kütüphane yalnızca ölü kurallar barındırmaz; **canlı kuralların bakımını da zorlaştırır**. Beş yüz kurallık bir kütüphanede hangi elli tanesinin gerçekten çalıştığını bilmiyorsanız, bir log kaynağı değiştiğinde neyin etkilendiğini de bilemezsiniz. Borç, kütüphaneyi yalnızca büyütmez; okunamaz kılar.

11.2 Bir kural nasıl körelir

Körelmenin farklı biçimleri vardır. Aşağıdaki göstergeler hangi arızayı araştıracağımızı ayırmaya yardımcı olur.

İNCELENECEK BEŞ DEĞİŞİM TÜRÜ

Olası değişim	Örnek gösterge	Tamamlayıcı kontrol
Kaynak kesildi	Hacim / gönderen varlık düştü	Envanter, zaman ve toplayıcı
Alan değişti	Doluluk, tür veya anlam değişti	Ham kayıt ve sözleşme karşılaştırması
Dışlama genişledi	Kapsam ve pozitif fixture kaybı	Birleşmiş koşul ve kaçış testleri
İş bağlamı eskidi	Varlık/politika artık farklı	Güncel ihtiyaç ve yetki kaydı
Davranış varyantı değişti	Kontrollü test eşleşmedi	Yürütme–olay–hedef zinciri

Örnek göstergeler teşhisi başlatır; tek başına nedeni veya her arızanın yakalanacağını kanıtlamaz.

Şekil 11.2 İncelenecek beş değişim türü ve örnek göstergeler.

Alan kayboldu. Kaynak sürümü veya ayrıştırma değişmiş olabilir. Doluluk izlemesi, alan sözleşmesi, örnek kayıt ve replay birlikte sorunu gösterebilir. Alan dolu ama anlamı yanlışsa yalnız doluluk yeterli olmaz.

Kaynak sustu. Bir sunucu grubu emekli oldu, bir ajan kaldırıldı, bir toplayıcı bozuldu. Kural sağlamdır ama bakacağı veri gelmiyordur. Bunu log kaynağı sağlık izlemesi yakalar.

Dışlama şişti. Eklenen filtreler tespitin kapsamını daraltabilir. Filtre sayısı bir uyarı sinyalidir; tek başına etkisini ölçmez. Eski ve yeni mantığı aynı olay kümesinde karşılaştırın, pozitif örneklerin ne kaybettiğine bakın.

Ortam değişti. Kuralın hedeflediği araç ya da uygulama artık kullanılmıyor. Kural doğru çalışıyordur ama yakalayacağı bir şey kalmamıştır. Bunu ancak son çalma tarihiyle birlikte bir insan yorumu ayırt edebilir.

Teknik değişti. Kural yalnız eski varyantı görüyor olabilir. Güncel emülasyon varyantları, olay dersleri, tehdit araştırması ve kapsam incelemesi bu boşluğu ortaya çıkarabilir.

> **ÖRNEK — DIŞLAMALARIN BİRİKEN ETKİSİ**
>
> Ayrı ayrı makul görünen dışlamalar birleşince kuralın kapsamını daraltabilir. Aynı dönem olaylarını eski ve yeni mantıktan geçirin. Azalan meşru eşleşmeyle kaybolan pozitif varyantı ayrı raporlayın. Yüzde hesaplanacaksa veri kümesi ve payda kaydedilmelidir.

11.3 Sessizliği okumak

Sessiz kural sağlıklı da olabilir, bozulmuş da olabilir. Önce etkin envanter, kaynak sağlığı, ihtiyaç ve son kontrollü doğrulama birlikte incelenir.

Hedef davranışın ortamda bulunmaması veya nadir olması, sessizliğin olası açıklamalarındandır. Veri, alan, zaman, mantık ya da hedef etkinlik sorunu da alarmı engelleyebilir. Bu seçenekleri ayırmak için envanter, kaynak sağlığı, ham olay ve kontrollü koşu kanıtını birlikte inceleyin.

Şekilde son dönemin alarm gözlemini güncel kontrollü kanıtla birlikte ele alıyorum. Bu bir inceleme modelidir; iki eksen bütün nedenleri açıklamaz. Alarm olmayan dönemde isabet oranı tanımsız olabilir. Alarm varsa etiketli inceleme sonucunu ayrıca ölçün.



Şekil 11.3 Alarm gözlemi ve güncel kontrollü kanıta göre inceleme matrisi.

"Sağlıklı" sınıfındaki kurallar da veri ve ortam değiştikçe gözden geçirilir. "İncele" sınıfı gürültü veya kalite sorununa işaret eder. Nadir bir davranışı hedefleyen kural uzun süre alarm vermeyebilir; sessizliği kabul etmek için veri sağlığına ve güncel kontrollü doğrulamaya bakın.

Veri veya doğrulaması şüpheli kuralın nedenini araştırın. Başarı kanıtı güncel ve aynı revizyona ait değilse haritada güncel doğrulama olarak gösterilmemelidir.

> **SAHADAN NOT — SESSİZ KURAL TARAMASI**
>
> Etkin kural envanterini temel alıp son 90 günün alarm sayısını rule_id ile ekleyin; eşleşmeyen sayaçları sıfır yapın. Sonra kaynağın sağlığını ayrı envanterden ekleyin. Veri var ama alarm yok sonucu otomatik olarak kural arızası değildir: davranış nadir olabilir. Ham veri yeterliliği ve kontrollü doğrulama bu ayrımı tamamlar.

SESSİZ KURAL — ENVANTER TEMEL ALINIR

```
index=alerts earliest=-90d rule_id=*
| stats count AS tetikleme BY rule_id
| inputlookup append=t kutuphane.csv
| stats sum(tetikleme) AS tetikleme values(logsource) AS logsource
        values(enabled) AS enabled BY rule_id
| fillnull value=0 tetikleme
| where tetikleme=0 AND enabled="true"
| lookup source_health.csv logsource OUTPUT events_24h telemetry_contract_ok
| eval teshis=case(isnull(events_24h),"sağlık kaydı yok",
  events_24h=0,"veri yok",telemetry_contract_ok!="true","alan sözleşmesini incele",
  true(),"veri var; davranış ve doğrulama incelenecek")
# kutuphane.csv tek rule_id için tek satırdır.
# source_health.csv ayrı, kontrollü işin çıktısıdır; map limiti yok.
# enabled, hedefteki gerçek etkinlik durumundan alınır; status değildir.
```

11.4 Gözden geçirme takvimi

Bakım için sorumlu ve ayrılmış zaman tanımlayın. Takvimli kontrol, değişiklik uyarısı ve olaydan öğrenme birlikte çalışabilir; yalnız boş zaman bulunmasını beklemek işin birikmesine yol açabilir.

Aşağıdaki ritmi başlangıç planı olarak öneriyorum. Süreler temsili tahminlerdir; gerçek iş yükünü ilk turlarda ölçüp takvimi buna göre ayarlayın.

Sıklık	Başlangıç kapsamı	Temsili süre	İş
Haftalık	Öncelikli gürültülü kurallar	1–2 saat	Tuning kuyruğunu değerlendir
Aylık	Yeni sessizleşen kurallar	Yarım gün	Veri ve doğrulama teşhisi
Üç aylık	Planlanan kütüphane dilimi	1–2 gün	Dışlama ve emeklilik incelemesi
Yıllık	Tehdit ve kapsama öncelikleri	Birkaç gün	Bilinen boşlukları yeniden değerlendir

Haftalık tur tuning döngüsüyle birleştirilebilir. Aylık tur yeni sessizlik ve veri değişikliklerini; daha geniş tur biriken kapsam ve dışlama işini ele alır. Atlanan turun sonraki emeği tam üç katına çıkaracağına dair ölçüm varsayılmaz.

Üç aylık tur kütüphanenin bütününe bakar: dışlamaların toplam etkisi, tekrar eden mantıklar, veri gereksinimleri ve öncelikli teknikler. Günlük regresyon ve dışlama denetimi de aynı sorunları daha erken gösterebilir.

BAKIMDA İKİNCİ GÖZÜ KULLANIN

İmkân varsa bakım incelemesini kuralı yazan kişiden başka biriyle yapın. Küçük ekipte belirli aralıklarla eşli inceleme düzenlenebilir. Gerekçe, sınır ve kanıtın depoda bulunması, kütüphane bilgisinin tek kişide kalmasını azaltmaya yardım eder.

11.5 Dışlama borcu

Dışlamalar tespit borcunun en hızlı biriken kalemidir, çünkü eklenmesi kolay ve kaldırılması korkutucudur. Kimse altı ay önce eklenmiş bir dışlamayı kaldırmak istemez; gürültünün geri gelmesinden çekinir.

Bölüm 4.4 ve 9.5'te her dışlamaya tarih, gerekçe ve gözden geçirme tarihi yazmayı önermiştik. Bu alanların karşılığı burada alınır: süresi dolan dışlamalar otomatik listelenir ve her biri üç sorudan geçirilir.

Dışlamanın nedeni hâlâ var mı, kapsamı değişmiş mi ve daha dar bir koşul kurulabilir mi? Araç veya hesap yetkisi değiştiğinde eski varsayım geçersiz olabilir. Daraltmanın yararını pozitif varyantlar ve meşru iş örnekleriyle ölçün; sabit bir iyileşme oranı varsaymayın.

DIŞLAMA DENETİMİ — YAPISAL KAYIT

```
from tools.dislama_denetimi import audit

for rule_id, filter_name, reason in audit("rules", "2026-10-06"):
    print(rule_id, filter_name, reason)
# Gerekçe/ticket/review_date: x_exclusions içinde, yorum regex'i değil.
# Sonuç yazma modülü bu alanları ve yorumları korur.
```

Bu pakette dörtten fazla dışlamayı inceleme uyarısı olarak kullanıyorum. Sayı yerel politikadır, teknik doğruluk eşiği değildir. Çok sayıda dışlama, geniş mantığı veya farklı iş bağlamlarını incelemek için bir işaret olabilir; az sayıda dışlama da güvenliği garanti etmez.

Mantığı ayrı senaryolara bölmek bazı durumlarda dışlama zincirini sadeleştirir. İki kuralın toplam kapsamını, tekrar alarmlarını ve bakım işini tek kuralla karşılaştırın. Dışlama sayısı tek başına kalite ölçüsü değildir.

11.6 Emekliye ayırmak

Bir kuralı kapatmak, çoğu ekipte psikolojik olarak zor bir karardır. Kural yazmak bir üretim, kapatmak bir kayıp gibi hissedilir. Oysa bakımlı bir kütüphanede emeklilik, tıpkı yeni kural yazmak gibi, normal bir işlemdir.



Şekil 11.4 Sessizlik incelemesinde önerilen kararlar; neden ve hedef durum ayrıca doğrulanır.

Sessizlikte önce yürütme, veri sağlığı, alan anlamı ve hedef etkinliği incelenir. Başarısız kontrollü testin nedeni kural, eşleme, zaman veya dağıtım olabilir. Davranış artık gerekli değilse gerekçeli emeklilik değerlendirilir. Güncel kontrollü başarı ve yeterli veri varsa sessizlik nadir davranışla uyumlu olabilir.

Emeklilikte mantığı ve karar gerekçesini geçmişte koruyun. Bu kitabın dağıtım politikasında deprecated kural üretim manifestinden çıkarılır. Sigma status alanı tek başına bütün araçlarda derlemeyi engellemez; geçmiş incelemesi için dosya yine derlenebilir. Hedefte devre dışı kalıp kalmadığı ayrıca doğrulanır.

EMEKLİLİK — METADATA PARÇASI

```
status: deprecated
x_deprecated_date: '2026-08-04'
x_deprecated_reason: Örnek yönetim aracı artık kullanılmıyor
related:
  - id: 5c0ea0a3-6946-470b-abf1-946fe3244020
    type: successor
# UUID öğretim örneği; gerçek successor kimliği bulunmadan kullanılmaz.
```

Emeklilik kayıtları bakım kararlarını görünür kılar. Sayının sıfır olması tek başına bakım yapılmadığını kanıtlamaz. Mevcut içeriğin hâlâ gerekli olduğu gösterilebiliyorsa sıfır emeklilik de açıklanabilir.

11.7 Kütüphane sağlık göstergeleri

Bölüm 10.12'de depodan türeyen metrikleri kurmuştuk. Bakım açısından bunların bir alt kümesi doğrudan sağlık göstergesidir ve zaman içindeki **eğilimleri** tek tek değerlerinden daha çok şey söyler.

Gösterge	Nasıl okunur	Örnek başlangıç politikası
Doğrulama yaşı	Risk ve değişim hızına göre	90 gün; kritiklerde daha kısa olabilir
Sessiz kural oranı	Nadirlik ve test kanıtıyla	Tek başına % eşiği verilmez
Dışlama sayısı	Kapsam kaybıyla birlikte	5 ve üzeri: inceleme sinyali; hata kanıtı değil
Süresi geçmiş dışlama	Gözden geçirme işi	0 hedefi; kayıt sahibine yönlendir
Emekli/yeni oranı	Karar gerekçesiyle	Sabit sağlıklı oran yok
Testsiz içerik	Depo politikasına göre	Desteklenen her dosyada test kaydı

Tablodaki eşikler başlangıç örneğidir. Sessiz fakat doğrulanmış kritik kuralların oranı yüksek olabilir. Emekli/yeni oranı da tek başına sağlık notu değildir; kararların gerekçesi ve kapsam etkisiyle okunur.

Bu göstergelerin bir panoya konması gerekmez; üç aylık turun başında bir kez çalıştırılıp önceki turla karşılaştırılması yeterlidir. Asıl değeri, bakım işini “ne kadar zaman ayırdık” yerine “kütüphane hangi yönde gidiyor” sorusuna bağlamasıdır.

11.8 Bakımı işin içine yerleştirmek

Bakımın sahibi ve ayrılmış zamanı yoksa iş ertelenebilir. Kapsam kaybının riskini de yeni geliştirme işiyle birlikte önceliklendirin.

Bakım için korunmuş zaman ayırmak, yeni kabul sırasında mevcut içerikten birini gözden geçirmek veya dönemsel bakım turu planlamak kullanılabilecek üç yaklaşımdır. Oranı, kapsamı ve sıklığı önce ölçülen borç ve ekip kapasitesiyle belirleyin; bunları evrensel süreler olarak önermiyorum.

Seçtiğiniz yöntemde bakım işi, sorumlusu ve tamamlanma koşulu görünür olmalıdır. Küçük ya da büyük ekip için otomatik olarak tek doğru yöntem yoktur; birikmiş iş ve yapılan bakımın sonuçları planı değiştirebilir.

> **BAKIMIN SONUCUNU RAPORLAYIN**
>
> Yeni içerikle birlikte onarılan, gerekçeyle emekli edilen ve dışlaması incelenen kuralları da raporlayın. Sayıların yanında etkisini ve kanıtını gösterin. “12 yeni tespit, 9 onarım, 4 emeklilik, 23 dışlama incelemesi” yalnız temsili bir rapor cümlesidir; gerçek değerleri kendi kayıtlarınızdan alın.

11.9 Bir bakım turu, baştan sona

Aşağıdaki bakım turu temsili bir planlama örneğidir; süre ve sayılar saha ölçümü olarak sunulmaz. Başlangıç kümesi 300 etkin kuraldır.

> ÖRNEK — ÜÇ AYLIK BAKIM TURU
>
> **1. Ölçüm (1 saat).** Depo metrikleri ve sessiz kural taraması çalıştırılır. Çıktı: 300 kuralın 41'i son 90 günde hiç çalmamış, 18 kuralda dörtten fazla dışlama var, 7 dışlamanın süresi dolmuş, doğrulama yaşı ortancası 112 gün.
>
> **2. Ayrıştırma (1 saat).** 41 sessiz kural iki gruba bölünür: 12'sinin log kaynağı veri göndermiyor (altyapıya bilet açılır), 29'u incelenecek.
>
> **3. Sessizlik teşhisi (4 saat).** 29 kural emülasyonla sınanır. Sonuç: 11'i çalışıyor (nadir ama sağlam, gerekçesi yazılır), 13'ü körelmiş (alan değişimi ya da dışlama şişmesi), 5'inin tekniği geçersiz.
>
> **4. Onarım (5 saat).** 13 körelmiş kural düzeltilir, testleri güncellenir, yeniden doğrulanır. Bu adım turun en uzun kısmıdır.
>
> **5. Emeklilik (1 saat).** 5 kural `deprecated` yapılır, gerekçeleri ve varsa yerini alan kural yazılır.
>
> **6. Dışlama denetimi (3 saat).** 18 şişmiş kuraldaki dışlamalar gözden geçirilir; 23 dışlama daraltılır, 4'ü tamamen kaldırılır, 2 kural ikiye bölünür.
>
> **7. Raporlama (1 saat).** Önceki turla karşılaştırmalı sağlık tablosu çıkarılır ve paylaşılır.

Bu temsili turda beş etkin kural emekli edilir: 300 − 5 = 295. İki etkin kuralın her biri iki yeni kurala ayrılır; eski iki kimlik pasifleşir, dört yenisi eklenir: 295 − 2 + 4 = 297 etkin kural. Tarihçe dosyaları depoda kaldığı için dosya sayısı başka bir ölçüdür. Doğrulama yaşı ortancasının yeni değeri, bütün güncel kayıtlar hesaplanmadan söylenemez.

Önceki incelemenin kayıtları, sonraki turda tekrar araştırmayı azaltabilir. Yeni veri kaynağı veya platform değişikliği ise işi büyütebilir. Bakımın süresini ve kalan borcu her turda ölçmek, takvimin işe yarayıp yaramadığını gösterir.

Kütüphaneyi yaşatmayı kurduk. Ama buraya kadar kuralları hep platformdan bağımsız düşündük. Gerçek bir ortamda kural, belirli bir SIEM'de çalışır ve her platformun kendine özgü kısıtları, güçlü yanları ve tuzakları vardır. Bir sonraki bölüm bu iniş anını ele alıyor: aynı tespiti QRadar, Splunk, Elastic ve Sentinel üzerinde kurmak, ve her birinde nelere dikkat etmek gerektiği.

BÖLÜM 12

Platforma İndirmek

> *Buraya kadar tespitleri platformdan bağımsız düşündük. Gerçek bir ortamda ise kural belirli bir SIEM'de çalışır ve her platformun kendi veri modeli, korelasyon mimarisi ve alarm nesnesi vardır. Bu bölüm aynı tespitin QRadar, Splunk, Elastic ve Sentinel üzerinde nasıl kurulduğunu ve her birinde nelere dikkat edilmesi gerektiğini ele alıyor.*

12.1 Çeviri neden yeterli değil

Bölüm 4.8'de bir Sigma kuralını `sigma convert` ile hedef platformun diline çevirdik ve orada bir uyarı vardı: çeviri bir doğrulama sayılmaz. Şimdi o uyarının nedenini açıyoruz.

Sigma derlemesi mantığı hedef dile taşır; pipeline alan eşlemesi ve ek dönüşümler de uygulayabilir. Buna rağmen kaynak verisinin gerçekten gelmesi, hedef ayarlar ve alarm çıktısı yalnız derleme sonucuyla doğrulanmaz. Beş ekseni birlikte değerlendirelim.

AYNI TESPİTİ HEDEFTE BEŞ EKSENDE BAĞLAMAK

	QRadar	Splunk	Elastic	Sentinel
Veri kaynağı	Log Source / QID	index / sourcetype	data stream	çalışma alanı tablosu
Alan bağlama	Custom Property	alan çıkarma	ECS / kaynak alanı	tablo + dönüşüm
Sorgu örneği	AQL	SPL	ES|QL / Lucene	KQL
Tespit örneği	CRE koşulları	zamanlanmış arama	EQL sequence	zamanlanmış sorgu
Çıktı / yanıt	Offense ayarı	Notable Event ayarı	Alert / Case ayarı	Alert / Incident ayarı

Örnek karşılıklardır; ürünlerin bütün tespit türlerini göstermez.
Sigma + pipeline desteği değişir. Veri, ayar ve çıktı hedefte doğrulanır.

Şekil 12.1 Aynı tespitin beş eksende farklı karşılık bulması. Derleme ve pipeline desteği, hedef kabulünün bir parçasıdır.

Veri kümesi, alanların anlamı, zamanlama, korelasyon desteği ve alarm çıktısı platforma göre bağlanır. Bir kısmı pipeline veya dağıtım yapılandırmasında ifade edilebilir. Hangi kısmın çevrildiğini ve hangisinin hedefte ayrıca kurulacağını belgeleyip gerçek kayıtlarla sınayın.

Bu bölümün amacı dört platformun eğitimini vermek değil — her biri için ayrı kitaplar var. Amaç, bir tespit mühendisinin her platformda **nereye bakması gerektiğini** ve hangi tuzakların o platforma özgü olduğunu göstermek.

12.2 Korelasyon mimarisi farkı

Korelasyonun yürütülme biçimi, aynı mantığın hedefteki zaman ve eşleşme davranışını etkileyebilir. Burada olay işleme ve zamanlanmış sorgu olmak üzere iki seçilmiş modeli karşılaştırıyorum. Bunlar ürünlerin bütün kural ve yürütme türlerinin sınıflandırması değildir.



Şekil 12.2 Seçilmiş olay işleme ve zamanlanmış sorgu modellerinin bekleme farkı.

Olay işleme modelinde QRadar CRE, işlenen olayları tanımlı testlerle karşılaştırır. Bu model sıfır gecikme demek değildir: toplama, işleme ve yanıt sürelerini ölçün. Yerel/global işlem kapsamını ve geç veriyi ayrıca sınayın.

Zamanlanmış modelde geçmişe bakan sorgu belirli aralıklarla çalışır. Bu bölüm Splunk ve Sentinel'in bu tür örneklerini ele alıyor; Splunk gerçek zamanlı alarmlar da sunar. Arama geçmişi, bekleme, yeniden çalışma ve tekilleştirme birlikte test edilir.

Geriye bakma süresi en az çalışma aralığı kadar olmalıdır. Eşit süreler ideal koşulda bitişik pencereler oluşturabilir. Ek payı toplama gecikmesi ve motorun çalışma davranışına göre seçin; örtüşen pencerelerde aynı olayı tekilleştirin. Örnekte 15 dakikada bir çalışan sorgu 30 dakikaya bakar; bu bir genel iki kat kuralı değildir.

> **DİKKAT — GECİKME BİLEŞENLERİ**
>
> Toplama, indeksleme, sonraki aramayı bekleme ve alarm işleme sürelerini ayrı ölçün. Beş dakikalık sabit aralıkta eşit dağılmış varış varsayımıyla bekleme ortalaması iki buçuk dakikadır; gerçek iş yükünde ölçülmeden aynı ortalama varsayılmaz.

12.3 QRadar

QRadar'da yalnız kural metnine bakmak yeterli değildir. Olayın ayrıştırılması, alanların CRE için kullanılabilirliği, mantık ve yanıt ayarları birlikte incelenir. Şekil 12.3 bu bağımlılıkların seçilmiş bir özetidir.



Şekil 12.3 QRadar veri, mantık ve yanıt bağımlılıklarının seçilmiş özeti.

DSM, kaynak alanlarını ayrıştırır; Event ID ve kategori bileşimi QID kaydına eşlenir. Eşlenmemiş kayıtta ham yük üzerinden bir koşul çalışabilir, fakat beklenen QID ve özellikleri isteyen mantık aynı sonucu vermeyebilir. Ham kayıtla çıkarılan alanları karşılaştırın.

QID bir olay sınıflandırma kaydının kimliğidir; kaynak olay kodu veya her ham olayın benzersiz kimliğiyle karıştırılmamalıdır. Kayıt ad, kategori ve önem gibi bilgileri bağlar. Yanlış eşleme, bu bilgileri kullanan kuralın sonucunu değiştirebilir.

Custom Property için aramada çıkarılma ile CRE'de kullanılabilirlik farklıdır. Kuralda kullanılacak alanın Rules and Search Indexing kapsamında etkin olduğu doğrulanmalıdır; yalnız arama anında hesaplanan alanı CRE'nin daha yavaş kullandığı varsayılmaz. QRadar sürümü, DSM, ifade kapsamı ve optimizasyon ayarını birlikte kaydedin.

Building block, yanıt üretmeyen ve kurallarda yeniden kullanılabilen test kümesidir. Varlık veya hesap grubunu ortak tanımda tutmak için kullanılabilir; her kuralın zorunlu bir building block'tan geçmesi gerekmez. Değişikliğin bağımlı kurallara etkisini test edin.

> **ORTAK KOŞULLARI BUILDING BLOCK İLE YÖNETMEK**
>
> Örneğin yönetim sunucularını tek bir koşul kümesinde tanımlayıp ihtiyaç duyan kurallarda kullanabilirsiniz. Değişiklik bütün bağımlı kuralların kapsamını etkileyebilir. Gerekçe, sürüm, sahiplik ve regresyon testi bu yüzden birlikte tutulur. Building block yalnız dışlama için değildir.

QRADAR — AQL; BELİRTİLEN ALAN SÖZLEŞMESİYLE

```
-- Event ID: sayısal 4688; aşağıdaki üç özellik TAM YOL/komut taşır.
-- DSM ve Custom Property adları bu örneğin yerel sözleşmesidir.
SELECT QIDNAME(qid) AS olay, "Process Name" AS surec,
  "Parent Process Name" AS ebeveyn, "Process CommandLine" AS komut,
  username, sourceip, starttime
FROM events
WHERE LOGSOURCETYPENAME(devicetype) = 'Microsoft Windows Security Event Log'
  AND "Event ID" = 4688
  AND "Parent Process Name" IMATCHES '.*\\(winword|excel|powerpnt)\.exe'
  AND "Process Name" IMATCHES '.*\\powershell\.exe'
  AND ("Process CommandLine" IMATCHES '.* -enc.*'
    OR "Process CommandLine" IMATCHES '.* -EncodedCommand.*')
LAST 24 HOURS
-- Genel hesap/host dışlaması yok; ortak Office kuralıyla aynı mantık.
-- CRE: aynı 4688/alan koşulları + açık response/offense index ayarı.
-- Özellikler CRE kullanımına etkin olmalı; QID tek başına varsayılmaz.
```

IMATCHES örnekte harf duyarsız kalıp eşleşmesi için seçildi. Her koşul regex gerektirmez; alan normalleştirilmişse uygun literal işleç daha sade olabilir. Çıkarım ve eşleşme maliyetini ölçün. QRadar Regex Monitor pahalı özellikleri devre dışı bırakabildiği için bu sağlık sinyalini de izleyin.

Offense indeksi, rule action/response ve response limiter ayrı ayarlardır. Tarihli IBM örneği bu seçenekleri gösterir; kurulu sürümde gerçek davranış sınanır. Gruplama alanını araştırma ihtiyacına göre seçin; her tetiklemenin aynı offense'e dönüşeceğini varsaymayın.

12.4 Splunk

Splunk'ta aynı mantık farklı sorgu biçimleriyle yazılabilir. Hız farkını, eşdeğer filtreler ve aynı zaman aralığı olmadan karşılaştırmayın. Bu bölüm bir performans benchmark'ı sunmuyor.

Splunk'ta zaman ve kaynak kapsamını daraltmak, sonucu değiştirmeyen seçici filtreleri hesaplamadan önce uygulamak iyi bir başlangıçtır. Komut türü ve alan çıkarma yeri de maliyeti etkiler. Değişiklikten sonra olay kümesini ve çalışma süresini aynı veri üzerinde karşılaştırın.

SPLUNK — AYNI OFFICE MANTIĞI

```
index=win sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational"
  EventCode=1 ParentImage IN ("*\\winword.exe", "*\\excel.exe", "*\\powerpnt.exe")
Image="*\\powershell.exe" CommandLine IN ("* -enc*", "* -EncodedCommand*")
| table _time host User ParentImage Image CommandLine

# AYRI ARAMA: CIM 6.4 Endpoint.Processes; normalizasyon ve hızlandırma kapsamı doğrulanır.
| tstats summariesonly=f count FROM datamodel=Endpoint.Processes
  WHERE Processes.parent_process_name IN ("winword.exe","excel.exe","powerpnt.exe")
    Processes.process_name="powershell.exe"
    (Processes.process="* -enc*" OR Processes.process="* -EncodedCommand*")
  BY Processes.dest Processes.user Processes.parent_process_path Processes.process
# TSIDX kullanımı; performans veya canlı eşdeğerlik ölçümü iddia edilmez.
```

tstats indekslenmiş alanları TSIDX üzerinden sorgular; hızlandırılmış veri modeli kullanımı için CIM eşlemesi ve model kapsamı doğru olmalıdır. summariesonly=t henüz özetlenmemiş olayları dışarıda bırakabilir. Hız uğruna farklı ebeveyn veya dışlama koşulu kullanmak aynı tespiti hızlandırmak değildir.

Bu bölümdeki notable örneği Splunk Enterprise Security 7.2 terminolojisini kullanır. Arama çıktısı, sonuç/gruplama ve throttle ayarları birlikte incelenir. Bastırmanın aynı alan değerini taşıyan yeni bir olayı da gizleyip gizlemediğini test edin.

12.5 Elastic

Elastic entegrasyonları ECS eşlemesi sağlayabilir. Kurulu sürümde alanların ve türlerin gerçekten beklendiği gibi olduğunu örnek kayıtla kontrol edin; entegrasyon adı tek başına yeterli değildir.

Bu bölümde üç kural türünü örnekliyorum: Query, Threshold ve EQL sequence. Detection Engine başka türler de destekler. Seçim, ihtiyaç ve kurulu sürümün özelliklerine bağlıdır.

ELASTIC — SIRALI ÜÇ OLAY

```
sequence by host.id, user.name with maxspan=30m
  [process where event.type == "start" and
    process.parent.name in~ ("winword.exe","excel.exe","powerpnt.exe") and
    process.name in~ ("cmd.exe","powershell.exe")]
  [process where event.type == "start" and
    process.name : "certutil.exe" and process.command_line : "*-urlcache*"]
  [process where event.type == "start" and
    process.name : "schtasks.exe" and process.command_line : "*/create*"]
// Bu ortak kullanıcı/host zaman sırasıdır; süreç soyağacı değildir.
// sample sırasızdır ve maxspan desteklemez.
// Sırasız + aynı zaman sınırı ayrı korelasyon tasarımı gerektirir.
```

EQL örneği üç olayın sıralı ilişkisini arar; Bölüm 5.6'daki beş adımlı çizelgenin tamamı değildir. Her halka için bağımsız sinyaller de tutulursa eksik zincir ayrıca incelenebilir. sample sırasızdır ve maxspan desteklemez; aynı zaman sınırını yalnız sözcüğü değiştirerek koruyamazsınız.

Elastic runtime alanı sorgu zamanında değerlendirilir; veri ve sorgu yükünü ölçün. ES|QL'de sorgu anında hesaplanan sütun için EVAL kullanılır; yeni runtime alan tanımıyla aynı işlem değildir. QRadar'da CRE için etkinleştirilmemiş arama özelliğiyle de karıştırmayın.

12.6 Microsoft Sentinel

Sentinel'de kullanılabilecek veri, bağlanan kaynaklara ve tablo kapsamına bağlıdır. Bu bölümde Microsoft telemetrisi üzerinde KQL ile yazılan zamanlanmış sorguları ele alıyorum. Aynı alanın çalışma alanında bulunması ve kullanılan tespit türünün ayarları ayrıca doğrulanır.

Sentinel'de watchlist sorguya ek bağlam taşıyabilir. _GetWatchlist ve SearchKey eşlemesini gerçek veri üzerinde kontrol edin. Envanterin güncelliği, kimlik anahtarı ve eksik eşleşme davranışı da sözleşmede yer almalıdır.

KQL örneği, Microsoft Defender XDR bağlayıcısından Sentinel çalışma alanına gelen DeviceProcessEvents şemasını varsayar. TimeGenerated sonuçta korunur; MDE Timestamp ile aynı anlamda olduğu varsayılmaz. Bağlayıcı ve tablo kapsamı kendi çalışma alanında kontrol edilir.

SENTINEL — TIMEGENERATED KORUNUR

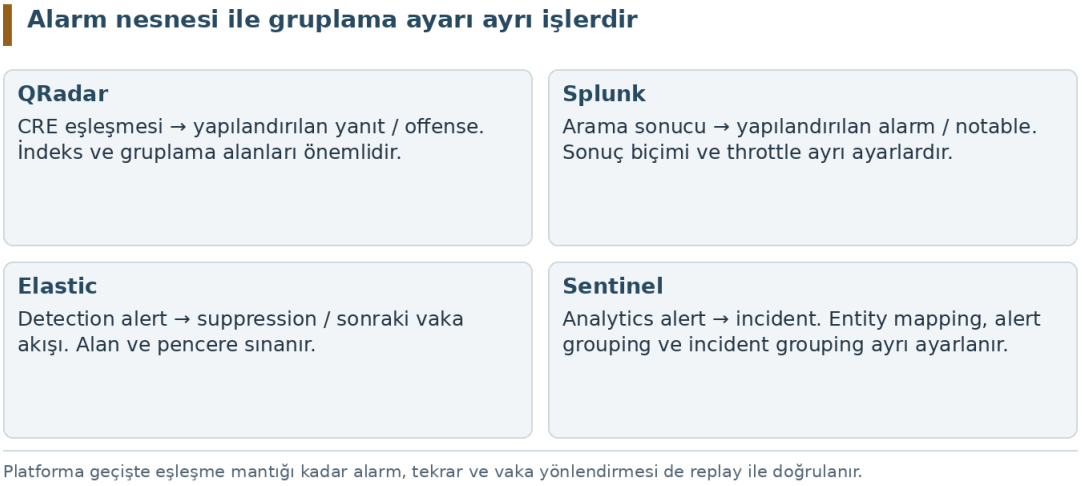
```
DeviceProcessEvents
| where TimeGenerated > ago(30m)
| where InitiatingProcessFileName in~ ("winword.exe","excel.exe","powerpnt.exe")
| where FileName =~ "powershell.exe"
| where ProcessCommandLine contains " -enc"
    or ProcessCommandLine contains " -EncodedCommand"
| project TimeGenerated, DeviceId, DeviceName, AccountDomain,
   AccountName, InitiatingProcessFileName, FileName, ProcessCommandLine
// Defender XDR bağlayıcısıyla Sentinel'e alınan tablo varsayımı.
// Azure Monitor DeviceProcessEvents tablosunda TimeGenerated bulunur; Timestamp burada varsayılmaz.
// queryFrequency: 15m; queryPeriod: 30m.
// Account/Host entityMappings ayrı; incident grouping ayrı yapılandırılır.
// Watchlist gerekirse SearchKey ve tanımlı kolon sözleşmesiyle kullanılır.
// Ortak başlangıç mantığında toplu hesap dışlaması yoktur.
```

entityMappings sonuçtaki alanı Account veya Host gibi varlıkla bağlar. Alert sonuç gruplaması ve incident grouping ayrı ayarlardır. Eşleme yapmak otomatik olarak seçtiğiniz incident politikasını kurmaz; her ayarı ayrıca tanımlayın.

Sorgu sıklığı işlem yükünü etkiler; faturaya etkisi veri katmanı ve fiyat planına bağlıdır. Analytics ingest/retention ücretlerini Data Lake sorgu ücretleriyle karıştırmayın. Maliyet hesabında plan, veri hacmi ve fiyat tarihini belirtin.

12.7 Alarm nesnesi ve gruplama

Kural eşleşmesinin ardından oluşan alarm, bastırma ve vaka gruplama davranışı araştırma yükünü değiştirir. Bu ayarlar mantıkla birlikte test edilir.



Şekil 12.4 Alarm/bulgu nesnesi ile gruplama ve bastırma ayarlarının ayrı okunması.

Bu örneklerde gruplama ve bastırma ayrı ayarlardır: QRadar offense indeksi ve response limiter; Splunk sonuç/throttle; Elastic suppression alanı ve süre; Sentinel alert/incident grouping. Platform değişiminde aynı ham olay ve beklenen çıktı üzerinden karşılaştırın.

Konu	QRadar	Splunk	Elastic	Sentinel
Olay nesnesi	Event; response ile offense	Sonuç; ürünle bulgu/notable	Detection alert	Alert; ayrı incident ayarı
Gruplama	Offense index alanı	Arama/sonuç ayarı	Kural türü/suppression	Alert + incident grouping
Bastırma	Response/limiter ayarı	Throttle alan ve süresi	Suppression alan ve süresi	Rule suppression; grouping ayrı
Zincir	CRE test ve building block	Uygun SPL korelasyonu	EQL sequence	KQL korelasyonu
Bağlam	Reference veri/özellik	Lookup	Enrich/lookup	Watchlist/lookup

12.8 Aynı tespit, dört platform

Bölüm 3.6'daki doğrudan Office → kodlanmış PowerShell örneğini dört hedefte düşünelim. Ortak mantık: üç Office ebeveyninden biri, powershell.exe ve belirtilen kodlanmış komut bayraklarından biri. Başlangıç kuralında genel hesap veya host dışlaması yoktur.

İş	Gereken doğrulama
Ortak mantık	Üç Office ebeveyni + PowerShell + kodlanmış komut; genel dışlama yok
QRadar	4688 alan sözleşmesi, CRE özellik etkinliği, aynı koşullar ve offense yanıtı
Splunk	EID 1 kapsamı; aynı koşullar; CIM/tstats özet kapsamı ve throttle
Elastic	Dataset/EID 1, ECS türleri, harf duyarlılığı ve suppression
Sentinel	Bağlayıcı/TimeGenerated, aynı üç ebeveyn, 15m/30m, ayrı grouping ayarları
Kabul	Aynı olaylar hedeflerde karşılaştırılır; sabit süre iddiası yok

Ortak kural; mantığı, kapsamı ve test örneklerini birlikte yönetmeyi kolaylaştırır. Her platformun alan eşlemesi, çalışma davranışı ve alarm çıktısı yine ayrı doğrulanır. Çevirinin zaman kazancını pilotta ölçün.

12.9 Platform değiştirmek

SIEM geçişinde sorgunun yanında veri anlamı, zamanlama ve alarm çıktısı da taşınır. Sürümlü kural ve test deposu karşılaştırmayı kolaylaştırır. Depo yoksa mevcut hedef envanteri ve geçmiş kayıtları temel alın; dört hedef için tek bir ürün belgesini kanıt saymayın.

Geçişte önce envanter ve kabul edilen kapsam belirlenir. Sonra kural, pipeline ve alarm ayarları hazırlanır. Aynı olaylar eski ve yeni hedefte karşılaştırılır; kapatma kabul ve geri alma koşullarıyla yapılır.

Paralel karşılaştırmada tek tarafın eşleşmediği kayıtları inceleyin. Neden alan, veri kapsamı, harf/null davranışı, pencere, sıra, gecikme veya farklı dışlama olabilir. Alarm sayısının aynı olması da tek başına aynı kapsamı kanıtlamaz.

> **SAHADAN NOT — GEÇİŞTE KAPSAM KARARI**
>
> Taşıma, kütüphaneyi gözden geçirmek için fırsattır. Gereksiz veya geçersiz içerik gerekçesiyle bırakılabilir; sessiz ama doğrulanmış kritik kural ise sırf çalmadı diye elenmez. Kaç kuralın taşındığı tek başına kazanılan veya kaybedilen kapsamı göstermez.

Platformları gördük. Geriye kitabın iki kapanış konusu kalıyor. Bir sonraki bölüm işin insan tarafını ele alıyor: tespit mühendisi rolünü kurmak, ekip içindeki yerini tanımlamak, hangi becerilerin gerektiği ve bu işte nasıl gelişileceği.

BÖLÜM 13

Rol ve Ekip

> *Buraya kadar işin kendisini anlattık. Bu bölüm onu yapan insanı ele alıyor: tespit mühendisinin gerçekte nasıl zaman harcadığını, hangi becerilere ihtiyaç duyduğunu, ekip içindeki arayüzlerini, rolün nasıl kurulup büyütüldüğünü ve başarısının nasıl ölçüldüğünü.*

13.1 Rolün doğuşu

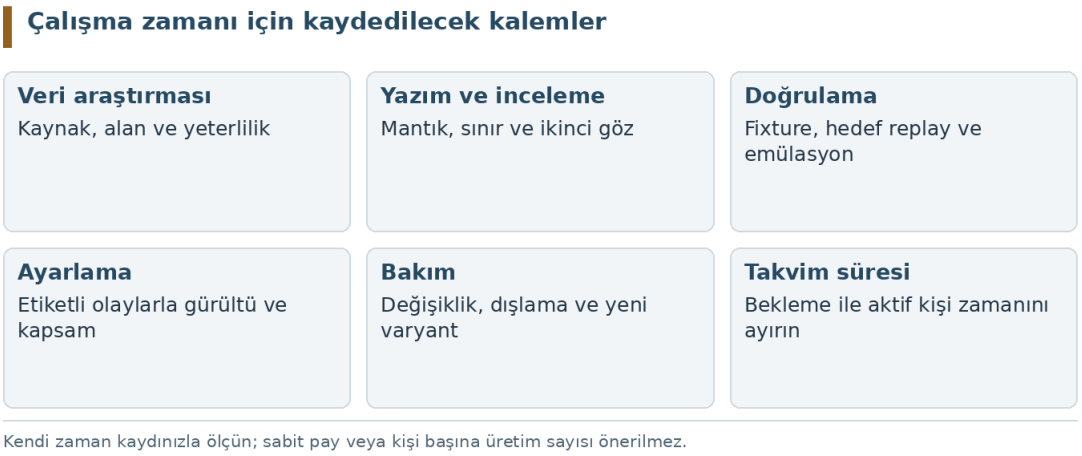
Bazı ekiplerde tespit işi SIEM yöneticisinin veya kıdemli analistin ek görevi olarak başlar. Veri, test ve bakım sorumlulukları büyüdükçe ayrı bir rol veya ayrılmış çalışma zamanı gerekir. Bu, bütün kurumlar için ortak bir unvan tarihi değildir.

Tespit işi kesintisiz çalışma zamanı ister. Aynı kişinin triyaj ve mühendislik yapması mümkündür; fakat kapasite ve nöbet düzeni buna göre ayrılmalıdır. Sürekli kesilen bir günde veri araştırması ve testin geri kalması şaşırtıcı değildir.

> **BAKIM VE GELİŞTİRME İÇİN ZAMAN AYIRIN**
>
> Tespit geliştirmeyi yalnız alarm kuyruğundan kalan zamana bağlamak planlamayı zorlaştırabilir. Ekibin kapasitesine göre kesintisiz çalışma zamanı ayırmayı öneriyorum. Tam zamanlı rol veya haftalık gün sayısı kurumun ihtiyacına bağlıdır; farklı uzunluktaki sürelerden evrensel verim sonucu çıkarmayın.

13.2 Zaman gerçekte nereye gidiyor

Tespit mühendisinin işi yazımdan fazlasını içerir. Veri araştırması, doğrulama, ayarlama ve bakım da iş planında görünür olmalıdır.



Şekil 13.1 Çalışma zamanını ölçmek için kalemler; sektör dağılımı veya sabit pay verilmez.

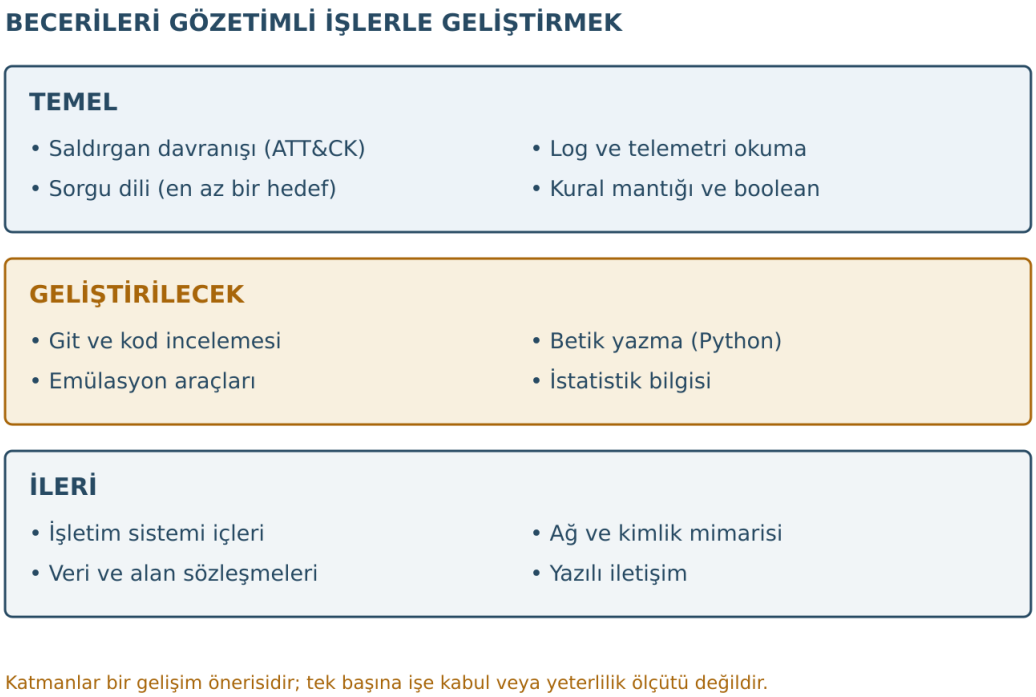
Veri araştırması, yazım, test, ayarlama ve bakım için kendi zaman kaydınızı tutun. Aktif kişi zamanı ile gölge ölçümündeki takvim süresini ayırın. Rolün iş yükünü bu kayıtlarla bütçelendirin.

“Ayda kaç yeni kural yazdın?” sorusu tek başına yeterli değildir. Bölüm 13.6’da doğrulanmış kapsam, bakım ve operasyon yüküyle birlikte ölçmeyi ele alıyorum.

Programın aşaması iş yükünü değiştirebilir. Yeni ortamda veri araştırması; büyüyen kütüphanede bakım daha çok zaman isteyebilir. Payları önceden sıralamak yerine düzenli ölçün.

13.3 Beceriler

Bu rol saldırgan davranışını, telemetriyi ve kod bakımını birleştiriyor. İşe alımda unvanın yanında hangi işin beklendiğini yazın; adayın o işi veri ve test kanıtıyla açıklayabilmesini değerlendirin.



Şekil 13.2 Beceri katmanları. Temel beceriler gözetimli çalışmayla geliştirilir; ileri beceriler zamanla eklenir.

Saldırgan davranışını, log okumayı ve boolean mantığını temel beceriler olarak görüyorum. Yeni başlayan kişi bunları gözetimli görevlerle de öğrenebilir. Bölüm 4.6'daki not 1 of ve not all of farkını somut olaylar üzerinde gösterebilmek yararlı bir değerlendirmedir.

Git, kod incelemesi ve betik becerisi tekrar eden işleri yönetmeye yardımcı olur. İstatistik bilgisi, örneklem ve referans dağılımını sorgulamak için gerekir. Gereken derinlik kullanılan model ve rolün sorumluluğuna bağlıdır.

İşletim sistemi bilgisi, bir davranışın neden belirli telemetriyi ürettiğini açıklamaya yardım eder. Yazılı iletişim de teslimatın parçasıdır: alarm özeti, inceleme yorumu ve bakım raporu başkasının karar vermesini kolaylaştırmalıdır. Bu becerileri gerçek işler ve geri bildirimle geliştirin.

> **DİKKAT — SERTİFİKA TEK BAŞINA YETERLİLİK DEĞİLDİR**
>
> GIAC GCDA ve SANS SEC555 gibi doğrudan SIEM/tespit alanında yollar vardır. Bunlar rolün bütün becerilerini tek başına garanti etmez. Adayın gerçek bir kaydı okumasını, mantığını açıklamasını, sınırlarını ve atlatma yollarını tartışmasını da isteyin.

13.4 Ekip içindeki arayüzler

Rolün diğer ekiplerden aldığı veriyi ve onlara devrettiği işi açıkça tanımlayın. Veri sahipliği, olay geri bildirimi ve emülasyon iş birliği bu arayüzlerin parçalarıdır.

DİĞER EKİPLERLE BEŞ BİLGİ ALIŞVERİŞİ

Arayüz	Tespit ekibine örnek girdi	Tespit ekibinden örnek çıktı
SOC / triyaj	Kapanış nedeni, yük, bağlam	Alarm sınırı ve araştırma adımı
Olay müdahalesi	Davranış, zaman ve kanıt	Yeni hipotez / erken sinyal testi
Tehdit istihbaratı	Aktör ve teknik bilgisi	Yerel veri ve kapsam sorusu
Altyapı	Kaynak ve değişiklik bilgisi	Olay/alan ihtiyacı, ölçülen hacim
Kırmızı / purple	Yürütme ve savunma sonucu	Varyant, veri ve kural test planı

Önerilen iş alışverişi; hangi arayüzün ne kadar kullanıldığı ekibin gerçek iş kayıtlarıyla ölçülür.

Şekil 13.3 Rolün diğer ekiplerle kurabileceği beş bilgi alışverişi.

SOC ve triyajdan kapanış nedeni, araştırma yükü ve meşru iş bağlamı gelir. Mühendis de alarmın sınırını ve ilk araştırma adımını iletir. Bu bilgi alışverişi Bölüm 9.7'deki ayarlama döngüsünü besler.

Olay müdahalesinden, "Bunu daha erken hangi veri ve mantıkla görebilirdik?" sorusunu taşıyorum. Tehdit istihbaratı ise davranış ve aktör bağlamı getirir. Her iki girdi kurumla ilişkisi, güncelliği ve eldeki telemetriyle değerlendirilir.

Altyapı talebini davranış, gereken olay ve pilotta ölçülen hacimle gerekçelendirin. Kapsam envanteri bu konuşmayı somutlaştırır; bakım ve kapasite planı da aynı masada değerlendirilmelidir.

Kırmızı takım ve purple team, seçilmiş davranışların yürütme ve savunma sonuçlarını paylaşır. Tespit ekibi de sınamak istediği varyantı, veri beklentisini ve kural revizyonunu iletir. Sonuç ancak koşunun gerçek kapsamıyla yorumlanır.

13.5 Rolü kurmak ve büyütmek

Tespit işi bir kişinin ek sorumluluğu olarak başlayabilir veya ayrı ekiple kurulabilir. Kapasite kararını bu başlangıç biçiminden çıkarmayın; geliştirme ve bakım kuyruğunu, ayrılmış zamanı ve veri değişim yükünü ölçün.



Şekil 13.4 Ekip kapasitesini değerlendirme ölçütleri; sabit kişi başına kural kotası verilmez.

Kapasiteyi ham kural sayısından çıkarmayın. Ayrılmış kişi zamanı, kural karmaşıklığı, otomasyon, veri değişim hızı ve bekleyen bakım işi birlikte ölçülür. Yeni geliştirme sürekli erteleniyorsa sebebi bu kalemlerde araştırın.

Bakım ve yeni geliştirme sürekli birikiyorsa kapasite artırılabilir; geçersiz veya gereksiz içerik gerekçesiyle emekliye ayrılabilir. Kritik fakat sessiz bir kuralın doğrulama kanıtını incelemeden sırf sayıyı azaltmak için kapatmayın.

İş yükü büyüdükçe veri ve telemetri, kural mantığı, doğrulama ve emülasyon sorumlulukları ayrı sahiplerde toplanabilir. Bu bir zorunlu ekip şeması değildir. Sınırlar katı olsa da olmasa da veri sözleşmesi ve doğrulama işinin sahibi açık olmalıdır.

13.6 Başarıyı ölçmek

Kural, bilet veya commit sayısı tek başına tespit kalitesini göstermez. Ölçünün neyi ödüllendirdiğini ve hangi davranışı görünmez bıraktığını değerlendirin. Aşağıdaki alternatiflerde de payda, örneklem ve kanıt kapsamı açık olmalıdır.

Tek başına yetersiz metrik	Sınırı	Daha yararlı tamamlayıcı
Kural sayısı	Kalite ve çalışmayı göstermez	Güncel kanıtı olan revizyon/varyant sayısı
Kapatılan bilet	Çözüm kalitesini göstermez	Tekrarlanan sorunun ve iş yükünün değişimi
ATT&CK kapsama yüzdesi	Varyantı ve paydayı gizleyebilir	Öncelikli listede kapsamı belirtilen kanıt
Alarm hacmi	Tehdit isabetini göstermez	Etiketli örneklemde isabet; bilinen kümede kapsama
Kod satırı / commit	Teslimat sonucu değildir	Veri sağlığı, regresyon ve bakım sonuçları

Çıktıyı yeni kural sayısıyla sınırlamayın. Öncelikli davranışlarda hangi varyantlar doğrulandı, tekrar eden yanlış alarm nasıl değişti ve güncel doğrulama kayıtlarının yaşı ne? Önceki ve sonraki değerler aynı dönem ve payda tanımıyla hesaplanmalıdır.

SAHADAN NOT — BAKIM İŞİ DE RAPORLANMALI

Bölüm 11.8'de bakımın görünmezliğinden söz etmiştik; bu sorunun bireysel karşılığı, bakım yapan mühendisin katkısının görünmemesidir. Yeni kural yazan kişi takdir edilir, kütüphaneyi ayakta tutan kişi edilmez.

Çeyreklik değerlendirmede bakım kalemlerini de yazılı hâle getirin: kaç körelmiş kural onarıldı, kaç dışlama daraltıldı, kaç kural emekliye ayrıldı, doğrulama yaşı nereden nereye geldi. Ölçülmeyen iş, zamanla yapılmayan iş hâline gelir.

13.7 Bu işte gelişmek

Bu bölüm için tek bir öğrenme yolu önermiyorum. Bölüm 13.3'teki eğitim ve sertifika seçeneklerinin yanında, gözetimli uygulama ve düzenli geri bildirim de gerekir. Aşağıdaki alışkanlıkları kendi çalışma planınıza uyarlayabilirsiniz.

Ortam bilgisini tehdit bilgisiyle birlikte geliştirin. Hesabın işi, aracın zamanı ve sunucunun rolü; ham kayıt, envanter, sistem sahibi ve doküman birlikte incelendiğinde anlaşılır. Tek bir veri kaynağını bu bilginin tamamı saymayın.

Kendi kuralınızı atlatmayı denemek, kapsamını öğrenmenin yararlı bir yoludur. Değişen araç, komut biçimi ve süreç zinciriyle testler kurun; bulduğunuz sınırı belgeleyin. Bunu yeni teknik öğrenme ve gerçek olay incelemesiyle birlikte yürütün.

Gerçek olay raporlarını okuyun. Tekniklerin hangi sırayla, hangi bağlam ve telemetriyle göründüğünü inceleyin; rapordaki boşlukları da kaydedin. Bu okuma, Bölüm 5.6'daki zincir fikrini laboratuvar ve kurum verisiyle sınamak için malzeme sağlar.

Windows sanal makinesi, Sysmon, toplayıcı ve Caldera; seçilmiş Windows süreç davranışları için bir laboratuvar başlangıcı olabilir. Bulut kimliği, ağ, çoklu makine veya farklı işletim sistemi senaryoları ayrı bileşen ister. Laboratuvarın üretimle hangi noktaları paylaşmadığını veri sözleşmesinde gösterin.

ÖRNEK — ÜÇ AYLIK GELİŞİM PLANI

Ay 1: Öncelikli bir davranış seçin; verisini ve farklı varyantlarını laboratuvarda inceleyin.
Ay 2: Kuralı yazın; birim, hedef ve emülasyon testini tamamlayın. Gölgede ölçün; kabul koşulları sağlanırsa üretime alın.
Ay 3: Yeniden doğrulayın, operasyon geri bildirimini inceleyin ve öğrendiklerinizi yazın. Bu bir planlama önerisidir; üretim öncesi doğrulama üçüncü aya ertelenmez.

BÖLÜM 14

Uçtan Uca Üç Vaka

Bu bölüm üç birleşik öğretim vakasını fikirden bakıma kadar izliyor. Biri doğrudan ilerliyor, biri veri boşluğuna çarpıyor, biri yeniden tasarlanıyor. Vakaları doğrulanmış olay raporu veya ürün benchmark'ı olarak okumayın.

14.1 Vakaları nasıl okumalı

Vakalar, metinde anlatılan kararları göstermek için birleştirilmiş ve sadeleştirilmiştir. Sayılar, süreler, hesaplar ve bilet adları temsilîdir; dayanak veri seti sunulmadığı için saha ölçümü olarak kullanılmaz. Asıl konu, her aşamada hangi kanıtın isteneceğidir.

Her vakada aynı iskeleti izleyeceğiz: fikrin kaynağı, veri kontrolü, kalıp seçimi, ilk kural, test, gölge ölçümü, tuning, doğrulama, üretim ve altı ay sonrası. Bu iskelet, Bölüm 1.2'de tanımladığımız üç çıktıyı — çalışan tespit, kanıt ve kapsama bilgisi — üretmek için gereken minimum yoldur.

14.2 Vaka 1 — Servis hesabıyla interaktif oturum

Bağlam. Orta ölçekli bir kurum, yaklaşık 900 Windows varlığı, QRadar. Tespit ekibi bir kişi. Fikir bir olay retrospektifinden geldi: bir saldırgan ele geçirdiği bir yedekleme servis hesabıyla RDP üzerinden birkaç sunucuya bağlanmıştı ve bu hiçbir alarm üretmemişti.

Servis hesabının interaktif oturum açmaması kurum politikası olabilir; hesabın adı veya "servis" etiketi bunu teknik olarak engellemez. İzinler ve hesap envanteriyle doğrulanmalıdır. Bu vakada domain servis hesapları için böyle bir politika olduğu varsayılıyor.

Veri kontrolü. 4624, LogonType ve hedef hesap SID'si incelenir. svc_ yalnız adlandırma ipucudur; hesap türü güvenilir envanterden alınır. Örnekte iki domain servis hesabı SID ile seçilir. Yerel servis hesabı aynı domain tekniği altında gösterilmez.

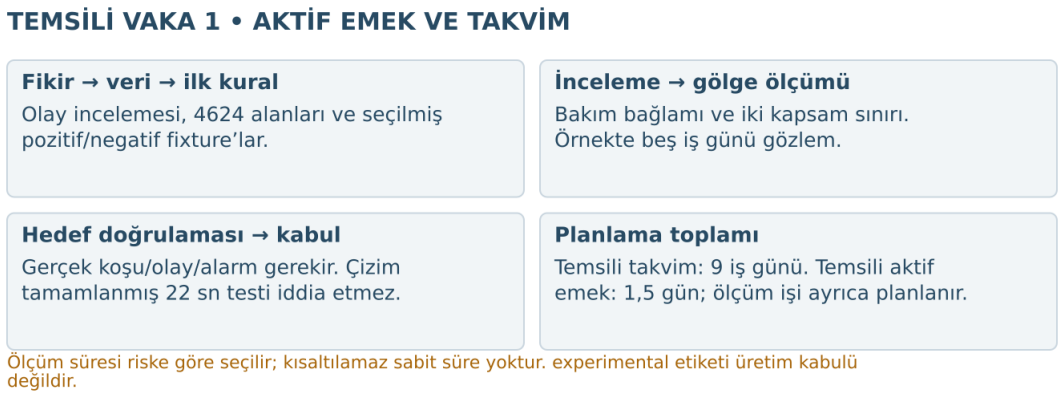
Kalıp seçimi. Bölüm 5'teki kalıplardan **ilişki kalıbı**: tek olay içinde iki alan arasındaki tutarsızlık (hesap türü ile oturum türü). Eşik ya da nadirlik gerekmiyor, çünkü tek bir olay tek başına anlamlı.

VAKA 1 — DOMAIN HESAP ENVANTERİNE DAYANAN KURAL

```
title: Envanterdeki domain servis hesabıyla interaktif oturum
id: 2c8d5f31-7a44-4e92-b1c6-9f3e2a7d5b08
status: experimental
description: >-
  Örnek envanterdeki domain servis hesabının 2 veya 10 türü oturumunu seçer.
  İsim öneki yerine kimlik envanteri esastır; 7 ve 11 ayrı inceleme kapsamıdır.
logsource: {product: windows, service: security}
detection:
  selection:
    EventID: 4624
    TargetDomainName: CORP
    TargetUserSid:
      - S-1-5-21-111-222-333-1101
      - S-1-5-21-111-222-333-1102
    LogonType: [2, 10]
  condition: selection
fields: [TargetUserSid, TargetUserName, LogonType, IpAddress, Computer]
falsepositives: [İnteraktif erişim için açıkça yetkilendirilmiş bakım]
level: high
tags: [attack.lateral-movement, attack.t1078.002, pattern.relationship]
x_rule_revision: dwell-1.1-service-logon-r1
```

Test. 2 (Interactive) ve 10 (RemoteInteractive) pozitif; 5 (Service), 3 (Network) ve envanter dışı kimlikler negatif örnektir. Domain ve SID koşulu ayrıca sınanır. Hesap adının svc_ ile başlaması tek başına pozitif değildir.

İnceleme. Adlandırma deseni yerine hesap envanteri kullanılır. 7 (Unlock) ve 11 (CachedInteractive) farklı olay kapsamlarıdır; gereken kimlik ve politika doğrulanarak ayrı kurala veya açıkça genişletilmiş kapsam testine alınır. Bu bölümde gösterilen ilk kural 2 ve 10'u kapsar.



Şekil 14.1 Temsili vaka planı: 9 iş günü takvim, 1,5 gün aktif emek; test sonucu değildir.

Gölge ölçümü. Beş iş günü. Sonuç: günde ortalama 4 eşleşme, hepsi iki kaynaktan — bir yedekleme hesabı (haftalık bakım penceresinde) ve bir izleme hesabı (yanlış yapılandırılmış, LogonType 2 ile koşuyor). İkincisi zaten bir bulgu: kural daha üretime çıkmadan bir yapılandırma hatasını ortaya çıkardı.

Ayarlama. Yanlış yapılandırılmış hesabı düzeltmek önceliklidir. Yetkili bakım için IP koşulu yalnız IP taşıyan RDP olayında anlamlıdır. Konsol oturumunda IP bulunmayabilir; bu dalda IP'ye dayanan dışlama uygulanmaz. Kimlik, hedef grubu ve doğrulanmış bakım bağlamı ayrı test edilir.

Konsol ve RDP dışlamaları tek bir IP koşuluna sıkıştırılmaz. Boş IpAddress, izinli RDP kaynağı, izinsiz RDP kaynağı ve yanlış hedef grubu ayrı test edilir. Yerel bir yanlış yapılandırma, tehdit isabeti hesabında saldırı olarak sayılmaz.

Doğrulama planı. Kontrollü oturum, ham 4624 ve alarm aynı koşu kimliğiyle ilişkilendirilir. Gecikme gerçek yürütme ve alarm zamanından ölçülür. Yalnız başarı kanıtı mevcutsa x_last_successful_validation yazılır; gösterilen öğretim kuralının durumu experimental kalır.

Altı ay sonraki kontrol. Eşleşen oturumların kapanış nedenleri, izin politikası ve bakım dışlaması yeniden incelenir. Yanlış yapılandırmanın yakalanması davranış açısından doğru eşleşmedir; tehdit isabeti hesabında saldırı diye sayılmaz.

> **SAHADAN NOT — BASİT KURALIN BAKIMI DA VARDIR**
>
> Kimlik ve oturum türü ilişkisi sade olabilir. İsabeti ölçülmeden yüksek, bakım maliyeti sıfır sayılmaz: hesap envanteri ve yetki politikası değişir. Kuruma özgü tutarsızlık kontrolleri yararlıdır; veri ve kapsamları da düzenli doğrulanmalıdır.

14.3 Vaka 2 — Zamanlanmış görevle kalıcılık

Bağlam. Aynı kurum, birkaç ay sonra. Fikir bu kez tehdit istihbaratından geldi: sektöre yönelik bir kampanyada `schtasks` ile SYSTEM bağlamında zamanlanmış görev oluşturularak kalıcılık kuruluyordu (T1053.005).

Veri kontrolü, ve ilk sürpriz. Bölüm 3.7'nin ilk kapısı bu kez olumsuz yanıt verdi. Windows'un 4698 olayı (zamanlanmış görev oluşturma) yalnızca sunucuların %12'sinde üretiliyordu; denetim politikası çoğu makinede kapalıydı. Sysmon EID 1 üzerinden `schtasks.exe` çalıştırmasını yakalamak alternatifti, ama Sysmon da yalnızca kritik sunucularda kuruluydu.



Şekil 14.2 Temsili veri talebi; varlık kapsamı ile varyant doğrulaması ayrı kayıtlardır.

Kararı doğru vermek. Burada iki yanlış yol vardı. Birincisi, kuralı %12'lik kapsamla yazıp "bu tekniği kapsıyoruz" demek — Bölüm 6.4'teki şişirilmiş kapsama. İkincisi, veri yok diye fikri tamamen bırakmak. Doğru yol üçüncüsüydü: fikri Bölüm 2.11'deki kapsama envanterine bir **veri talebi** olarak kaydetmek.

Talep. Teknik, gereken 4698 olayı, ilgili Success denetim alt kategorisi, hedef varlıklar ve pilot ölçüm yöntemi yazılır. Ek hacim pilotta hesaplanır; yalnız "az olay bekliyoruz" ifadesiyle bütün ortamın yükü ihmal edilebilir ilan edilmez.

Altı hafta bekleme. GPO değişikliği bir değişiklik yönetimi sürecinden geçti. Bu süre boşa geçmedi: kural yazıldı, testleri kuruldu ve %12'lik kapsamda gölgede çalıştırıldı. Böylece politika dağıtıldığında kural zaten hazırdı ve doğrudan ölçüme geçilebildi.

VAKA 2 — SÜREÇ VE 4698 İÇİN AYRI KURALLAR

```
title: Schtasks ile SYSTEM hesabı için görev oluşturma isteği
id: 8b1e4c07-2f56-4a19-83d7-6c0a9e2b4f71
status: experimental
description: >-
  İngilizce SYSTEM hesabını /ru argümanında isteyen schtasks sürecini seçer.
  Başarılı görev oluşturulduğunu kanıtlamaz; 4698 kuralı ayrı kanıttır.
logsource: {category: process_creation, product: windows}
detection:
  selection:
    Image|endswith: '\schtasks.exe'
    CommandLine|contains: '/create'
    CommandLine|re: '(?i)(?:^|\s)/ru\s+(?:"(?:NT AUTHORITY\\)?SYSTEM"|SYSTEM)(?:\s|$)'
  condition: selection
fields: [CommandLine, ParentImage, User, Computer]
falsepositives: [Meşru kurulum ve bakım görevleri]
level: high
tags: [attack.persistence, attack.t1053.005, pattern.relationship]
x_data_requirement: Sysmon EID 1 veya komut satırı politikası açık Security 4688.
x_rule_revision: dwell-1.1-schtasks-process-r1

---
title: Security 4698 görevinde SYSTEM Principal
id: 3a478786-2447-4b72-b28f-d8120c515c1b
status: experimental
description: TaskContent XML içindeki Principal UserId alanından SYSTEM görevini seçer.
logsource: {product: windows, service: security}
detection:
  selection:
    EventID: 4698
    TaskPrincipalUserId: ['S-1-5-18', 'SYSTEM', 'NT AUTHORITY\SYSTEM']
  condition: selection
fields: [TaskName, TaskPrincipalUserId, SubjectUserName, Computer]
falsepositives: [Meşru kurulum ve bakım görevleri]
level: high
tags: [attack.persistence, attack.t1053.005]
x_data_requirement: >-
  Audit Other Object Access Events (Success); TaskContent XML ayrıştırması.
  TaskPrincipalUserId özel sözleşme alanıdır, ham Windows alanı değildir.
x_rule_revision: dwell-1.1-task-security-r1
```

İki kaynak, iki ayrı kuraldır. Süreç kuralı schtasks isteğini; 4698 kuralı oluşturulan görevin TaskContent içindeki Principal kimliğini gösterir. TaskPrincipalUserId ayrıştırıcının ürettiği özel alandır. 4698 yoksa bu ikinci kuralın varlık kapsamı kazanılmış sayılmaz.

Görev oluşturma denetiminin sağlanması başka tespitleri de mümkün kılabilir. Görev değiştirme ve silme olayları ayrıca toplanıp sınanmalıdır; 4698'in gelmesi bütün görev yaşam döngüsü olaylarının geldiğini kanıtlamaz.

DİKKAT — VERİ TALEBİNİ TESPİT İŞİ GİBİ TAKİP EDİN

Veri talepleri, açıldıktan sonra unutulmaya en yatkın iş kalemidir; çünkü başka bir ekibin kuyruğundadır ve tespit ekibinin panosunda görünmez. Sahada gördüğüm birçok kapsama boşluğu, aslında iki yıl önce açılmış ve takip edilmemiş bir taleple ilgiliydi.

Çözüm basittir: veri taleplerini kapsama envanterinde açık bir kalem olarak tutun ve her bakım turunda gözden geçirin. Kapatılmamış bir veri talebi, yazılmamış bir kural kadar gerçek bir boşluktur.

14.4 Vaka 3 — Yanal hareket, iki kez baştan

Bağlam. Aynı kurum, bir yıl sonra. Kütüphane olgunlaşmış, ekip iki kişi. Fikir bir purple team egzersizinden geldi: kırmızı takım `wmic /node:` ile sunucular arasında komut çalıştırdı ve hiçbir alarm düşmedi.

Veri kontrolü. Bu kez sorun yoktu: Sysmon EID 1 artık geniş kapsamda toplanıyordu ve komut satırı doluydu. İş doğrudan kural yazımına geçti, ve asıl zorluk burada başladı.



Şekil 14.3 Vaka 3'te kapsamı daraltma: uzak faaliyet, kabuk kökenli yürütme isteği ve hedef sayımı. Nadirlik ek bağlamdır.

Birinci deneme: komut satırında /node: aramak. Bu, uzak WMIC faaliyetidir; envanter ve durum sorguları da eşleşebilir. Böyle bir başlangıç kuralının çıktısını doğrudan "uzak komut yürütüldü" diye adlandırmak fazla geniş bir iddiadır.

Bu noktada kolay yol dışlama eklemekti. Üç aracı dışlamak hacmi düşürürdü ama Bölüm 9.5'teki kör noktayı açardı: saldırgan aynı komutu o hesaplarla çalıştırdığında görünmez olurdu. Bunun yerine kalıp değiştirildi.

İkinci deneme: uzak süreç oluşturma isteğini ve kabuk kökenini aramak. process call create davranışı ile gerçek ebeveyn birlikte sınanır. Komutun başarıyla yürütüldüğü ayrı telemetriyle doğrulanır; yöneticiler de aynı yöntemi kullanabilir.

Üçüncü deneme: farklı hedefleri saymak. Aynı kaynak ve kullanıcı için on dakikada üçten fazla TargetHost seçilir. Hedef alanı komut satırından çıkarılır; tek komutta birden fazla hedef varsa ayrı hedef kayıtlarına açılır. Nadirlik bu YAML'de filtre değildir; alarm bağlamına eklenir. Alarmın azalması ve isabetin değişmesi gerçek kayıtlar üzerinde ayrıca ölçülür.

VAKA 3 — AYRIŞTIRILMIŞ HEDEF SAYIMI

```
title: Kabuk kökenli WMIC uzak süreç oluşturma isteği
id: c7659323-7279-4faf-9d4d-a2f3b894605a
name: wmic_uzak
logsource: {category: process_creation, product: windows}
detection:
  selection:
    Image|endswith: '\wmic.exe'
    CommandLine|contains|all: ['/node:', 'process', 'call', 'create']
    TargetHost|exists: true
  selection_parent:
    ParentImage|endswith: ['\cmd.exe', '\powershell.exe', '\wscript.exe', '\mshta.exe']
  condition: selection and selection_parent
---
title: On dakikada dört veya daha fazla WMIC hedefi
id: 6b59bf7c-5a19-4d50-a6ec-8b9a67fcb0e8
status: experimental
description: >-
  Aynı kaynak ve kullanıcı için farklı TargetHost değerlerini sayar.
  TargetHost komut satırından ayrıştırılır; nadirlik yalnız zenginleştirmedir.
correlation:
  type: value_count
  rules: [wmic_uzak]
  group-by: [User, Computer]
  timespan: 10m
  condition:
    field: TargetHost
    gt: 3
falsepositives: [Meşru toplu yönetim]
level: high
tags: [attack.lateral-movement, attack.t1047, pattern.threshold]
x_rule_revision: dwell-1.1-wmic-correlation-r1
```

Nadirlik, kaynak–hedef geçmişinden hesaplanan ayrı zenginleştirmedir. Örnekte altmış günlük geçmiş varsayılır. “Bu hedef daha önce görüldü mü?” bilgisi analiste yardımcı olur; eşik koşulunu veya YAML’nin eşleşme sonucunu değiştirmez.

TargetHost ham Sysmon alanı değildir. Eşlikçi ayrıştırıcı tek /node ve literal virgüllü host listesini destekler; @dosya ve çözümlenemeyen biçimleri reddeder. Çoklu hedefler aynı olay kimliği korunarak ayrı hedef satırlarına açılır. WMIC’in bulunması işletim sistemi sürümüne bağlıdır; kurulu olmayan araç için bu örnek uygulanmaz.

İlk denemenin sonu. Birinci deneme silinmedi. Kalıbı değiştirilip zenginleştirmeye taşındı: `wmic /node:` çağrılarının ham listesi artık bir av kuyruğunda duruyor ve haftalık olarak frekans analiziyle taranıyor. Bölüm 3.2'deki ilke — gürültülü bir kuralı silmek yerine başka bir kullanım biçimine taşımak — tam olarak bu.

Doğrulama planı. Tek hedef, aynı pencere içinde dört hedef, farklı kullanıcıların hedefleri, alıntılı/virgüllü hedef listesi ve yavaş yayılma sınanır. Zamanlanan motorun pencere sınırında da test yapılır. Gerçek koşu ve alarm kanıtı olmadan gecikme değeri yazılmaz.

ÖRNEK — BİLİNEN SINIRI YAZMAK

Herhangi bir on dakikalık pencerede üçten fazla farklı hedefe ulaşmayan yavaş hareket bu eşikle yakalanmaz. Tek hedefe yönelik yürütme ayrı temel sinyal olarak tutulabilir. Telafi av sorgusu varsa kimliği, dönemi ve gerçek sahibi kayda eklenir; var olmayan bir HUNT numarası çalışır kontrolmüş gibi yazılmaz.

Bakım. Yönetim aracı WinRM kullanmaya başladığında WMIC kuralı kendiliğinden bozulmaz. Yeni görünür davranış ile daha önceki WinRM kapsam boşluğu ayrılır. WinRM'in kendi veri ve tespit sözleşmesi kontrol edilir; kapsam açığı ancak bu incelemeyle kaydedilir.

14.5 Üç vakadan çıkan dersler

Üç vaka farklı yollardan geçti ama ortak birkaç şey söylüyorlar.

Temsili vaka	1	2	3
Fikir	Olay dersi	Tehdit araştırması	Purple test
Engel	Hesap envanteri/politika	Telemetri kapsamı	Geniş başlangıç mantığı
Mantık	Kimlik + oturum türü	İki kaynağa ayrı kural	Yürütme isteği + hedef sayımı
Ek bağlam	Bakım yetkisi	Görev Principal	Kaynak–hedef nadirliği
Kanıt	4624 ve gerçek alarm	Süreç ile 4698 ayrı	Parser/pencere/replay

İlk ders, farklı bilgi kaynaklarını birlikte kullanmaktır. Bu üç temsili vakada fikir olay incelemesinden, tehdit araştırmasından ve kontrollü testten gelir. Mühendisin kendi veri araştırması da yeni bir hipotez üretebilir; kaynağı ve gerekçeyi kayda yazın.

İkinci ders veri kontrolüdür: gerekli olayın varlık kapsamını bilmeden üretim iddiası kuramayız. Hazır olmayan veri için önce toplama ve görünürlük işi tamamlanır.

Üçüncü ders, gürültünün her zaman dışlamayla çözülmemesidir. Üçüncü vakada önce davranış kapsamını daraltıyoruz, sonra kaynak–hedef bağlamını ekliyoruz. Yararı aynı veri üzerinde karşılaştırılır.

Dördüncü ders, aktif emekle takvim süresini ayırmaktır. Ölçüm sürerken başka işler yürütülebilir; vakalardaki süreler temsili planlama örnekleridir.

14.6 Kapanış

Bu ciltte veriyi tanıma, mantığı yazma, sınırlarını sınama, alarm yükünü ölçme ve bakım işini birlikte ele aldık.

Ben bu işte kanıtın kapsamını açık yazmayı önemsiyorum. Veri kontrolü gerekli olayları, birim testi seçilmiş örnekleri, hedef replay ve emülasyon da belirli varyantın sonucunu gösterir. Gölge ölçümü yükü, bakım bu koşulların sürüp sürmediğini izler.

Her tespit için "Bunun çalıştığını nereden biliyorum?" sorusuna tarih, revizyon, kapsam ve kanıtla cevap vermek istiyorum. Kanıt eksikse o eksikliği de kayda yazmalıyız.

Gördüğümüz varyantları, bilinen boşlukları ve kanıtı bir arada tutmak, ortam değiştiğinde bir sonraki işi seçmemizi kolaylaştırır.

Bir sonraki ciltte threat hunting'i, yani hipotezle yürütülen tehdit avını ele alacağım.

Umarım bu kitap, tespitleri yazarken ve neyi gördüklerini yeniden sınarken elinizin altında olur.

EK A

Sigma Hızlı Referans

Bölüm 4'ün başvuru özeti. Bu kutular tam dosya yerine geçmeyen yapı parçalarını bir araya getirir.

İSKELET — BOŞ ALANLAR AÇIKLAMA İÇİNDİR

```
# Tam örnek: rules/office_enc_powershell.yml
# title / logsource / detection: tek olay türünde zorunlu.
# id: kalıcı UUID; status: experimental | test | stable | deprecated | unsupported
# date: YYYY-MM-DD; modified: YYYY-MM-DD
# description: davranış ve sınır; references: kesin kaynak URL'si
# fields: alarm alanları; falsepositives: liste ([] olabilir)
# level: informational | low | medium | high | critical
# tags: davranışa uygun ATT&CK ve yerel kalıp etiketleri
# correlation türünde logsource/detection yerine correlation vardır.
```

Modifier	Ne yapar
contains	Değer bu dizgiyi içeriyorsa
startswith / endswith	Bu dizgiyle başlıyor / bitiyorsa
all	Listedeki tüm değerler sağlanmalı
cased	Metinde harf duyarlı eşleşme ister
re	Varsayılan harf duyarlı regex; hedefte sınanır
base64 / base64offset	Değeri dönüştürür; offset üç hizalama üretir
cidr	IP aralığı içinde mi
lt lte gt gte	Sayısal karşılaştırma
windash	- ve / bayrak biçimlerini birlikte arar
fieldref	Değeri başka bir alanla karşılaştırır
exists	Anahtar var mı? Null/boş değer var olabilir

CONDITION — ALTERNATİF SATIRLAR

```
# Her satır ayrı bir condition seçeneğidir.
# condition: selection
# condition: selection and not filter_x
# condition: selection and not 1 of filter_*
# condition: selection and not all of filter_*
# condition: 1 of selection_*
# condition: all of selection_*
```

KORELASYON — İKİ AYRI AÇIKLAMA PARÇASI

```
correlation:
  type: event_count
  rules: [base_rule]
  group-by: [User, Computer]
  timespan: 10m
  condition: {gte: 20}
---
correlation:
  type: value_count
  rules: [base_rule]
  group-by: [User, Computer]
  timespan: 10m
  condition: {field: TargetHost, gt: 3}
# temporal/temporal_ordered için farklı kural referansları ve sıra önemlidir.
# base_rule burada açıklama adı; tam dosya rules/ içinde verilmiştir.
```

CLI — DOĞRULANMIŞ HEDEF VE PIPELINE ADLARI

```
python -m pip install -r requirements-lock.txt
sigma list targets
sigma list pipelines
python -m tools.sema_kontrol rules --as-of 2026-10-06
python -m tools.derle
sigma convert -t splunk -p splunk_windows rules/office_enc_powershell.yml
sigma convert -t lucene -p pipelines/sysmon-to-ecs.yml rules/office_enc_powershell.yml
```

EK B

Alan Eşleme Tablosu

Kaynak alanı ile ortak şema alanını ad ve anlamıyla birlikte okuyun. Tablo ECS, CIM 6.4 ve paketteki sabit OCSF kaydına dayanır; kaynak sürümü ve eşleme yine kontrol edilir.

TABLONUN NOTLARI

[1] OCSF alanları paketteki commit kaydıyla sınırlıdır. [2] _indextime indeksleme zamanıdır. [3] Hash için algoritma ve ilgili dosya seçilir; Sysmon Hashes, algoritma=değer çiftleridir. CIM 6.4 process_hash açıklaması ebeveyn digest'ini söyler; yerel sözleşme olmadan süreç SHA256'sı saymayın. [4] LogonType oturum türüdür, kimlik doğrulama yöntemi değildir. winlog.* entegrasyon; yerel logon_type ve OCSF unmapped eşlemesi ayrıca belgelenir. Actor, ebeveyn ve hedef kimlik ayrılır.

Kavram	ECS / entegrasyon	OCSF şema kaydı	CIM 6.4 / yerel	Windows
Olay zamanı	@timestamp	time (UTC ms)	_time	UtcTime / TimeCreated
Ajan okuması	event.created	Logger/sözleşme	Yerel alan	Yerel alan
Ara işleme	Yerel alan	metadata.processed_time	Yerel alan	Yerel alan
Merkezî varış	event.ingested	metadata.logged_time[1] (isteğe bağlı; depolama zamanı)	_indextime[2]	Yerel alan
Makine	host.name	device.hostname	dest	Computer
Kullanıcı	user.name	actor.user.name	user	User / hedef kimlik
Süreç yolu	process.executable	process.file.path	process_path	Image
Süreç adı	process.name	process.file.name	process_name	Yoldan ayrıştırılır
Komut	process.command_line	process.cmd_line	process	CommandLine
Süreç ID	process.pid	process.pid	process_id	ProcessId
Ebeveyn yolu	process.parent.executable	process.parent_process.file.path	parent_process_path	ParentImage
Ebeveyn komutu	process.parent.command_line	process.parent_process.cmd_line	parent_process	ParentCommandLine
Süreç SHA256	process.hash.sha256	process.file.hashes[3]	process_hash[3] (doğrudan SHA-256 eşdeğeri değil)	Hashes[3]
Genel dosya SHA256	file.hash.sha256	file.hashes[3]	file_hash[3]	Kaynağa bağlı
Kaynak IP	source.ip	src_endpoint.ip	src_ip	SourceIp / IpAddress
Hedef IP	destination.ip	dst_endpoint.ip	dest_ip	DestinationIp
Hedef port	destination.port	dst_endpoint.port	dest_port	DestinationPort
DNS adı	dns.question.name	query.hostname	query	QueryName
Registry yolu	registry.path	reg_key.path	registry_path	TargetObject
Kaynak olay kodu	event.code	metadata.event_code	signature_id / sözleşme	EventID
OCSF olay sınıfı	Eşdeğer değil	class_uid	Eşdeğer değil	EventID ile aynı değil
Windows oturum türü	winlog.logon.type[4]	Özel/unmapped alan[4]	Yerel logon_type[4]	LogonType
Kimlik doğrulama yöntemi	Kaynak entegrasyonu	Authentication sınıfı[4]	authentication_method[4]	AuthenticationPackageName

EK C

Kontrol Listeleri

Kitapta dağınık hâlde geçen kontrol noktalarının tek yerde toplanmış hâli. Yazdırıp yanınızda tutmak için.

C.1 Yeni bir kural yazmadan önce

VERİ VE TASARIM

[ ] Davranış ve kapsam açıkça tanımlandı mı?
[ ] Gereken olay türleri ve alanlar gerçekten geliyor mu?
[ ] Tip, biçim, anlam ve zaman sözleşmesi doğrulandı mı?
[ ] Mevcut tespit veya av içeriği araştırıldı mı?
[ ] Alarm, av veya zenginleştirme kullanımına karar verildi mi?
[ ] Test edilebilir koşul ve bilinen sınır yazıldı mı?

C.2 Kural incelemesi

İNCELEME

[ ] Başlık, mantığın gerçekten gösterdiği davranışı söylüyor mu?
[ ] Meşru ve şüpheli olaylar ayrı fixture'larla sınandı mı?
[ ] Her dışlamanın gerekçesi, sahibi ve gözden geçirme tarihi var mı?
[ ] Onaylı metni inert argümana ekleyerek kaçış denendi mi?
[ ] Eşlenmeyen/boş alan ve farklı harf biçimi sınandı mı?
[ ] Hedef motorun destek ve pencere sınırları yazıldı mı?
[ ] Alarma bakan kişi kanıtı ve ilk adımı görebiliyor mu?

C.3 Yeni bir log kaynağı bağlarken

VERİ SÖZLEŞMESİ

[ ] Güncel ham kayıtlar, ayrıştırılmış alanlarla karşılaştırıldı mı?
[ ] Kaynak/ajan/şema sürümü ve olay kapsamı kaydedildi mi?
[ ] Alan türü, anlamı, doluluk ve uzunluk referansı ölçüldü mü?
[ ] Olay, ajan okuması, işleme ve merkezî varış ayrıldı mı?
[ ] Saat ofseti ve senkronizasyonu kontrol edildi mi?
[ ] Sıfır olaylı varlıklar envanterle karşılaştırıldı mı?
[ ] Sözleşme sahibi ve değişiklik bildirimi belli mi?

C.4 Emülasyon koşusu

EMÜLASYON: ÖNCE, SIRASINDA, SONRA

ÖNCE
[ ] Yetki, sistemler, tarihler ve varyantlar yazılı mı?
[ ] Yıkıcı adımlar izole laboratuvara ayrıldı mı?
[ ] Benzersiz nesne adı, sahiplik kaydı ve cleanup tanımlı mı?
[ ] Beklenen telemetri, kural revizyonu ve alarm sonucu yazıldı mı?
SIRASINDA
[ ] Host, ajan, yürütme kimliği ve gerçek başlangıç zamanı tutuluyor mu?
SONRA
[ ] Ham olay, sonra alarm, aynı koşu için kontrol edildi mi?
[ ] Son test ile son başarılı doğrulama ayrı yazıldı mı?
[ ] Eksik/başarısız ölçüme gecikme değeri uydurulmadı mı?
[ ] Yalnız oluşturulan nesneler temizlendi ve sonuç doğrulandı mı?

C.5 Üç aylık bakım turu

BAKIM TURU

[ ] Etkin envanter ile alarm ve kaynak sağlığı birleştirildi mi?
[ ] Sessiz fakat doğrulanmış içerik ile veri/kural arızası ayrıldı mı?
[ ] Aynı revizyon ve güncel kanıt şartı denetlendi mi?
[ ] Dışlamaların toplam kapsam kaybı ve süresi incelendi mi?
[ ] Geçersiz içerik gerekçesi ve successor ile emekli edildi mi?
[ ] Aktif, pasif ve dosya sayıları ayrı raporlandı mı?
[ ] Önceki turla aynı payda ve dönemde karşılaştırıldı mı?

EK D

Başlangıç Kural Seti

Yeni bir tespit programı için başlangıç önerileri. Önceliği kendi tehdit ihtiyacınıza, hazır telemetrinize ve araştırma kapasitenize göre seçin. Listedeki başlıklar ölçülmüş isabet oranı vaat etmez.

#	Tespit	Teknik	Kalıp	Gerekli veri
1	Office → PowerShell	T1059.001	İlişki	Süreç + gerçek ebeveyn
2	Kodlanmış PowerShell	T1059.001; T1027 bağlama göre	Eşleşme	Komut satırı
3	Sistem adı yanlış dizinde	T1036.005	İlişki	Süreç + gerçek yol
4	Certutil/bitsadmin indirmesi	T1105	İlişki	Komut + ağ/sonuç kanıtı
5	Domain servis hesabı oturumu	T1078.002	İlişki	4624 + SID/envanter + tür
6	Başarısız yığın → başarı	T1110	Eşik/sıra	4625 + 4624; kimlik kapsamı
7	SYSTEM görev oluşturma	T1053.005	İlişki	4698 XML; süreç kuralı ayrı
8	Yeni servis, şüpheli yol	T1543.003	İlişki	7045 veya 4697 + yol
9	Şüpheli LSASS erişimi	T1003.001 bağlama göre	İlişki	Sysmon EID 10 + erişim maskesi
10	Yeni ve imzasız ikili	Tek başına eşlenmez	Nadirlik	Süreç + doğrulanmış imza/hash
11	Yeni kayıtlı domaine sorgu	Tek başına C2 eşlenmez	Nadirlik	DNS + güvenilir kayıt yaşı
12	İmkânsız seyahat hipotezi	T1078.004 bağlama göre	Sapma	Kimlik + konum + VPN/oturum bağlamı

ÖNCELİĞİ VERİ GEREKSİNİMİYLE SEÇİN

1–4 süreç ve komut satırı; 5–6 oturum; 7 görev; 8 servis kurulum; 9 süreç erişimi telemetrisi ister. Aynı Windows kanalı bu olayların bazılarını taşıyabilir, ancak her audit alt kategorisi ve alan ayrı doğrulanır. 10 ek imza zenginleştirmesi, 11 DNS ve güvenilir kayıt yaşı, 12 kimlik konum bağlamı gerektirir. Sırayı kendi tehdit ihtiyacınıza ve hazır verinize göre kurun.

Her kuralın veri gereksinimi, sahibi, kapsamı ve testi yazılmalı; hedefte ve emülasyonda doğrulanmalı; üretim öncesi gölgede ölçülmelidir. Kabul koşulları Bölüm 7'deki kapılarda yer alır.

SÖZLÜK

Terimler

Kitap boyunca geçen terimlerin kısa karşılıkları. Terimler sahada kullanıldıkları hâliyle verilmiştir.

Alan doluluk oranı Seçilmiş olay kümesinde bir alanın dolu geldiği kayıtların yüzdesi. Türün ve anlamın doğru olduğunu tek başına kanıtlamaz.

Atomik test Belirli bir saldırgan davranışını veya teknik varyantını dar kapsamda çalıştıran, tekrar edilebilir test. Tek başına bütün ATT&CK tekniğini doğrulamaz.

ATT&CK MITRE'nin gerçek olaylarda gözlenmiş saldırgan taktik ve tekniklerini kataloglayan çerçevesi.

Baseline Bir ortamın "normal"inin ölçülmüş hâli; sapma ve nadirlik tespitleri buna göre çalışır.

Building block QRadar'da yeniden kullanılabilir koşul kümesi; dışlama ve varlık listeleri için kullanılır.

CIM Splunk'ın ortak veri modeli (Common Information Model).

Detection-as-code Kuralların sürüm kontrolünde tutulup test edilerek bir hatla dağıtıldığı çalışma biçimi.

Dwell time Bir sistemin ele geçirilmesinden ihlalin tespitine kadar geçen süre. Bu kitaptaki emülasyon gecikmesiyle aynı başlangıç noktasına sahip değildir.

ECS Elastic Common Schema; yaygın kullanılan ortak alan şeması.

Emülasyon Gerçek saldırgan davranışının kontrollü biçimde tekrarlanması (adversary emulation).

EQL Elastic'in olay sorgulama dili; sequence ile zincir tespiti yapılabilir.

False negative Gerçekleşmiş ama yakalanmamış olay.

False positive Açıkça tanımlanmış hedef sınıf için yanlış pozitif. Davranış eşleşmesi ile tehdit sınıflaması aynı etiket değildir; benign true positive ayrı tutulur.

Gölge mod Kuralın çalışıp eşleşmelerinin ölçüldüğü, operasyon bildirimlerinin yönlendirilmediği aşama. Devre dışı kural gölge çalışmaz.

Idempotent Aynı işlemin birden çok kez uygulanmasının tek bir kez uygulanmasıyla aynı sonucu vermesi.

İsabet (precision) Etiketli kümede TP/(TP+FP). Tehdit isabeti hesabında değerlendirilmemiş ve kararsız kayıtların paydası ayrıca belirtilir.

Kalıp Bir tespitin mantık biçimi: eşleşme, ilişki, eşik, nadirlik, sıra ya da sapma.

Kapsama haritası Hangi tekniklerde veri, kural ve doğrulama bulunduğunu gösteren tablo.

Kapsama (recall) Etiketli gerçeklik kümesinde TP/(TP+FN). Test kümesindeki değer bütün üretim olaylarına genellenmez.

Korelasyon Birden çok olayın bir zaman penceresinde birleştirilerek değerlendirilmesi.

Körelme Bir kuralın hata üretmeden işlevsiz hâle gelmesi.

LOLBin Sistemin meşru ikilisinin saldırgan tarafından kötüye kullanılması (living off the land binary).

Nadirlik Bir değerin ortamda ilk kez ya da çok seyrek görülmesine dayanan tespit kalıbı.

Notable event Bu bölümde Splunk Enterprise Security 7.2'nin correlation search sonucu üretilen ve Incident Review'da incelenen kaydı. Ürün ve sürüm terimleri ayrıca kontrol edilir.

OCSF Satıcıdan bağımsız olmayı hedefleyen açık güvenlik şeması.

Offense QRadar'da rule action/response ve indeksleme ayarlarıyla oluşturulan veya güncellenen araştırma nesnesi.

Pipeline Sigma kuralını hedef ortama uyarlayan dönüşüm tanımı. Alan eşlemesi yanında desteklenen koşul ve değer dönüşümlerini de içerebilir.

Purple team Kırmızı ve mavi ekiplerin savunmayı birlikte iyileştirmek için çalıştığı yaklaşım.

QID QRadar'da olay sınıflandırma kaydının kimliği; kaynak olay kodu veya her ham olayın benzersiz kimliği değildir.

Regresyon testi Bir değişikliğin mevcut tespitleri bozup bozmadığını gösteren test.

Runtime field Elastic'te sorgu zamanında değerlendirilen alan. İşlem yükü veri ve sorguyla ölçülür.

Sapma Gözlenen davranışın belirlenmiş bir referans dağılımdan uzaklaşmasına dayanan tespit kalıbı. Referans sabit tutulabilir veya tanımlanmış politikayla güncellenebilir.

Sessiz körleşme Verinin akmaya devam ettiği ama kuralın artık eşleşmediği arıza.

Sigma Platformdan bağımsız, YAML tabanlı tespit kural formatı.

Sysmon Ayrıntılı Windows telemetrisi üreten Sysinternals aracı.

Tespit borcu Kütüphanede olup amacını artık yerine getirmeyen ama etkin görünen kuralların birikimi.

Tespit doğrulaması Belirli kural revizyonunun belirli davranış ve varyantı gördüğünün, test veya doğrulanmış olay kaydıyla gösterilmesi.

Tespit gecikmesi Buradaki emülasyon ölçümünde, bilinen davranışın gerçek yürütme anından ilişkilendirilmiş alarmın oluşmasına kadar geçen süre. İhlalin ilk giriş anından ölçülen dwell time ile karıştırılmaz.

TTP Saldırganın taktik, teknik ve prosedürleri; yani yöntemi.

Tuning Bir tespitin gürültüsünü azaltırken korunan ve kaybedilen kapsamı ölçerek yapılan ayarlama.

Veri sözleşmesi Bir log kaynağı ile ona dayanan tespitler arasındaki yazılı mutabakat.

Watchlist Sentinel sorgusu veya analitik kuralında başvurulan liste; _GetWatchlist ile bağlam eklenebilir.

Zenginleştirme Bir alarma varlık, kimlik ve istihbarat bağlamının otomatik eklenmesi.

KAYNAKÇA

Kaynaklar ve ileri okuma

Bu kaynakça, kitapta yararlanılan birincil ürün dokümantasyonunu, teknik şartnameleri ve ileri okuma bağlantılarını içerir. Ürün, sürüm ve şema davranışları zaman içinde değişebilir; doğrudan bağlantılardan güncel teknik açıklamaları kontrol edin. Kaynak belgelerin doğruladığı alan tanımları, belirli bir kurumun veri toplama veya üretim yapılandırmasının çalıştığını tek başına kanıtlamaz.

Microsoft — Sysmon olayları

EID 1 süreç oluşturmadır; imza bilgisi EID 6/7 açıklamalarındadır. EID 10 yüksek hacim üretebilir.

https://learn.microsoft.com/en-us/sysinternals/downloads/sysmon

Microsoft — Sysmon yapılandırma dosyaları

RuleGroup groupRelation alanı AND/OR mantığını belirler.

https://learn.microsoft.com/en-us/windows/security/operating-system-security/sysmon/sysmon-configuration-files

Microsoft — Security 4688

Komut satırı boş olsa da süreç adı, kimlik ve sürüme bağlı ebeveyn bilgisi bulunabilir.

https://learn.microsoft.com/windows/security/threat-protection/auditing/event-4688

Linux Audit — auditctl(8)

İlk eşleşen kural belirleyicidir; sonradan gelen dar kural önceki geniş kuralı iptal etmez.

https://man7.org/linux/man-pages/man8/auditctl.8.html

Linux Audit — audit.rules(7)

auid>=UID_MIN ve auid!=unset geçerli kullanıcı oturumlarına ilişkin filtredir; ayrıcalık testi değildir.

https://man7.org/linux/man-pages/man7/audit.rules.7.html

Elastic — ECS Event alanları

event.created ilk okunma, event.ingested merkezî depoya varış zamanıdır; event.code kaynak olay kodudur.

https://www.elastic.co/docs/reference/ecs/ecs-event

OCSF — Representing Process Parentage

actor.process oluşturan aktörü, process.parent_process ebeveyni temsil eder; Windows üzerinde farklı olabilirler.

https://github.com/ocsf/ocsf-docs/blob/main/articles/representing-process-parentage.md

OCSF — Temel olay şeması

class_uid OCSF olay sınıfını tanımlar; Windows EventID ile aynı kavram değildir.

https://github.com/ocsf/ocsf-schema/blob/main/events/base_event.json

Splunk — CIM 6.4 Endpoint

parent_process tam komut dizgesidir; parent_process_path ebeveyn dosya yoludur.

https://help.splunk.com/en/splunk-enterprise/common-information-model/6.4/data-models/endpoint

Kubernetes — Auditing

Audit politikasında None kayıt üretmez; audit-policy-file verilmemişse olaylar kaydedilmez.

https://kubernetes.io/docs/tasks/debug/debug-cluster/audit/

Zeek — Parmak izi paketleri

JA3 ve JA4 için ayrı Zeek paketleri vardır; temel ssl.log açıklamasından hazır oldukları sonucu çıkmaz.

https://packages.zeek.org/packages?q=fingerprint

SigmaHQ — Sigma Rules Specification

Güncel tarih biçimi YYYY-MM-DD; status seçenekleri arasında unsupported, level seçenekleri arasında informational vardır.

https://sigmahq.io/sigma-specification/specification/sigma-rules-specification.html

SigmaHQ — Modifiers

wide/utf16le kodlama dönüşümleri ve base64offset birlikte kullanılabilir; exists alan varlığını sınar.

https://sigmahq.io/docs/basics/modifiers.html

SigmaHQ — Processing Pipelines

Dönüşümler sıralıdır; exclude_fields listede bulunmayan alanı seçer; detection_item_failure hata oluşturur.

https://sigmahq.io/docs/digging-deeper/pipelines.html

SigmaHQ — Correlations

value_count için condition.field gerekir. Korelasyon kuralları logsource taşımaz; zincirleme desteği backend seçimine bağlıdır.

https://sigmahq.io/docs/meta/correlations.html

SigmaHQ — sigma-cli

Hedefler eklentilerle sağlanır; CLI, backend ve pipeline adları birbirinden ayrılmalıdır.

https://github.com/SigmaHQ/sigma-cli

SigmaHQ — Elasticsearch backend

Elasticsearch eklentisinde LuceneBackend vardır; README komut örneklerinde hedef -t lucene kullanılır.

https://github.com/SigmaHQ/pySigma-backend-elasticsearch

MITRE — ATT&CK sürümleri

Kontrol tarihinde güncel sürüm v19.2; v16 tarihsel sürümdür.

https://attack.mitre.org/resources/versions/

MITRE — Data Sources

Eski Data Sources modeli ATT&CK v18 ile Ekim 2025 itibarıyla kullanımdan kaldırılmıştır.

https://attack.mitre.org/datasources/

MITRE — T1047 WMI

WMI hem yerel hem uzak sistemlerde işlem yapabilir; WMI ebeveyni tek başına uzaklığı kanıtlamaz.

https://attack.mitre.org/techniques/T1047/

MITRE — T1105 Ingress Tool Transfer

Araç veya dosya indirme bu teknik kapsamında değerlendirilir; uygulanan davranış esas alınır.

https://attack.mitre.org/techniques/T1105/

MITRE — T1218 System Binary Proxy Execution

Teknik imzalı sistem ikilisi üzerinden yürütmeyi konu alır; herhangi bir imzalı araç kullanımı yeterli değildir.

https://attack.mitre.org/techniques/T1218/

MITRE — T1071.004 DNS

DNS üzerinden komuta kontrol alt tekniği .004; .001 web protokolleridir.

https://attack.mitre.org/techniques/T1071/004/

Google — Classification metrics

Recall=TP/(TP+FN); etiketli gerçeklik kümesi varsa yanlış negatifler sayılabilir.

https://developers.google.com/machine-learning/crash-course/classification/accuracy-precision-recall

Microsoft — about_PowerShell_exe

EncodedCommand içeriği UTF-16LE ile kodlanmalıdır.

https://learn.microsoft.com/en-us/powershell/module/microsoft.powershell.core/about/about_powershell_exe?view=powershell-5.1

Microsoft — PowerShell parsing

PowerShell açık satır devamı için backtick kullanır.

https://learn.microsoft.com/en-us/powershell/module/microsoft.powershell.core/about/about_parsing?view=powershell-7.1

MITRE — Navigator Layer Format 4.5

domain zorunludur; versions verilirse navigator ve layer alt alanları zorunludur.

https://github.com/mitre-attack/attack-navigator/blob/master/layers/spec/v4.5/layerformat.md

Caldera — Operation Results

Delegation, collection ve agent execution zamanları farklıdır; paw ajan kimliğidir, host ayrı alandır.

https://caldera.readthedocs.io/en/stable/Operation-Results.html

Elastic — Manage detection rules

Devre dışı kuralın zamanlanmış yürütmesi durur; enabled=false gölge çalıştırma değildir.

https://www.elastic.co/docs/solutions/security/detect-and-alert/manage-detection-rules

Elastic — Create a detection rule API

Kibana API, birden çok kural türü ve low/medium/high/critical önem düzeylerini tanımlar.

https://www.elastic.co/docs/api/doc/kibana/operation/operation-createrule

Elastic — Using the detection APIs

Detection API uçları Kibana API kapsamındadır.

https://www.elastic.co/docs/solutions/security/detect-and-alert/using-the-api

Microsoft — Create scheduled analytics rules

Sonuçta TimeGenerated tutulmalı; lookback>=frequency olmalıdır. Varlık eşleme ile incident grouping farklı ayarlardır.

https://learn.microsoft.com/en-us/azure/sentinel/create-analytics-rules

Microsoft — Solution analytics rule format

queryFrequency, queryPeriod, entityMappings ve eventGroupingSettings ayrı yapılandırmalardır.

https://learn.microsoft.com/en-us/azure/sentinel/isv/sentinel-analytic-rules-creation

Microsoft — Sentinel billing

Ücretlendirme veri katmanına bağlıdır; Analytics ile Data Lake sorgu ücretlerini genellemek doğru değildir.

https://learn.microsoft.com/en-us/azure/sentinel/billing

IBM — Custom property expressions

Enable for use in Rules and Search Indexing, CRE kuralında kullanılabilmesi için gereklidir.

https://www.ibm.com/docs/en/qradar-on-cloud?topic=cefp-defining-custom-properties-by-using-custom-property-expressions

Splunk — return

Alt aramadan salt alan değeri döndürmek için $field biçimi kullanılır.

https://help.splunk.com/en/splunk-enterprise/search/spl-search-reference/9.2/search-commands/return

Splunk — tstats

tstats indekslenmiş alanları tsidx dosyaları üzerinden sorgular.

https://help.splunk.com/en/splunk-enterprise/spl-search-reference/10.0/search-commands/tstats

Microsoft — Security 4624

Tip 7 Unlock, tip 11 CachedInteractive; kaynak ağ adresi alanı olay bağlamına bağlıdır.

https://learn.microsoft.com/windows/security/threat-protection/auditing/event-4624

GIAC — Certified Detection Analyst

GCDA ve ilişkili SEC555 eğitimi doğrudan tespit/SIEM alanında bir sertifika yolu sunar.

https://www.giac.org/certifications/certified-detection-analyst-gcda

Creative Commons — Software FAQ

CC, yazılım için yazılıma özgü lisans kullanılmasını önerir. Kitabın izin kapsamı ayrıca yazılmalıdır.

https://creativecommons.org/faq/#can-i-apply-a-creative-commons-license-to-software

Microsoft — Security 4698

4698 görev oluşturma olayıdır; temel görev bilgisi TaskContent XML içindedir, süreç oluşturma şemasıyla aynı değildir.

https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-10/security/threat-protection/auditing/event-4698

Splunk — cidrmatch

cidrmatch CIDR ve IP için string argüman kabul eder.

https://help.splunk.com/en/splunk-cloud-platform/search/search-reference/9.2.2406/evaluation-functions/comparison-and-conditional-functions

Elastic — EQL syntax

sample olay sırasını dikkate almaz ve maxspan desteklemez; eşleşme işleçlerinin harf duyarlılığı farklıdır.

https://www.elastic.co/docs/reference/query-languages/eql/eql-syntax

IBM — Regex Monitor

Pahalı özel özellik ifadeleri performans gerekçesiyle devre dışı bırakılabilir.

https://www.ibm.com/docs/en/qradar-on-cloud?topic=appliances-custom-property-disabled

Splunk — Subsearch result formatting

Alt arama sonucu varsayılan olarak arama ifadesine dönüştürülür; salt sayı olduğu varsayılmamalıdır.

https://help.splunk.com/en/splunk-enterprise/search/search-manual/9.1/subsearches/change-the-format-of-subsearch-results

Open Source Initiative — MIT No Attribution (MIT-0)

Özgün kod için izin ve garanti koşulları.

https://opensource.org/license/mit-0

OCSF — Metadata ve Process şema anlık görüntüsü

metadata.event_code, logged_time, processed_time ve process.parent_process; commit anlık görüntüsü.

https://github.com/ocsf/ocsf-schema/tree/b1b251095d94de314bfdd5fba34a49d7f7543af3/objects

SigmaHQ — pySigma Splunk backend

Backend özellikleri; kitapta 2.1.0 ile yapılan derleme raporu ayrıca pakettedir.

https://github.com/SigmaHQ/pySigma-backend-splunk

Elastic — ECS Process alanları

Gerçek süreç/ebeveyn yolları ve hash alanlarının bağlamı.

https://www.elastic.co/docs/reference/ecs/ecs-process

Microsoft — Defender XDR bağlayıcısını Sentinel'e bağlama

Defender XDR olay tablolarının çalışma alanına alınması ve bağlayıcı kapsamı.

https://learn.microsoft.com/en-us/azure/sentinel/connect-microsoft-365-defender

SigmaHQ — Detection ve Correlation JSON şemaları

Sabitlenmiş şema commit'i; detection ve correlation dosyaları ayrı kullanılır.

https://github.com/SigmaHQ/sigma-specification/tree/ba9251aa834b11a70dbf80836b453dba99c5159e/json-schema

Splunk Enterprise 10.0 — streamstats

Zaman penceresi, artan zaman sırası, sayım ve max_stream_window sınırı.

https://help.splunk.com/en/splunk-enterprise/spl-search-reference/10.0/search-commands/streamstats

SigmaHQ — Appendix: Modifiers, 2.1.0

cased, exists ve regex harf duyarlılığı; anahtar varlığı değerin doluluğu değildir.

https://sigmahq.io/sigma-specification/specification/sigma-appendix-modifiers.html

Elastic — Kibana v8 Find detection rules API

page/per_page, created_at sıralaması, data dizisi ve total alanı. Atomik envanter garantisi çıkarılmaz.

https://www.elastic.co/docs/api/doc/kibana/v8/operation/operation-findrules

AWS — CloudTrail trails

Tek bölgeli ve çok bölgeli izlerin toplama kapsamı; bütün bulut hizmetlerine genellenmez.

https://docs.aws.amazon.com/awscloudtrail/latest/userguide/cloudtrail-trails.html

Microsoft — Windows PowerShell 5.1: about_Logging

Script block ve modül günlüğü; Windows PowerShell Operational kanalı.

https://learn.microsoft.com/en-us/powershell/module/microsoft.powershell.core/about/about_logging?view=powershell-5.1

Microsoft — PowerShell 7.6: about_Logging_Windows

PowerShellCore/Operational ve olay sağlayıcısının kaydı; işlenen betik bloğu kapsamı.

https://learn.microsoft.com/en-us/powershell/module/microsoft.powershell.core/about/about_logging_windows?view=powershell-7.6

NIST — Adversarial Machine Learning, AI 100-2e2025

Bölüm 2.3: öğrenme verisi ve model zehirleme riskleri. Kitabın yerel önlemleri garanti olarak sunulmaz.

https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-2e2025.pdf

Mandiant — M-Trends 2024: dwell time tanımı

Ele geçirilmeden tespit edilmesine kadar geçen süre tanımı; raporun geçmiş istatistikleri güncel oran olarak kullanılmaz.

https://cloud.google.com/blog/topics/threat-intelligence/m-trends-2024

Caldera — Basic Usage

Ability, ajan grubu, adversary profile, planner, fact ve isteğe bağlı cleanup kavramları. Yerel koşu politikası ayrı tanımlanır.

https://caldera.readthedocs.io/en/latest/Basic-Usage.html

IBM — QRadar Administration Guide: Event mapping

Event ID ve kategori bileşimi QID kaydına eşlenir; kayıtta ad, açıklama, kategori ve önem bilgisi bulunabilir. Bölüm: Event mapping.

https://www.ibm.com/docs/en/SSKMKU/pdf/b_qradar_admin_guide.pdf

IBM — Creating a custom rule

CRE test sırası, yerel/global işlem kapsamı ve historical correlation ile hedef testi. Sürüm ve yerleşim ayrıca kaydedilir.

https://www.ibm.com/docs/en/qradar-on-cloud?topic=rules-creating-custom-rule

Splunk Enterprise 9.3 — Quick tips for optimization

Zaman/veri kaynağını daraltma ve hesaplamadan önce filtreleme önerileri; yerel hız ölçümü değildir.

https://help.splunk.com/en/splunk-enterprise/search/search-manual/9.3/optimizing-searches/quick-tips-for-optimization

Splunk — Throttle alerts

Zamanlanmış ve gerçek zamanlı alarm; sonuç alanına ve süreye bağlı throttling. Throttle, ilk tetikleme koşulundan farklıdır.

https://help.splunk.com/en/splunk-cloud-platform/alert-and-respond/alerting-manual/10.2.2510/manage-alert-trigger-conditions-and-throttling/throttle-alerts

Elastic — Runtime fields

Runtime alan sorgu zamanında değerlendirilir; sorgu yükü hesaba katılır. ES|QL sorgu anında yeni runtime alan tanımlamaz; hesaplanan sütunda EVAL kullanılır.

https://www.elastic.co/docs/manage-data/data-store/mapping/runtime-fields

Elastic — Suppress detection alerts

Suppression alanları, zaman seçenekleri, eksik alan ve dizi davranışı kural türüne bağlıdır; abonelik gereksinimi ayrıca kontrol edilir.

https://www.elastic.co/docs/solutions/security/detect-and-alert/alert-suppression

GitHub — Workflow syntax for GitHub Actions

Workflow tetikleyicileri, runner, jobs/steps ve uses/run yapısı. Dosyanın yerel kontrolü GitHub üzerinde koşulmuş CI kanıtı değildir.

https://docs.github.com/en/actions/reference/workflows-and-actions/workflow-syntax

Splunk Enterprise 9.0 — Finding and removing outliers

Ortanca, çeyrekler ve IQR hesabının SPL karşılığı. Belgedeki örnek veya katsayı, kitabın yerel eşiğinin performansını kanıtlamaz.

https://help.splunk.com/en/splunk-enterprise/search/search-manual/9.0/advanced-statistics/finding-and-removing-outliers

Splunk Enterprise 9.3 — Define a KV Store lookup

Lookup eşleme anahtarı, eklenen bağlam alanları ve izin kapsamı; kurum verisinin doğruluğu ayrıca incelenir.

https://help.splunk.com/en/splunk-enterprise/manage-knowledge-objects/knowledge-management-manual/9.3/use-lookups-in-splunk-web/define-a-kv-store-lookup-in-splunk-web

Splunk Enterprise Security 7.2 — Investigate a notable

Notable kaydından correlation search ve katkı olaylarına geçiş. Bu bölümde ES 7.2 terminolojisi kullanılır; bütün sürümlere genellenmez.

https://help.splunk.com/en/splunk-enterprise-security-7/user-guide/7.2/incident-review/investigate-a-notable-on-incident-review-in-splunk-enterprise-security

Microsoft — Build queries or rules with watchlists

_GetWatchlist ve SearchKey ile sorgu/analitik kural bağlamı; varlık eşleme ve incident grouping yerine geçmez.

https://learn.microsoft.com/en-us/azure/sentinel/watchlists-queries

IBM Redbooks — Securing Data on Threat Detection, 2021

Basılı sayfa 34, Şekil 32: offense index, rule response ve response limiter ayarları. Tarihli ürün örneğidir; kurulu sürümde ayrıca doğrulanır.

https://www.redbooks.ibm.com/redpapers/pdfs/redp5560.pdf

AWS — CloudTrail event record contents

sourceIPAddress alanındaki AWS hizmet kökenli IP dışı değerleri ve bağlamı açıklar.

https://docs.aws.amazon.com/awscloudtrail/latest/userguide/cloudtrail-event-reference-record-contents.html

Microsoft — Azure Monitor DeviceProcessEvents şeması

Sentinel Log Analytics DeviceProcessEvents tablosunda bulunan TimeGenerated ve süreç alanlarını açıklar.

https://learn.microsoft.com/en-us/azure/azure-monitor/reference/tables/deviceprocessevents

Elastic — EQL syntax

sequence, by ve maxspan sözdizimini ve birleştirme anahtarlarının null sınırını açıklar.

https://www.elastic.co/docs/reference/query-languages/eql/eql-syntax

Splunk — CIM 6.4 Endpoint Processes

process, process_path, parent_process_path ve process_hash alanlarının tanımları.

https://help.splunk.com/en/splunk-cloud-platform/common-information-model/6.4/data-models/endpoint